

FIRST SECURITY

Cibersegurança Ofensiva · Pentest · Red Team

Conteúdo Redigido do Site

Textos prontos por página, com CTAs, formulários e linkagens internas

Domínio: firstsecurity.com.br

Companheiro da Documentação de Implementação do Site

Documento confidencial · Uso interno First Security

Sumário

Parte 1. Apresentação e convenções deste documento

Parte 2. Home institucional (/)

Parte 3. Páginas centrais e atalhos de conversão (Contato, Orçamento, Agendar conversa, Quem somos)

Parte 4. Hub e pilares de Pentest (/pentest, /pentest/o-que-e, /pentest/tipos)

Parte 5. Páginas de serviço (18 páginas comerciais redigidas)

Parte 6. Pilar Red Team em cibersegurança e netas

Parte 7. Comparativos (oito páginas redigidas)

Parte 8. Páginas de Compliance regulatório (sete páginas)

Parte 9. Páginas verticais e segmentos B2B

Parte 10. Páginas geográficas (Onde atendemos)

Parte 11. Blog: textos prontos para pilares e estrutura editorial

Parte 12. Páginas de autoridade e E.E.A.T. (Metodologia, Equipe, Certificações, Diferenciais, Casos de uso, Modelo de relatório, Glossário)

Parte 13. Páginas legais (textos prontos para Política de Privacidade, LGPD, Termos, Cookies, Divulgação Responsável e Confidencialidade)

Parte 14. Encerramento, próximos passos e governança de revisão

Parte 1. Apresentação e convenções deste documento

Este documento traz, para cada página do site First Security, o conteúdo redigido e pronto para implementação: hero, parágrafos por seção, textos exatos dos botões, hierarquia interna de links, perguntas frequentes respondidas e indicação clara de onde aparece CTA, onde aparece formulário e onde o bloco é puramente informativo. É o complemento direto da Documentação de Implementação do Site, que mapeou a arquitetura, e antecede o Design System, que vai definir a roupagem visual.

A leitura deve ser feita em conjunto com a Documentação de Implementação. Aquele documento explica por que cada página existe, qual é a intenção de busca atendida, qual o schema técnico, qual o lugar dela na arquitetura. Este documento entrega o que cada página fala, com que palavras, com que ritmo e quais decisões o visitante é levado a tomar em cada bloco.

1.1 Convenções de marcação visual

Quatro tipos de marcação aparecem ao longo do documento. Eles são intencionais e seguem padrão de cor para que o desenvolvedor identifique de imediato o que cada bloco exige na implementação.

1.1.1 Cabeçalho de página

Toda página começa com uma faixa azul escura contendo a URL relativa (ex: /servicos/pentest-web). Logo abaixo aparece o título da página e a URL completa clicável apontando para o domínio firstsecurity.com.br. Esse cabeçalho funciona como separador e como identificador rápido durante a implementação.

1.1.2 Botões de CTA

Sempre que houver um botão de chamada para ação, ele aparece em destaque com fundo verde claro e borda verde escura, com o rótulo entre colchetes [BOTÃO CTA] indicando se é primário, secundário, hero, meio ou final. O texto exato do botão vem em negrito, seguido do destino interno (URL relativa). Quando dois botões aparecem lado a lado, o bloco mostra "[DOIS BOTÕES CTA lado a lado]" e detalha o primário e o secundário em linhas separadas.

1.1.3 Formulários

Onde houver formulário, o bloco aparece com fundo roxo claro e borda roxa, marcado como [FORMULÁRIO] com o nome funcional do formulário. Logo abaixo, em lista, aparecem os campos exigidos e o texto do botão de envio. O bloco também indica o que acontece após o envio (página de obrigado, sequência de email, encaminhamento a CRM) sempre que essa informação for relevante.

1.1.4 Blocos sem CTA e sem formulário

Quando um bloco é puramente informativo e não conduz a nenhuma ação, ele aparece com fundo cinza claro e a marcação [SEM CTA / SEM FORMULÁRIO]. Isso impede que o desenvolvedor adicione botões por inércia em todo lugar; o silêncio também é decisão de design.

1.1.5 Linkagens internas

Toda menção a outra página do site vira hyperlink real no documento, em azul sublinhado. Exemplo prático: quando o texto fala em [pentest web](https://firstsecurity.com.br/servicos/pentest-web), isso já vira link clicável apontando para firstsecurity.com.br/servicos/pentest-web. O desenvolvedor pode passar o mouse sobre qualquer trecho e confirmar a URL de destino. Para o copywriter que for ajustar, o link continua editável como qualquer hyperlink do Word.

1.1.6 Notas editoriais

Eventualmente, um bloco amarelo claro com a marcação [NOTA EDITORIAL] aparece para sinalizar decisões de copy, alternativas possíveis ou observações de produção que ficariam fora do texto principal. São anotações para a equipe de implementação e não fazem parte do texto que vai ao ar.

1.2 Princípios editoriais aplicados em todos os textos

- **Português brasileiro impecável:** acentuação completa, til, cedilha, concordâncias verbais e nominais. Revisão obrigatória antes de cada publicação.
- **Sem travessões:** em nenhum texto deste documento aparece o caractere travessão. Substituído por vírgula, dois pontos, parênteses ou ponto, conforme o ritmo da frase.
- **Frase de abertura curta em cada bloco:** os primeiros 15 a 25 palavras de cada H2 funcionam como resumo citável (formato GEO), pensados para serem extraídos por AI Overview, Perplexity e ChatGPT.
- **Entidade nomeada nos blocos-chave:** em vez de "ela é capaz de", o texto diz "a First Security é capaz de". Em vez de "esse modelo funciona", o texto diz "o modelo PTaaS funciona". Pronomes vagos são eliminados.
- **CTAs com verbo no infinitivo:** "Solicitar orçamento", "Falar com especialista", "Agendar conversa", "Baixar modelo". Evita-se "clique aqui" em qualquer lugar.
- **Linguagem direta,** sem jargão desnecessário no topo e com profundidade técnica nos blocos finais, onde quem chega já está qualificado.
- **Sem exageros vazios:** nada de "líder absoluta", "a número um do Brasil". A autoridade aparece via certificações, equipe nomeada, cases e metodologia transparente.
- **"Red Team" e "Blue Team" sempre qualificados:** no copy, esses termos vêm acompanhados de "em cibersegurança" ou "defensivo" para evitar associação com Pokémon, Halo, suplementos ou Team Fortress.
- **Tom de voz:** sério, técnico, confiante, mas acessível. Nada de marketês. A pessoa do outro lado é um CISO, um diretor de TI, um gestor de compliance ou um head de engenharia, e ela percebe excesso de marketing em três frases.

1.3 Estrutura de cada página neste documento

Cada página segue um padrão estável que facilita tanto a implementação quanto a manutenção editorial. A ordem é: cabeçalho com URL e título, hero (frase forte + parágrafo de apoio + CTAs), bloco a bloco do corpo da página (cada um com seu H2, parágrafos e indicação de ação), perguntas frequentes (quando aplicável) e CTA de fechamento. Sempre que houver linkagem para outra página, o link aparece inline como hyperlink real.

1.4 Como usar este documento na implementação

1. Abra a Parte que corresponde ao silo da página em construção.
2. Localize a página pelo cabeçalho azul com URL.
3. Copie o texto bloco a bloco para o CMS (ou para o componente Astro correspondente).
4. Configure os botões com o texto e a URL exata indicada em cada bloco CTA.
5. Implemente os formulários com os campos listados e o texto do botão de envio. Configure a integração com CRM e o opt-in LGPD.
6. Verifique linkagens internas: cada hyperlink azul no documento deve virar um link funcional na página.
7. Para perguntas frequentes, marque cada par P/R com schema FAQPage no JSON-LD.
8. Revise a página em pré-produção contra esta documentação antes de publicar.

Este documento é o que vai ao ar. Se alguma palavra precisar mudar (decisão jurídica, decisão comercial, decisão editorial), a mudança nasce aqui antes de chegar no site.

Parte 2. Home institucional (/)

A home é a página com maior responsabilidade do site. Ela carrega o primeiro toque com leads vindos de busca direta pela marca, anúncios pagos, indicação ou tráfego social. Cada bloco aqui foi pensado para resolver uma dúvida diferente do visitante no menor tempo possível, sem encher de informação genérica. Os textos abaixo já estão prontos para ir ao ar.

PÁGINA • /

Home institucional

URL completa: <https://firstsecurity.com.br/>

HERO (topo da página, primeira dobra)

H1 (grande, dominante):

Cibersegurança ofensiva que sustenta decisões de risco

Subtítulo (parágrafo de apoio, abaixo do H1):

A First Security conduz pentests profissionais, operações de Red Team e ciclos integrados de Purple Team para empresas brasileiras que precisam comprovar segurança diante de clientes, reguladores e do próprio conselho. Equipe certificada, metodologia transparente, relatório aceito por auditores. Sem teatro de segurança, sem ferramenta vendida no lugar de serviço.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

Linha de prova social imediata (abaixo dos botões, fonte menor):

Atendemos fintechs, bancos, SaaS, varejo, indústria, governo e healthtechs em todo o Brasil. Equipe com OSCP, OSWE, OSEP, CRT0 e CISSP.

[SEM CTA / SEM FORMULÁRIO] No hero, abaixo dos botões, apenas a linha de prova social. Nenhum bloco extra antes da próxima seção.

BLOCO 2 — Serviços em destaque (grid de 6 cards)

H2:

Como podemos proteger sua operação

Seis frentes de trabalho concentram a entrega da First Security. Cada card abre uma página dedicada com escopo, entregáveis e como começar.

Card 1:

Título: Pentest profissional **Texto:** Aplicações web, APIs, mobile, infraestrutura, cloud e Active Directory testados por especialistas com validação manual e prova de impacto. **Link do card:**

[Conhecer pentest →](#)

Card 2:

Título: PTaaS, pentest contínuo **Texto:** Modelo recorrente em plataforma, com retestes ilimitados e integração ao seu pipeline de desenvolvimento. Ideal para SaaS, cloud e APIs em evolução. **Link do card:** [Conhecer PTaaS →](#)

Card 3:

Título: Red Team em cibersegurança **Texto:** Simulação de adversário real para medir profundidade de comprometimento e capacidade defensiva do seu SOC. Cobertura ampla por tática MITRE ATT&CK. **Link do card:** [Conhecer Red Team →](#)

Card 4:

Título: Purple Team **Texto:** Ciclo integrado entre ataque e defesa para evoluir a maturidade do seu time defensivo a cada exercício. Diferencial real, não slogan. **Link do card:** [Conhecer Purple Team →](#)

Card 5:

Título: AI Red Teaming **Texto:** Testes em LLMs, agentes e fluxos críticos baseados em IA: prompt injection, jailbreaks, vazamento de dados, riscos OWASP Top 10 for LLM. **Link do card:** [Conhecer AI Red Teaming →](#)

Card 6:

Título: Engenharia social **Texto:** Campanhas de phishing, vishing e ataques físicos autorizados para mapear o vetor humano. Resultado mensurável e com recomendações práticas. **Link do card:** [Conhecer engenharia social →](#)

[BOTÃO CTA secundário (centralizado abaixo do grid)] **Ver todos os serviços** → </servicos>

BLOCO 3 — Compliance regulatório (faixa horizontal com logos)

H2:

Suas obrigações regulatórias atendidas com profundidade

A First Security entrega relatórios prontos para auditoria nas principais normas que envolvem segurança da informação no Brasil e no mundo. A escolha da metodologia, dos entregáveis e da janela de execução é feita já considerando o que cada norma exige.

Faixa com seis chips clicáveis:

[LGPD](#) · [PCI DSS](#) · [ISO 27001](#) · [BACEN 4.893](#) · [SOC 2](#) · [NIST CSF](#)

[BOTÃO CTA secundário] **Ver todas as normas atendidas** → </compliance>

BLOCO 4 — Por que First Security (quatro pilares em grid)

H2:

Por que empresas escolhem a First Security

A primeira escolha de fornecedor em cibersegurança é uma decisão de risco. Quatro pontos diferenciam a First Security das alternativas disponíveis no mercado brasileiro.

Equipe certificada e identificável

Os profissionais que assinam os relatórios têm nome, perfil público e certificações verificáveis. OSCP, OSWE, OSEP, CRT0, CISSP. Não há subcontratação opaca. O líder técnico do projeto é o mesmo que entra na reunião de fechamento.

Ciclo completo: ataque, defesa e integração

A First Security trabalha o ciclo todo. Faz pentest, executa Red Team e integra com o time defensivo via Purple Team. Isso significa que cada vulnerabilidade encontrada vira oportunidade de melhoria operacional, não só item de relatório.

Metodologia transparente

Trabalhamos com PTES, OWASP WSTG e MASTG, NIST SP 800-115, MITRE ATT&CK e OSSTMM. Cada etapa do projeto é documentada e reproduzível. Você pode consultar nossa [metodologia completa](#) antes de assinar contrato.

Relatório que passa em auditoria

Nossos relatórios são lidos e aceitos por auditores QSA (PCI DSS), pelo BACEN, por auditores ISO 27001 e por compradores em diligência de SOC 2. Você pode [baixar um modelo anonimizado](#) antes mesmo de pedir orçamento.

[SEM CTA / SEM FORMULÁRIO] Os quatro pilares são informacionais. O CTA vem no próximo bloco.

BLOCO 5 — Setores atendidos (carrossel ou grid de cards)

H2:

Atendemos quem mais precisa de segurança comprovada

A First Security trabalha com empresas reguladas e com alta exposição. A abordagem do projeto muda quando o setor exige. Cada card abre uma página dedicada com riscos típicos, regulação aplicável e cases anonimizados.

Cards (oito setores em destaque):

- [Fintechs](#) • BACEN, PCI DSS, LGPD, PIX e open finance
- [Bancos](#) • Core banking, Active Directory, internet banking
- [SaaS B2B](#) • SOC 2, ISO 27001, multi-tenant, APIs
- [E-commerce](#) • PCI DSS, checkout, sazonalidade e fraude
- [Healthtech](#) • LGPD, HIPAA, prontuário eletrônico, telemedicina
- [Governo](#) • Lei 14.133, TCU, CGU, ANPD
- [Indústria 4.0](#) • OT, IT, IEC 62443, continuidade operacional
- [Marketplace](#) • Antifraude, abuso de seller, APIs

[BOTÃO CTA secundário] [Ver todos os setores atendidos](#) → [/segmentos](#)

BLOCO 6 — Atendimento no Brasil (mapa interativo)

H2:

Atendimento em todo o Brasil, presencial nas praças principais

A First Security trabalha remotamente em qualquer cidade do país. Em São Paulo, Rio de Janeiro, Belo Horizonte, Brasília, Porto Alegre, Curitiba, Florianópolis, Recife, Fortaleza, Salvador e Goiânia oferecemos atendimento presencial sempre que o projeto exigir reunião física, validação de controle físico ou trabalho em sala segura.

Mapa do Brasil com marcadores clicáveis:

- [Pentest em São Paulo](#)
- [Pentest no Rio de Janeiro](#)
- [Pentest em Belo Horizonte e Minas Gerais](#)
- [Pentest em Brasília e Distrito Federal](#)
- [Pentest em Porto Alegre e Rio Grande do Sul](#)
- [Pentest em Goiânia e Goiás](#)
- [Ver todas as praças atendidas](#)

[SEM CTA / SEM FORMULÁRIO] Bloco com mapa e lista de links. CTA vem no fechamento.

BLOCO 7 — Casos reais (carrossel de três cases anonimizados)

H2:

O que entregamos na prática

Cases reais e anonimizados mostram com mais clareza o que uma proposta consegue prometer. Os três projetos abaixo representam frentes diferentes do nosso trabalho, em setores diferentes, com escopos diferentes. Todos foram aprovados por escrito pelo cliente antes da publicação.

Card de case 1:

Setor: Fintech de crédito · **Serviço:** Pentest contínuo (PTaaS) + API security · **Resultado:** Sete vulnerabilidades críticas em BOLA e BFLA identificadas antes do go-live público. Auditoria PCI DSS aprovada no primeiro ciclo. [Ler o caso completo →](#)

Card de case 2:

Setor: SaaS B2B internacional · **Serviço:** Red Team + AI Red Teaming · **Resultado:** Comprometimento completo do ambiente AWS em 11 dias por meio de prompt injection em integração com LLM. Plano de remediação fechado em três semanas. [Ler o caso completo →](#)

Card de case 3:

Setor: Healthtech · **Serviço:** Pentest mobile + cloud + LGPD · **Resultado:** Mapeamento completo de tratamento de dado sensível em três semanas. Adequação ANPD apoiada com relatório técnico para o encarregado. [Ler o caso completo →](#)

[BOTÃO CTA secundário] [Ver todos os casos → /casos-de-uso](#)

BLOCO 8 — Lead magnet (faixa horizontal com formulário)

H2:

Veja como é um relatório de pentest de verdade

Antes de assinar contrato, conheça o entregável. A First Security disponibiliza um modelo anonimizado de relatório executivo e técnico, exatamente como ele chega na mão do nosso cliente final. Sumário executivo para diretoria, achados ordenados por criticidade, evidências reproduzíveis e plano de remediação por prioridade.

[FORMULÁRIO] Lead magnet: modelo de relatório

Campos:

- Nome completo (texto, obrigatório)
- Email corporativo (email, obrigatório, validação de domínio livre)
- Empresa (texto, obrigatório)
- Cargo (texto, obrigatório)
- Telefone (texto opcional, máscara brasileira)
- Aceite LGPD (checkbox obrigatório com link para /legal/politica-de-privacidade)

Botão de envio: "Baixar modelo gratuito"

NOTA EDITORIAL: Após o envio, o usuário é redirecionado para /relatorios/modelo-de-relatorio/obrigado, recebe email automático com o PDF e entra em sequência de nutrição de quatro emails ao longo de duas semanas. Integração com CRM (qualificação por cargo e setor da empresa).

BLOCO 9 — Equipe certificada (faixa institucional)

H2:

Equipe com nome, rosto e certificação verificável

Quem assina um pentest é responsável pelo trabalho. A First Security é construída em torno de pessoas reais com trajetória pública. Veja quem lidera cada frente, quais certificações a equipe carrega e quais pesquisas próprias publicamos.

Visual sugerido:

Faixa horizontal com seis fotos circulares dos profissionais sêniores (cinza com nome embaixo, sem maquiagem de marketing). Abaixo, três botões discretos.

- [Conhecer a equipe](#)
- [Certificações da equipe](#)
- [Metodologia que adotamos](#)

[SEM CTA / SEM FORMULÁRIO] Bloco institucional. Os links acima funcionam como CTAs leves; o CTA pesado fica no próximo bloco.

BLOCO 10 — Conhecimento (três últimos posts do blog)

H2:

Conteúdo técnico para tomar decisões com base sólida

O blog da First Security é mantido por quem está em campo. Cada texto sai com nome de autor, data de publicação e revisor. Não publicamos texto genérico de IA generalista, e isso faz diferença.

Bloco dinâmico:

Mostra os três posts mais recentes do blog (componente dinâmico via Content Collections do Astro). Cada card tem categoria, título, resumo de duas linhas e autor.

[BOTÃO CTA secundário] Ver todo o blog → </blog>

BLOCO 11 — CTA final (faixa de fechamento)

H2:

Pronto para um diagnóstico sem compromisso?

Em uma conversa de 30 minutos, mapeamos seu cenário, identificamos o serviço mais adequado e enviamos uma proposta com escopo e preço em até 48 horas úteis. Sem formulário longo, sem aviso de qualificação automática, sem promessa que não cabe.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Linha discreta abaixo dos botões:

Atendemos em todo o Brasil. Equipe disponível em horário comercial. Resposta em até 24 horas úteis.

Parte 3. Páginas centrais e atalhos de conversão

Essas páginas concentram a parte mais transacional do site. Quem chega aqui já decidiu agir, falta apenas a fricção de envio. O texto é curto, direto e funcional. O objetivo é remover dúvida e converter sem teatro.

PÁGINA • /contato

Contato

URL completa: <https://firstsecurity.com.br/contato>

HERO

H1:

Fale com a First Security

Estamos prontos para conversar sobre o seu cenário. Esta página reúne todos os canais de contato: comercial, técnico, jurídico, imprensa e segurança. Escolha o canal certo e a resposta chega rápido.

[SEM CTA / SEM FORMULÁRIO] Hero sem botão. Os atalhos por canal vêm logo abaixo.

BLOCO 2 — Atalhos por canal (grid de quatro cards clicáveis)

H2:

Escolha o canal certo

Cada canal abaixo tem uma equipe dedicada. Mensagens enviadas no canal certo são respondidas em até 24 horas úteis.

Card 1, comercial:

Título: Comercial e proposta de pentest • Para solicitar orçamento, conhecer serviços ou agendar uma conversa. [Solicitar orçamento →](#)

Card 2, técnico:

Título: Suporte técnico em projeto em andamento • Para clientes ativos que precisam falar com o pentester responsável. **Email:** tecnico@firstsecurity.com.br

Card 3, jurídico e LGPD:

Título: Jurídico, LGPD e encarregado de proteção de dados • Para exercer direitos do titular, dúvidas sobre privacidade ou solicitações jurídicas. **Email:** dpo@firstsecurity.com.br

Card 4, segurança:

Título: Reportar vulnerabilidade no site da First Security • Pesquisadores e clientes podem reportar vulnerabilidades aqui. Política de divulgação responsável. **Email:** security@firstsecurity.com.br
[Política de Divulgação Responsável →](#)

BLOCO 3 — Formulário geral de contato

H2:

Ou nos envie uma mensagem

Se preferir, use o formulário abaixo. Encaminhamos sua mensagem para a área certa internamente e respondemos em até 24 horas úteis.

[FORMULÁRIO] Contato geral

Campos:

- Nome completo (texto, obrigatório)
- Email corporativo (email, obrigatório)
- Empresa (texto, opcional)
- Assunto (seleção: Comercial, Técnico, Jurídico/LGPD, Segurança, Outro)
- Mensagem (textarea, obrigatório, 800 caracteres)
- Aceite LGPD (checkbox obrigatório, link para /legal/política-de-privacidade)

Botão de envio: "Enviar mensagem"

NOTA EDITORIAL: Após envio: redirecionamento para /contato/obrigado com confirmação visual e tempo estimado de retorno. Notificação por email para a caixa correspondente ao assunto selecionado. Integração com CRM para rastreio.

BLOCO 4 — Endereço e horário

H2:

Onde estamos

A First Security tem sede operacional em Goiânia (Goiás) e atende clientes em todo o Brasil presencial e remotamente. Para reuniões presenciais nas demais praças (SP, RJ, MG, DF, RS, PR, SC, PE, CE, BA), agendamos com antecedência mínima de cinco dias úteis.

Bloco com endereço (placeholder, ajustar com endereço real):

- Sede operacional: Goiânia, Goiás
- Horário de atendimento: segunda a sexta, das 9h às 18h (horário de Brasília)
- Atendimento emergencial para contratos ativos: 24/7 via canal dedicado

[SEM CTA / SEM FORMULÁRIO] Bloco institucional informacional.

Solicitar orçamento

URL completa: <https://firstsecurity.com.br/orcamento>

HERO

H1:

Solicite um orçamento de pentest profissional

Em até 48 horas úteis, sua proposta sai com escopo definido, prazo realista e preço fechado. Sem qualificação automática frustrante, sem promessas vagas. O orçamento é elaborado por um pentester sênior da equipe, não por software.

[SEM CTA / SEM FORMULÁRIO] Hero sem botão. Formulário começa logo abaixo.

BLOCO 2 — Como funciona (três passos)

H2:

Como funciona, passo a passo

A solicitação de orçamento na First Security segue um fluxo curto e previsível.

Três cards em linha:

- 1. Envio do briefing** • Você preenche o formulário abaixo com informações básicas sobre o ambiente e o objetivo do trabalho.
- 2. Reunião de descoberta** • Em até 24 horas úteis, um especialista da First Security entra em contato para uma conversa de 30 a 45 minutos. Sem cobrança, sem compromisso.
- 3. Proposta detalhada** • Em até 48 horas úteis após a reunião, você recebe a proposta por escrito com escopo, prazo, preço e termos contratuais.

[SEM CTA / SEM FORMULÁRIO] Passos numerados. O formulário vem logo a seguir.

BLOCO 3 — Formulário principal

H2:

Conte sobre o seu projeto

Quanto mais informação você puder dar, mais preciso fica o orçamento. Se algum campo não fizer sentido, deixe em branco e tratamos na reunião.

[FORMULÁRIO] Solicitação de orçamento

Campos:

- Nome completo (obrigatório)
- Email corporativo (obrigatório, validação de domínio livre)
- Cargo (obrigatório)
- Empresa (obrigatório)
- CNPJ (opcional, formato BR)

- Setor da empresa (seleção: Fintech, Banco, SaaS, E-commerce, Healthtech, Indústria, Governo, Outro)
- Porte da empresa (seleção por número de funcionários: até 50, 50-200, 200-1000, 1000-5000, mais de 5000)
- Telefone (opcional, máscara brasileira)
- Tipo de teste desejado (multi-seleção: Web, Mobile, API, Cloud, Infraestrutura, Active Directory, Red Team, PTaaS contínuo, AI Red Teaming, Engenharia social, Não sei ainda)
- Motivação principal (seleção: Compliance regulatório, Exigência de cliente, Decisão interna, Pós-incidente, Outro)
- Norma envolvida, se houver (multi-seleção: LGPD, PCI DSS, ISO 27001, BACEN, SOC 2, NIST CSF, HIPAA, Nenhuma)
- Janela desejada de execução (seleção: Imediato, 30 dias, 60 dias, 90 dias ou mais, Sem urgência)
- Detalhamento adicional (textarea, opcional, 1500 caracteres)
- Como nos conheceu (seleção: Busca no Google, Indicação, LinkedIn, Evento, Outro)
- Aceite LGPD (checkbox obrigatório com link para /legal/politica-de-privacidade)

Botão de envio: **"Solicitar orçamento"**

NOTA EDITORIAL: Após envio: redirecionamento para /orcamento/obrigado com mensagem de confirmação personalizada e prazo de retorno. Email automático com cópia do briefing. Atribuição automática para um pentester sênior do CRM conforme setor e norma. SLA interno: primeira resposta em até 24 horas úteis.

BLOCO 4 — Garantias

H2:

O que garantimos no processo de orçamento

- Resposta humana, não automatizada, em até 24 horas úteis.
- Reunião de descoberta sem custo e sem compromisso.
- Proposta com escopo, prazo e preço fixados por escrito.
- NDA prévio assinado antes de qualquer detalhe técnico ser compartilhado.
- Confidencialidade absoluta sobre as informações trocadas durante a fase comercial.

Conheça em detalhes a nossa [Política de Confidencialidade](#) e a [Política de Privacidade](#).

[SEM CTA / SEM FORMULÁRIO] Bloco institucional sem CTA. Reforço de confiança após o formulário.

Agendar uma conversa

URL completa: <https://firstsecurity.com.br/agendar-conversa>

HERO

H1:

Agende uma conversa de 30 minutos com um especialista

Ainda não chegou na hora do orçamento? Tudo bem. Em meia hora, conversamos sobre o cenário da sua empresa e indicamos o caminho mais sensato. Pode ser pentest, pode ser Red Team, pode ser Purple Team. Pode até ser que você ainda não precise contratar nada agora, e a gente vai dizer.

[SEM CTA / SEM FORMULÁRIO] Hero sem botão. Calendário embutido logo abaixo.

BLOCO 2 — Calendário embutido (Cal.com ou Calendly)

H2:

Escolha o melhor horário

Selecione um dia e um horário no calendário abaixo. Ao confirmar, você recebe convite por email com link de videochamada (Google Meet) e um lembrete uma hora antes.

Componente embutido:

NOTA EDITORIAL: Integração com Cal.com (preferencial pela política LGPD) ou Calendly. Conferir alinhamento com a Política de Privacidade do site quanto à transferência de dados ao fornecedor escolhido. Janelas disponíveis: segunda a sexta, das 10h às 17h, fuso de Brasília. Slots de 30 minutos.

[SEM CTA / SEM FORMULÁRIO] O componente é o próprio CTA. Não há botão adicional.

BLOCO 3 — O que esperar da conversa

H2:

O que vamos cobrir nessa conversa

A conversa é direta. Em 30 minutos, normalmente cobrimos:

- Cenário atual: o que sua empresa já tem em termos de segurança e o que ainda falta.
- Urgência: existe pressão regulatória, exigência de cliente ou incidente recente?
- Escopo possível: o que faz sentido testar primeiro, qual a forma mais eficiente.
- Estimativa preliminar: faixa de investimento e prazo.
- Próximos passos: se você quiser seguir, formalizamos com orçamento detalhado. Se não, ficamos como referência futura.

[SEM CTA / SEM FORMULÁRIO] Bloco informativo, sem ação extra.

BLOCO 4 — Prefere começar pelo orçamento direto?

H2:

Já sabe o que precisa? Vá direto ao orçamento

Se você já tem clareza sobre o serviço, o escopo e a janela, vá direto para o formulário de orçamento. A reunião de descoberta acontece depois do envio.

[BOTÃO CTA secundário] Solicitar orçamento agora → </orcamento>

Quem somos

URL completa: <https://firstsecurity.com.br/quem-somos>

HERO

H1:

Cibersegurança ofensiva feita por gente que entende do ofício

A First Security existe para fazer cibersegurança ofensiva séria no Brasil. Sem fast food de pentest, sem "ferramenta automatizada" vendida como serviço, sem time terceirizado escondido. Os profissionais que assinam os relatórios estão aqui, na conversa, na execução e no fechamento.

[SEM CTA / SEM FORMULÁRIO] *Hero institucional sem botão.*

BLOCO 2 — Manifesto

H2:

O que nos move

Pentest é uma decisão de risco. O cliente que contrata a First Security está depositando confiança em pessoas que vão entrar em seus sistemas, eventualmente em produção, e ter acesso a informação sensível. Isso exige uma ética profissional que não cabe em folder.

Trabalhamos com método documentado, equipe identificável, comunicação clara com o cliente em cada fase do projeto e relatórios que aguentam questionamento de auditor. Nossa promessa é simples: o que está no relatório é o que aconteceu, com prova reproduzível, e a recomendação é executável dentro do orçamento de segurança que a empresa tem.

A First Security não vende medo. A gente sabe que medo vende bem em cibersegurança, e por isso mesmo não vendemos. Vendemos clareza sobre risco, profundidade técnica e capacidade de transformar achado em decisão.

[SEM CTA / SEM FORMULÁRIO] *Bloco institucional. Apenas texto.*

BLOCO 3 — Acesso rápido às páginas filhas (cards)

H2:

Conheça a First Security em profundidade

Esta página é um resumo. Para entender em detalhe o que está por trás do nosso trabalho, vá a cada uma das páginas dedicadas.

Quatro cards em grid:

- [Equipe](#) • Quem são as pessoas da First Security, com bio, certificações e contato profissional.
- [Metodologia](#) • Como conduzimos cada projeto, fase a fase, com base em PTES, OWASP, NIST e MITRE ATT&CK.
- [Certificações](#) • As credenciais que o time carrega: OSCP, OSWE, OSEP, CRT0, CISSP e mais.

- [Diferenciais](#) • Por que escolher a First Security em vez de fornecedores genéricos.

BLOCO 4 — Em números (faixa visual)

H2:

A First Security em números

NOTA EDITORIAL: Os números abaixo devem ser preenchidos pela equipe comercial com dados reais e atualizados trimestralmente. Os valores listados são placeholders.

Faixa horizontal com quatro estatísticas:

- Mais de X projetos concluídos
- Mais de Y vulnerabilidades críticas reportadas e remediadas
- Z setores atendidos no Brasil
- W CVEs publicadas pela equipe de pesquisa

[SEM CTA / SEM FORMULÁRIO] Bloco visual sem ação. Reforço de prova.

BLOCO 5 — Equipe em destaque (cinco profissionais)

H2:

Quem lidera as frentes técnicas

Apresentamos os profissionais que conduzem cada frente de trabalho da First Security. Cada um deles tem página individual com bio, certificações e publicações.

NOTA EDITORIAL: Componente: cinco cards verticais com foto profissional, nome, cargo, certificações principais (até quatro siglas) e link para a página individual. Os nomes abaixo são placeholders.

- **Nome do Líder Técnico** • Co-fundador e Diretor Técnico • OSCP, OSEP, OSCE3, CRT0 • [Conhecer →](#)
- **Nome do Head Red Team** • Head de Red Team • CRT0, CRTL, OSEP, CISSP • [Conhecer →](#)
- **Nome do Head Web** • Head de Pentest Web e API • OSWE, BSCP, OSCP • [Conhecer →](#)
- **Nome do Head Cloud** • Head de Cloud Security • AWS Security, Azure Security, OSCP • [Conhecer →](#)
- **Nome do Head Pesquisa** • Head de Pesquisa • OSED, OSCE3 • [Conhecer →](#)

[BOTÃO CTA secundário] Ver equipe completa → </quem-somos/equipe>

BLOCO 6 — CTA final

H2:

Quer entender se podemos ajudar?

Conheça nossas pessoas, nosso método e a forma como entregamos. Se fizer sentido, conversamos.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar uma conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Parte 4. Hub e pilares de Pentest

O hub /pentest e as duas páginas pilares /pentest/o-que-e e /pentest/tipos sustentam a autoridade tópica do domínio para a entidade central do negócio. São páginas pesadas em conteúdo, com hierarquia clara, perguntas frequentes desenvolvidas e linkagem ampla para serviços e comparativos. O texto abaixo está pronto para ir ao ar.

PÁGINA • /pentest

Pentest, hub principal

URL completa: <https://firstsecurity.com.br/pentest>

HERO

H1:

Pentest profissional para empresas brasileiras

Pentest é o exercício autorizado de exploração de vulnerabilidades em sistemas, redes, aplicações e processos para identificar e validar falhas reais antes que um atacante as explore. A First Security entrega pentest com equipe certificada, metodologia documentada (PTES, OWASP, NIST, MITRE ATT&CK) e relatórios aceitos por auditores QSA, BACEN, ISO 27001 e SOC 2.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — O que é pentest (resposta direta)

H2:

O que é um pentest, em uma linha

Pentest, abreviação de "penetration test" ou teste de intrusão, é uma simulação controlada de ataque contra um alvo definido, executada por especialistas autorizados, com o objetivo de identificar e validar vulnerabilidades exploráveis e medir o impacto real que elas teriam nas mãos de um atacante.

Diferente de um scan automatizado, o pentest envolve julgamento humano, exploração manual, encadeamento de falhas e validação de impacto. Diferente de uma auditoria, ele não verifica conformidade com normas, e sim a capacidade técnica do alvo de resistir a um ataque real.

Para aprofundar o conceito, leia o pilar dedicado [o que é pentest](#) ou veja os [tipos de pentest](#) por modalidade e escopo.

[SEM CTA / SEM FORMULÁRIO] Bloco conceitual sem ação. Os links inline cumprem a função de navegação.

BLOCO 3 — Para que serve um pentest

H2:

Para que serve um pentest, na prática

Cinco frentes justificam o investimento em pentest em uma empresa brasileira média a grande.

Comprovar segurança para clientes corporativos

Quem vende para grandes empresas e governo passa por questionários de segurança, due diligence e auditoria de fornecedor. Apresentar relatório de pentest recente, feito por consultoria reconhecida, encurta o ciclo de venda em semanas.

Atender exigência regulatória

Normas brasileiras e internacionais exigem ou pressupõem teste de intrusão recorrente. [LGPD](#), [Resolução BACEN 4.893](#), [PCI DSS](#), [ISO 27001](#) e [SOC 2](#) estão entre as principais.

Reduzir risco antes do lançamento

Aplicação nova, integração crítica, migração para cloud, lançamento de feature exposta a parceiros: todas são janelas em que uma falha não detectada custa caro depois. Pentest na fase de pré-produção é mais barato que retrabalho pós-incidente.

Validar a maturidade do time defensivo

Pentest e [Red Team em cibersegurança](#) não só encontram falhas, eles também colocam à prova o SOC e os controles de detecção. Quando integrado em ciclo [Purple Team](#), o aprendizado vira melhoria operacional permanente.

Apoiar decisão de investimento em segurança

CISOs e CFOs precisam de evidência concreta para defender orçamento de segurança. Relatórios de pentest com impacto financeiro associado dão o que o conselho pede: linguagem de risco, não jargão técnico.

[SEM CTA / SEM FORMULÁRIO] Bloco informacional com cinco subseções. Linkagem ampla para serviços e compliance.

BLOCO 4 — Quando contratar um pentest (gatilhos)

H2:

Quando contratar um pentest

Os gatilhos abaixo costumam indicar que chegou a hora.

- Você vai lançar uma aplicação nova, especialmente exposta à internet ou a parceiros.
- Sua empresa entrou em ciclo de auditoria (LGPD, BACEN, PCI DSS, ISO 27001, SOC 2).
- Houve incidente recente, mesmo que pequeno, ou tentativa identificada pelo SOC.
- Você está em diligência para uma rodada de investimento, M&A ou venda da empresa.
- O time de produto ou cloud cresceu rápido e a superfície de exposição passou a ser desconhecida.
- A área comercial está perdendo deals por falta de evidência de segurança.

- Seu último pentest tem mais de 12 meses e o ambiente mudou bastante desde então.

[SEM CTA / SEM FORMULÁRIO] *Lista de gatilhos. Sem CTA neste bloco.*

BLOCO 5 — Tipos de pentest oferecidos pela First Security (grid)

H2:

Tipos de pentest que oferecemos

Cada modalidade abaixo tem página dedicada com escopo, entregáveis, duração típica e cases. Clique no card que mais se aproxima do seu cenário.

Grid de cards:

- [Pentest Web](#) • Aplicações web, portais, painéis administrativos, CMS.
- [Pentest Mobile](#) • Apps iOS e Android, com cobertura OWASP MASVS.
- [Pentest API](#) • REST, GraphQL, gRPC, com OWASP API Top 10.
- [Pentest Cloud](#) • AWS, Azure, GCP, com revisão de configuração e exploração.
- [Pentest de Infraestrutura](#) • Rede interna, perímetro externo, segmentação.
- [Pentest Active Directory](#) • AD, Azure AD/Entra ID, Kerberoasting, BloodHound.
- [Pentest IoT](#) • Dispositivos conectados, firmware, comunicação rádio.
- [Pentest OT/SCADA](#) • Ambientes industriais, IEC 62443.
- [Pentest com IA](#) • Aplicações que usam LLM, agentes, ML em produção.
- [Pentest as a Service \(PTaaS\)](#) • Modelo contínuo, retestes ilimitados, integração CI/CD.

[BOTÃO CTA secundário] **Ver todos os serviços** → </servicos>

BLOCO 6 — Modalidades por nível de conhecimento

H2:

Black box, white box e grey box: qual escolher

Além do escopo (web, mobile, cloud, AD), o pentest se classifica pela quantidade de informação que o testador recebe antes de começar.

Black box: o testador começa sem informação nenhuma, como um atacante externo. Resultado mais realista, prazo maior, custo proporcional ao tempo improdutivo de reconhecimento.

White box: o testador recebe tudo (credenciais, documentação, código quando aplicável). Resultado de maior profundidade no mesmo tempo, custo menor. Ideal para escopos críticos com janela curta.

Grey box: o meio termo. O testador recebe informação parcial, simulando um usuário comum, um parceiro ou um funcionário sem privilégios. Boa relação entre realismo e profundidade.

Aprofunde a comparação na página [Black Box vs White Box vs Grey Box](#).

[SEM CTA / SEM FORMULÁRIO] *Bloco explicativo. Link inline para comparativo.*

BLOCO 7 — Como funciona um projeto de pentest na First Security

H2:

Como conduzimos um pentest, do começo ao fim

O processo abaixo se aplica à maioria dos projetos. Variações por porte ou criticidade são acordadas na fase de pré-engajement.

Pré-engajement

Reunião de descoberta, NDA assinado, definição formal de escopo, autorização por escrito de todos os ativos a serem testados, definição de janela de execução, ponto focal técnico, regras de engajamento e canal de emergência.

Reconhecimento

Coleta passiva e ativa de informações sobre o alvo. Mapeamento de superfície de exposição. Identificação de tecnologias, versões, integrações e pontos de entrada.

Análise e exploração

Identificação de vulnerabilidades por meio de testes manuais e auxílio de ferramentas. Cada vulnerabilidade encontrada é validada com prova de impacto reproduzível. Encadeamento de falhas para demonstrar caminhos de comprometimento reais.

Pós-exploração

Avaliação do impacto efetivo: o que um atacante conseguiria acessar, modificar ou exfiltrar a partir do ponto comprometido. Movimento lateral controlado quando autorizado. Sempre com registro detalhado.

Relato

Entrega do relatório técnico e executivo. O técnico documenta cada achado com descrição, evidência, severidade (CVSS), impacto de negócio e recomendação de remediação. O executivo traz a visão para diretoria e conselho, com priorização e estimativa de esforço.

Reteste

Após o cliente concluir a remediação, executamos reteste para confirmar a correção e fechamos o ciclo. Reteste incluído no escopo do projeto.

A descrição completa de cada fase está na [página de metodologia](#).

[SEM CTA / SEM FORMULÁRIO] Bloco explicativo de processo. Link inline para metodologia.

BLOCO 8 — Perguntas frequentes

H2:

Perguntas frequentes sobre pentest

Quanto custa um pentest?

O preço depende de quatro variáveis: escopo (número e complexidade de alvos), modalidade (black, white, grey), modelo comercial (projeto ou recorrente PTaaS) e janela. Projetos pequenos de

aplicação web ou API costumam ficar na faixa de poucas dezenas de milhares de reais. Projetos enterprise com Red Team completo podem chegar a centenas. A First Security entrega proposta com preço fechado em até 48 horas úteis após o briefing.

Quanto tempo dura um pentest?

Entre uma semana (escopo pequeno) e cerca de seis semanas (Red Team enterprise). Pentest web ou mobile típico fica entre duas e quatro semanas. PTaaS é contínuo ao longo do contrato.

Pentest é seguro para o ambiente em produção?

Sim, quando executado por equipe qualificada e com regras de engajamento bem definidas. A First Security trabalha com ponto focal técnico do cliente em tempo real durante a execução e tem canal de emergência para qualquer eventualidade. Testes destrutivos são sempre previamente acordados ou substituídos por evidência alternativa.

O pentest causa indisponibilidade?

Em regra, não. Testes de negação de serviço (DoS/DDoS) ficam fora do escopo por padrão, salvo solicitação explícita do cliente para ambiente segregado. Qualquer ação com risco operacional é validada antes de ser executada.

Qual a diferença entre pentest e análise de vulnerabilidade?

A análise de vulnerabilidade é um scan automatizado que lista falhas conhecidas. O pentest é uma exploração manual que valida quais dessas falhas são realmente exploráveis e o impacto que causariam. Os dois se complementam, mas não se substituem. Aprofunde em [Pentest vs Análise de Vulnerabilidade](#).

Pentest é a mesma coisa que Red Team?

Não. Pentest tem escopo bem delimitado e foco em encontrar o máximo de vulnerabilidades. Red Team tem escopo amplo (inclui pessoas e processos), simula adversário real com objetivo específico e mede também a capacidade do time defensivo de detectar. Detalhes em [Pentest vs Red Team](#).

Com que frequência devo fazer pentest?

O mínimo recomendado é uma vez ao ano e após qualquer mudança significativa de arquitetura. PCI DSS exige anualmente e após mudança. SaaS em release contínuo se beneficia muito mais de PTaaS, com cobertura ao longo do ano todo.

Que normas exigem pentest?

PCI DSS exige no Requisito 11.3. BACEN, LGPD, ISO 27001 e SOC 2 pressupõem pentest como evidência razoável de "medidas de segurança". Veja todas em [Pentest e compliance](#).

O relatório vem em português ou em inglês?

O padrão é português. Para clientes com auditores ou compradores estrangeiros (SOC 2, due diligence internacional), entregamos em inglês ou bilíngue sem custo adicional. Especificar no briefing.

Vocês assinam NDA?

Sempre. NDA é assinado antes de qualquer troca de detalhes técnicos, ainda na fase comercial. Aceitamos NDA do cliente ou usamos o nosso padrão.

H2:

Pronto para começar?

Cada projeto começa com uma conversa simples. Diga o que você precisa e a gente diz o que faz sentido.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

O que é Pentest

URL completa: <https://firstsecurity.com.br/pentest/o-que-e>

HERO

H1:

O que é Pentest: definição, propósito e como funciona

Pentest, ou teste de intrusão, é uma simulação autorizada de ataque cibernético executada por especialistas com o objetivo de identificar e validar vulnerabilidades reais em sistemas, aplicações, redes ou processos, antes que um atacante mal-intencionado o faça.

Este guia explica em profundidade o que é pentest, como ele funciona, quais são os tipos e quando faz sentido contratar. É a página de referência da First Security para o conceito.

[SEM CTA / SEM FORMULÁRIO] Hero com definição autocontida (formato GEO citável). Sem CTA aqui.

BLOCO 2 — Definição completa

H2:

Definição completa de pentest

Pentest é o termo abreviado de "penetration test", também chamado em português de teste de intrusão ou teste de invasão. É a prática de simular ataques cibernéticos contra alvos definidos, com autorização formal, conduzidos por profissionais qualificados, para identificar vulnerabilidades exploráveis e medir o impacto que elas teriam nas mãos de um atacante real.

Três elementos definem o pentest e o diferenciam de outras práticas:

Autorização formal. Sem autorização por escrito, qualquer tentativa de exploração é crime previsto na legislação brasileira. Pentest profissional sempre começa com contrato, NDA e termo de autorização.

Profissional qualificado. Pentest exige conhecimento profundo de redes, sistemas, aplicações e técnicas de ataque. Boa parte dos profissionais carrega certificações reconhecidas (OSCP, OSWE, OSEP) e tem experiência prática verificável.

Validação de impacto. Não basta listar vulnerabilidades. O pentest valida cada uma com prova de conceito reproduzível e mede o impacto real (acesso obtido, dados expostos, persistência possível).

BLOCO 3 — Origem do termo

H2:

De onde vem o termo "pentest"

A prática de testar a segurança de sistemas por meio de tentativa de invasão controlada existe formalmente desde os anos 1970, quando a Força Aérea Norte-Americana contratou pesquisadores

para testar a segurança de seus sistemas Multics. O termo "tiger team" foi cunhado nessa época, em referência a essas equipes ofensivas internas.

Na década de 1990, com a internet em expansão, surgiram as primeiras consultorias comerciais especializadas. O termo "penetration testing" se consolidou ao longo dos anos 2000, com a publicação de frameworks como o OSSTMM e o PTES, e com a entrada do PCI DSS exigindo pentest formal para empresas que processam cartões.

Hoje, pentest é prática regulatória e operacional em qualquer empresa que trate dado sensível ou tenha exposição relevante.

[SEM CTA / SEM FORMULÁRIO] Bloco histórico, contextual. Sem ação.

BLOCO 4 — Pentest vs outras práticas (tabela comparativa)

H2:

Como o pentest se diferencia de outras práticas de segurança

Muita gente confunde pentest com análise de vulnerabilidade, auditoria, bug bounty ou Red Team. Cada um atende a um propósito diferente. A tabela abaixo resume.

Tabela:

Prática	Objetivo central	Validação de impacto?	Quem executa
Pentest	Encontrar e validar vulnerabilidades exploráveis em escopo definido	Sim, manual	Pentester profissional
Análise de vulnerabilidade	Listar vulnerabilidades conhecidas via scan	Não	Scanner automatizado
Auditoria de segurança	Verificar conformidade com controles e processos	Não (verifica documentos e amostras)	Auditor
Bug bounty	Receber reports de vulnerabilidades de pesquisadores externos	Sim, mas sem garantia de cobertura	Comunidade global
Red Team	Simular adversário real para medir maturidade defensiva	Sim, com profundidade	Equipe ofensiva especializada

Veja as comparações em detalhe nas páginas dedicadas: [Pentest vs Análise de Vulnerabilidade](#), [Pentest vs Auditoria](#), [Pentest vs Bug Bounty](#) e [Pentest vs Red Team](#).

[SEM CTA / SEM FORMULÁRIO] Bloco com tabela e linkagem ampla para comparativos.

BLOCO 5 — Frameworks de referência

H2:

Frameworks reconhecidos que orientam um bom pentest

Pentest sério não é improvisado. Existem frameworks publicados e mantidos por organizações reconhecidas internacionalmente que orientam metodologia, escopo, técnicas e relatório.

PTES (Penetration Testing Execution Standard)

Padrão de execução desenvolvido por consultorias e pesquisadores que define sete fases canônicas: pré-engajamento, reconhecimento, modelagem de ameaça, análise de vulnerabilidade, exploração, pós-exploração e relato. É o esqueleto metodológico mais adotado por consultorias brasileiras sérias.

OWASP WSTG e MASTG

O Web Security Testing Guide e o Mobile Application Security Testing Guide, da OWASP, são guias detalhados de checklist técnico para pentest de aplicações web e mobile. Documentam centenas de cenários de teste, com referência para vulnerabilidades típicas.

OWASP API Security Top 10

Lista mantida pela OWASP com as 10 principais classes de vulnerabilidade em APIs (REST, GraphQL, gRPC). Inclui BOLA, BFLA, broken authentication, mass assignment, entre outras. Referência obrigatória em pentest de API.

NIST SP 800-115

Publicação do NIST norte-americano com diretrizes para condução de testes técnicos de segurança da informação. Usada como referência em ambientes regulados.

MITRE ATT&CK

Matriz de táticas, técnicas e procedimentos usados por adversários reais. Permite mapear cada achado do pentest a uma técnica de ataque conhecida, o que enriquece o relatório e facilita a comunicação com o time defensivo.

OSSTMM

Manual aberto de metodologia de segurança operacional, com viés mais formal. Usado especialmente em pentests de infraestrutura e auditoria técnica.

A First Security adota todos esses frameworks de forma combinada. Veja como aplicamos na [página de metodologia](#).

[SEM CTA / SEM FORMULÁRIO] Bloco técnico. Link inline para metodologia.

BLOCO 6 — Tipos de pentest (resumo)

H2:

Os principais tipos de pentest

A classificação de pentest segue três eixos: modalidade (quanto conhecimento o testador tem do alvo), escopo técnico (que tipo de ativo está sendo testado) e modelo comercial (projeto único ou serviço contínuo).

Por modalidade

- **Black box:** sem informação prévia.
- **White box:** informação completa.
- **Grey box:** informação parcial.

Por escopo

- **Pentest Web:** aplicações e portais web.
- **Pentest Mobile:** apps iOS e Android.
- **Pentest API:** REST, GraphQL, gRPC.
- **Pentest Cloud:** AWS, Azure, GCP.
- **Pentest de Infraestrutura:** redes internas e perímetro externo.
- **Pentest Active Directory:** AD e identidade.
- **Pentest IoT e OT/SCADA:** dispositivos conectados e ambientes industriais.
- **Pentest com IA:** aplicações baseadas em LLM e agentes.

Por modelo comercial

- **Projeto pontual:** escopo fechado, prazo curto, entrega única.
- **PTaaS (Pentest as a Service):** contínuo, plataforma, retestes ilimitados.
- **Red Team:** simulação de adversário com objetivo, escopo amplo.

Aprofunde tudo isso no pilar dedicado [Tipos de pentest](#).

[SEM CTA / SEM FORMULÁRIO] Bloco resumo. Link inline para pilar dedicado.

BLOCO 7 — Pentest é legal no Brasil?

H2:

Pentest é legal no Brasil?

Sim, desde que executado com autorização formal e por escrito do responsável legal pelos sistemas testados. Sem essa autorização, qualquer tentativa de acesso não autorizado a sistemas alheios configura crime previsto na Lei Carolina Dieckmann (Lei 12.737/2012) e no Código Penal brasileiro.

A First Security só executa pentest após assinatura de contrato, NDA e termo de autorização que especifica nominalmente todos os ativos no escopo, a janela de execução e o ponto focal do cliente. Sem esses três documentos, nada começa.

[SEM CTA / SEM FORMULÁRIO] Bloco legal. Sem ação.

BLOCO 8 — FAQ

H2:

Perguntas frequentes sobre o que é pentest

Pentest é a mesma coisa que hacking?

Tecnicamente as técnicas são parecidas, mas o que diferencia é a autorização. Hacking sem autorização é crime. Pentest é hacking ético, autorizado, com contrato, propósito definido e regras claras.

Qual a diferença entre pentest e Red Team?

Pentest foca em encontrar o máximo de vulnerabilidades em escopo bem delimitado. Red Team simula adversário real com objetivo (acessar X, exfiltrar Y) e escopo amplo, incluindo pessoas e processos. Detalhe em [Pentest vs Red Team](#).

O pentester precisa ter alguma certificação?

Não é obrigatório por lei, mas as certificações reconhecidas (OSCP, OSWE, OSEP, CRTO, GPEN) atestam competência técnica e ética profissional. A First Security exige que todo profissional sênior carregue pelo menos uma certificação reconhecida.

Pentest substitui WAF, EDR e firewall?

Não. Pentest é prática diagnóstica, não preventiva. Ele identifica falhas para que controles preventivos (WAF, EDR, firewall, SIEM) sejam configurados corretamente. Pentest e controle de segurança são complementares.

O resultado do pentest fica confidencial?

Sim, absoluta. A First Security trata os relatórios como informação ultra confidencial, segregada por projeto, com acesso restrito por need-to-know. Veja a [Política de Confidencialidade](#).

BLOCO 9 — CTA final

H2:

Pronto para um pentest profissional?

Se você chegou até aqui, provavelmente tem clareza de que pentest é um investimento. O próximo passo é falar com um especialista da First Security para entender o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → [/agendar-conversa](#)

Secundário: Ver tipos de pentest → [/pentest/tipos](#)

Tipos de Pentest

URL completa: <https://firstsecurity.com.br/pentest/tipos>

HERO

H1:

Tipos de pentest: como escolher a modalidade e o escopo certos

Pentest se classifica por modalidade (black, white, grey box), por escopo técnico (web, mobile, API, cloud, infraestrutura, AD, IoT, OT, IA) e por modelo comercial (projeto único ou serviço contínuo PTaaS). A escolha certa depende do objetivo do teste, da janela disponível e do orçamento.

Esta página é guia rápido para o decisor que precisa entender as opções antes de pedir orçamento. Para conceitos básicos, veja [o que é pentest](#).

[SEM CTA / SEM FORMULÁRIO] Hero conceitual com link para a página pilar conceitual.

BLOCO 2 — Tabela mestra (formato GEO citável)

H2:

Tipos de pentest em uma tabela

A tabela abaixo é o atalho rápido. Os blocos seguintes detalham cada eixo.

Eixo de classificação	Tipos	Quando faz mais sentido
Modalidade	Black box, White box, Grey box	Black box para simular atacante externo. White box para máxima profundidade. Grey box para custo-benefício.
Escopo técnico	Web, Mobile, API, Cloud, Infra, AD, IoT, OT, IA	Depende do ativo crítico. Tipicamente Web e API para SaaS; Infra e AD para enterprise; Cloud para qualquer ambiente moderno.
Modelo comercial	Projeto pontual, Retainer, PTaaS	Projeto para escopo fechado e auditoria. PTaaS para release contínuo. Retainer para programas anuais.

BLOCO 3 — Tipos por modalidade

H2:

Modalidades de pentest, do mais cego ao mais transparente

Black box: sem informação prévia

O testador recebe apenas o alvo (URL, IP, app) e começa do zero. Simula um atacante externo sem nenhuma informação interna. Resultado de maior realismo, mas o tempo de reconhecimento consome boa parte da janela do projeto, e por isso a profundidade técnica é limitada pelo prazo.

[Página dedicada.](#)

White box: informação completa

O testador recebe credenciais, documentação técnica, diagramas de arquitetura e, quando aplicável, acesso ao código-fonte. Resulta na maior profundidade de teste no menor tempo, ideal para ambientes críticos e janelas curtas. [Página dedicada.](#)

Grey box: o meio termo prático

O testador recebe informação parcial (geralmente um usuário comum, ou credenciais de parceiro). Equilíbrio entre realismo de black box e profundidade de white box. É a modalidade mais usada na prática para a maioria dos casos. [Página dedicada.](#)

Comparação detalhada na página [Black Box vs White Box vs Grey Box.](#)

| [SEM CTA / SEM FORMULÁRIO] Subseções com link interno para cada neta.

BLOCO 4 — Tipos por escopo técnico

H2:

Escopos técnicos atendidos pela First Security

Cada escopo abaixo é uma página de serviço completa. Os textos curtos servem para você reconhecer qual se aplica.

Pentest Web: aplicações e portais expostos à internet, painéis administrativos, CMS. Cobertura OWASP Top 10 e WSTG. [Saiba mais.](#)

Pentest Mobile: apps iOS e Android. Cobertura OWASP MASVS, análise estática e dinâmica, instrumentação. [Saiba mais.](#)

Pentest API: REST, GraphQL, gRPC. Cobertura OWASP API Top 10 com foco em BOLA, BFLA e mass assignment. [Saiba mais.](#)

Pentest Cloud: AWS, Azure, GCP. Revisão de configuração, IAM, exposição de buckets, exploração ativa. [Saiba mais.](#)

Pentest de Infraestrutura: rede interna, perímetro externo, segmentação, controles de borda. [Saiba mais.](#)

Pentest Active Directory: AD on-premises e Azure AD/Entra ID. Kerberoasting, BloodHound, escalonamento de privilégios. [Saiba mais.](#)

Pentest IoT: dispositivos conectados, firmware, comunicação rádio, protocolos não convencionais. [Saiba mais.](#)

Pentest OT/SCADA: ambientes industriais, IEC 62443, com cuidado redobrado para não impactar produção. [Saiba mais](#).

Pentest com IA: aplicações que usam LLM, agentes, integrações com IA. Cobertura OWASP Top 10 for LLM. [Saiba mais](#).

[SEM CTA / SEM FORMULÁRIO] *Lista de escopos com link para cada serviço.*

BLOCO 5 — Tipos por modelo comercial

H2:

Modelos comerciais: projeto, retainer ou PTaaS

Projeto pontual

Escopo fechado, prazo definido, entrega única. Modelo tradicional, ainda mais comum em pentests anuais para fins de compliance.

Retainer

Contrato anual com horas pré-alocadas que o cliente consome conforme demanda. Útil para empresas que sabem que vão precisar de vários pentests ao longo do ano, mas ainda não evoluíram para um modelo recorrente.

PTaaS, Pentest as a Service

Assinatura mensal ou anual com plataforma de gestão, retestes ilimitados, integração com CI/CD e dashboard de vulnerabilidades em tempo real. Ideal para SaaS, ambientes cloud e times que fazem release contínuo. [Saiba mais sobre PTaaS](#).

A escolha entre PTaaS e pentest tradicional é estratégica. Aprofunde em [PTaaS vs Pentest Tradicional](#).

[SEM CTA / SEM FORMULÁRIO] *Bloco explicativo com links de aprofundamento.*

BLOCO 6 — Como escolher o tipo certo (passo a passo)

H2:

Como escolher o tipo de pentest certo para o seu caso

Quatro perguntas resolvem a maioria das dúvidas.

9. **Qual é o ativo mais crítico?** Se for aplicação web e API, vá direto a pentest web + API. Se for ambiente corporativo Windows, AD é prioridade. Se for ambiente cloud, comece por cloud + IAM.
10. **Qual é o objetivo do teste?** Compliance regulatório? Black box anual costuma resolver. Validação contínua de releases? PTaaS. Medir maturidade defensiva? Red Team.
11. **Qual a janela disponível?** Janela curta com escopo crítico pede white box. Janela ampla com objetivo de realismo permite black box.
12. **Qual a maturidade do time defensivo?** Maturidade inicial pede pentest tradicional. Maturidade avançada se beneficia mais de Red Team e Purple Team.

BLOCO 7 — FAQ

H2:

Perguntas frequentes sobre tipos de pentest

Posso contratar mais de um tipo no mesmo projeto?

Sim, e é comum. Um projeto típico pode envolver pentest web + API + cloud, por exemplo. A First Security organiza tudo em um contrato único com escopo bem definido.

Qual o tipo de pentest mais barato?

Em regra, pentest web simples ou pentest API de pequeno porte. Mas o "mais barato" raramente é o mais útil. A pergunta certa é "qual entrega mais valor para o meu cenário".

PTaaS substitui pentest anual para compliance?

Em muitos casos, sim. PCI DSS, por exemplo, aceita pentest contínuo desde que documentado adequadamente. Cada norma tem nuances. Consulte na fase comercial.

Como funciona um pentest com IA?

É diferente do pentest tradicional porque os vetores incluem prompt injection, jailbreaks, vazamento de dados via contexto e abuso de tooling do agente. A First Security tem oferta dedicada de [AI Red Teaming](#) e [Pentest com IA](#).

BLOCO 8 — CTA final

H2:

Não tem certeza qual tipo escolher?

Conversamos com você e ajudamos a definir o tipo certo, sem empurrar serviço que você não precisa. A reunião de descoberta é gratuita e sem compromisso.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa de descoberta → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Parte 5. Páginas de Serviço

Cada página abaixo é uma oferta comercial em si. Texto pronto, estrutura uniforme, linkagens internas para serviços relacionados, comparativos e compliance. Hero + descrição + escopo + entregáveis + metodologia + FAQ + CTA. Esse padrão facilita manutenção e mantém coerência editorial entre páginas.

PÁGINA • /servicos

Hub de Serviços

URL completa: <https://firstsecurity.com.br/servicos>

HERO

Serviços de cibersegurança ofensiva da First Security

Pentest, Red Team, Purple Team, PTaaS, AI Red Teaming, engenharia social e mais. Cada serviço abaixo tem página dedicada com escopo, prazo, entregáveis e modelo comercial. Encontre o que se aproxima do seu cenário e fale com um especialista.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — Catálogo completo (cards organizados por categoria)

Catálogo completo

Organizamos o catálogo em quatro categorias para facilitar a navegação.

Pentest por escopo técnico

- [Pentest Web](#) • Aplicações web, portais, painéis administrativos, CMS.
- [Pentest Mobile](#) • Apps iOS e Android.
- [Pentest API](#) • REST, GraphQL, gRPC, OWASP API Top 10.
- [Pentest Cloud](#) • AWS, Azure, GCP.
- [Pentest de Infraestrutura](#) • Rede interna e perímetro.
- [Pentest Active Directory](#) • AD e identidade.
- [Pentest IoT](#) • Dispositivos conectados.
- [Pentest OT/SCADA](#) • Ambientes industriais.
- [Pentest com IA](#) • Aplicações baseadas em LLM.

Serviços contínuos e adversariais

- [Pentest as a Service \(PTaaS\)](#) • Modelo recorrente com retestes ilimitados.
- [Red Team](#) • Simulação de adversário real.
- [Purple Team](#) • Integração entre ataque e defesa.

- [AI Red Teaming](#) • Testes em LLMs e agentes.
- [Engenharia Social](#) • Phishing, vishing, ataques físicos autorizados.

Para perfis específicos

- [Pentest para Empresas](#) • Pacote enterprise.
- [Consultoria em Cibersegurança](#) • Para programas de longo prazo.

Termos em português

- [Teste de Intrusão](#) • Sinônimo de pentest em português.
- [Pentest no Brasil](#) • Página bilíngue para investidores internacionais.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest Web (aplicações web)

URL completa: <https://firstsecurity.com.br/servicos/pentest-web>

HERO

Pentest Web profissional

Aplicações web, portais corporativos, painéis administrativos, CMS e SaaS testados com profundidade por especialistas certificados (OSWE, BSCP, OSCP). Cobertura OWASP Top 10, OWASP WSTG, autenticação, autorização, lógica de negócio. Relatório executivo e técnico, com plano de remediação priorizado.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Escopo típico

O que é testado em um Pentest Web

A First Security executa pentest web cobrindo de forma manual e profunda os controles que importam.

- Autenticação: força bruta, recuperação de senha, MFA, gerenciamento de sessão.
- Autorização: IDOR, broken access control, escalada vertical e horizontal.
- Validação de entrada: SQL injection, XSS, command injection, deserialização insegura.
- Lógica de negócio: bypass de fluxos, race conditions, abuso de funcionalidades legítimas.
- Configuração: headers de segurança, CORS, exposição de informação, banner grabbing.
- Componentes de terceiros: bibliotecas com CVE conhecidas, dependências desatualizadas.

BLOCO 3 — Entregáveis

O que você recebe

- Relatório executivo (até 8 páginas) para diretoria e conselho, em linguagem de risco.
- Relatório técnico detalhado com cada achado, evidência reproduzível, CVSS, impacto e recomendação.
- Reunião de fechamento com o líder técnico do projeto.
- Reteste incluso para validar correções.
- Certificado de execução para apresentar a auditores e clientes.

BLOCO 4 — Quando contratar

Quando faz sentido contratar pentest web

- Antes do lançamento de aplicação nova exposta à internet.

- Anualmente, para empresas reguladas (LGPD, PCI DSS, ISO 27001, SOC 2).
- Após mudança significativa de arquitetura ou refatoração relevante.
- Como evidência em diligência comercial ou rodada de investimento.
- Após qualquer incidente, mesmo que pequeno.

BLOCO 5 — Metodologia

Metodologia que adotamos

A First Security combina PTES, OWASP WSTG, NIST SP 800-115 e MITRE ATT&CK para web. O detalhamento completo está na [página de metodologia](#).

BLOCO 6 — Compliance

Compliance regulatório atendido

Pentest Web é exigido ou pressuposto em diversas normas brasileiras e internacionais.

- [LGPD](#)
- [PCI DSS](#)
- [ISO 27001](#)
- [SOC 2](#)

BLOCO 7 — Serviços relacionados

Serviços relacionados

Quem contrata pentest web também costuma se interessar por [Pentest API](#), [Pentest Cloud](#) e o modelo contínuo [PTaaS](#).

BLOCO 8 — FAQ

Perguntas frequentes

Quanto tempo dura um pentest web?

Entre uma e quatro semanas, dependendo da complexidade da aplicação. Aplicações com muitos perfis de usuário e regras de negócio complexas levam mais tempo.

Vocês testam em produção ou em homologação?

Preferimos homologação por questão de segurança operacional, mas testamos em produção quando o cliente solicita, com acordo prévio sobre janelas e regras de engajamento.

Pentest web cobre API?

Não automaticamente. APIs têm classes próprias de vulnerabilidade (BOLA, BFLA) e merecem escopo dedicado. Recomendamos contratar pentest web + pentest API quando ambos compõem o produto.

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Pentest Mobile (iOS e Android)

URL completa: <https://firstsecurity.com.br/servicos/pentest-mobile>

HERO

Pentest Mobile para apps iOS e Android

Testes profundos em aplicativos mobile com cobertura OWASP MASVS e MASTG. Análise estática (decompilação, hardening, secrets em código) e dinâmica (instrumentação com Frida, jailbreak/root, interceptação de tráfego). Relatório pronto para auditores e para o time de desenvolvimento.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — Escopo

O que é testado em pentest mobile

- Análise estática: decompilação do binário, busca por chaves embarcadas, certificados, secrets.
- Hardening: proteção contra reverse engineering, anti-debugging, anti-tampering, root/jailbreak detection.
- Armazenamento local: SharedPreferences, Keychain, banco SQLite, arquivos no sandbox.
- Comunicação: pinning de certificado, validação de TLS, tráfego com APIs.
- Autenticação e gestão de sessão no contexto mobile (biometria, refresh tokens).
- Lógica de negócio no app cliente e no backend.
- Permissões e exposição de IPC (intents, deep links, content providers em Android).

BLOCO 3 — Diferenciais

Diferenciais do pentest mobile da First Security

- Equipe com OSWE e experiência prática em apps de fintechs e healthtechs brasileiras.
- Cobertura tanto Android quanto iOS no mesmo projeto.
- Avaliação real de hardening: o que adianta criptografar dados se o app não detecta dispositivo roteado?
- Recomendações práticas para o time de desenvolvimento mobile (não só "implemente OWASP").

BLOCO 4 — Compliance

Compliance e regulação

Apps mobile estão sob escopo da [LGPD](#), e quando processam dados de saúde, da [HIPAA](#). Quando processam cartão, da [PCI DSS](#).

BLOCO 5 — Serviços relacionados

Quem testa app mobile também testa a [API que ele consome](#) e os [serviços cloud do backend](#).

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest API (REST, GraphQL, gRPC)

URL completa: <https://firstsecurity.com.br/servicos/pentest-api>

HERO

Pentest API com profundidade técnica

APIs REST, GraphQL e gRPC testadas com cobertura completa do OWASP API Security Top 10. Foco em BOLA, BFLA, autenticação quebrada, exposição excessiva de dados e mass assignment. Relatório com cada endpoint testado, evidência reproduzível e recomendação implementável.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — Escopo

O que é testado em pentest API

A First Security executa cobertura completa da OWASP API Top 10 (versão mais recente), com adaptação para a sua arquitetura.

- Broken Object Level Authorization (BOLA): IDOR em recursos da API.
- Broken Authentication: tokens, refresh, expiração, replay.
- Broken Object Property Level Authorization (BOPLA): mass assignment, exposição de campos.
- Unrestricted Resource Consumption: rate limit, DoS de aplicação.
- Broken Function Level Authorization (BFLA): endpoints administrativos acessíveis.
- Unrestricted Access to Sensitive Business Flows: abuso de funcionalidade legítima.
- Server Side Request Forgery: SSRF em endpoints que fazem requisições externas.
- Security Misconfiguration: headers, CORS, debug endpoints expostos.
- Improper Inventory Management: APIs órfãs ou esquecidas em ambientes.
- Unsafe Consumption of APIs: APIs de terceiros consumidas sem validação.

BLOCO 3 — Particularidades GraphQL e gRPC

GraphQL e gRPC têm escopo próprio

GraphQL tem classes próprias de vulnerabilidade: introspection exposto, query batching attacks, alias overloading, depth attacks, exposição de schema. A First Security tem método específico para GraphQL.

gRPC, por trabalhar com Protocol Buffers e HTTP/2, exige tooling diferente. Cobrimos com mitmproxy adaptado e validação manual de cada serviço.

BLOCO 4 — Compliance

Compliance regulatório

API expõe o coração do produto, por isso costuma estar no centro de exigências de [LGPD](#), [PCI DSS](#), [SOC 2](#) e [BACEN](#) em fintechs.

BLOCO 5 — FAQ

Perguntas frequentes sobre pentest API

Quantos endpoints vocês conseguem testar em um projeto?

Não trabalhamos com escopo por número de endpoints, e sim por complexidade. Uma API com 30 endpoints CRUD simples leva menos tempo que uma API com 10 endpoints complexos cheios de regras de negócio. Mapeamos juntos no briefing.

Vocês usam OpenAPI/Swagger?

Sim, quando disponível. Acelera o reconhecimento e melhora a cobertura. Mas também trabalhamos com APIs sem documentação, fazendo descoberta de endpoints via tráfego do app cliente.

Pentest API é igual a pentest web?

Não. APIs têm vulnerabilidades próprias que não aparecem em pentest web tradicional. Aprofunde em [Pentest API vs Web](#).

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest Cloud (AWS, Azure, GCP)

URL completa: <https://firstsecurity.com.br/servicos/pentest-cloud>

HERO

Pentest Cloud em AWS, Azure e GCP

Revisão de configuração + exploração ativa em ambientes cloud. IAM mal configurado, buckets expostos, secrets em variáveis de ambiente, escalada de privilégio entre serviços, exfiltração de dados via APIs do próprio provedor. Resultado: visibilidade real do que um atacante consegue, não checklist genérico.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Escopo

O que cobrimos em pentest cloud

- IAM: políticas excessivas, roles assumíveis, trust relationships, escalada vertical e lateral.
- Storage: buckets S3, blobs Azure, GCS expostos sem autenticação ou com permissão excessiva.
- Compute: EC2/Azure VM/GCE com metadata service exposto, secrets em user data, AMIs públicas.
- Container: ECR, ACR, GCR com imagens públicas; ECS, EKS, AKS, GKE mal segmentados.
- Serverless: Lambda, Azure Functions, Cloud Functions com permissão excessiva ou triggers abusáveis.
- Network: VPC, NSG, firewall rules, peering, exposição de banco gerenciado.
- Logging e monitoramento: CloudTrail, Activity Log, Audit Logs configurados ou ausentes.

BLOCO 3 — Abordagem

Como conduzimos o pentest cloud

A First Security combina três camadas no pentest cloud: revisão de configuração via Prowler/ScoutSuite/CloudSploit, exploração ativa com credenciais do cliente (testando IAM real) e simulação de adversário externo tentando comprometer o ambiente a partir de uma aplicação web ou API.

BLOCO 4 — Compliance

Compliance cloud

- [LGPD para ambientes cloud](#)
- [ISO 27001 e ISO 27017 \(cloud-specific\)](#)

- [SOC 2 com foco em infraestrutura cloud](#)

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest de Infraestrutura

URL completa: <https://firstsecurity.com.br/servicos/pentest-infraestrutura>

HERO

Pentest de Infraestrutura (interna e externa)

Avaliação completa de redes corporativas, perímetro externo, segmentação de rede e controles de borda. Black box externo simulando atacante da internet; assumed breach interno simulando colaborador comprometido ou notebook infectado. Cobertura ampla de Windows, Linux, equipamentos de rede e dispositivos.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Escopo

O que cobrimos

Perímetro externo

- Descoberta de superfície de exposição (DNS, subdomínios, certificados).
- Vulnerabilidades em serviços expostos (VPN, RDP, SSH, web admin, painéis).
- Exposição de credenciais em vazamentos públicos.

Rede interna

- Enumeração de domínio Windows.
- SMB, LDAP, Kerberos, NetBIOS, mDNS, LLMNR.
- Pivoting e movimento lateral.
- Segmentação de rede e separação de ambientes.
- Exfiltração de dados controlada.

BLOCO 3 — Modalidades

Modalidades comuns

- **Externo black box:** só recebemos IPs/domínios do perímetro.
- **Interno assumed breach:** recebemos acesso a um dispositivo na rede interna como ponto inicial.
- **Híbrido:** os dois cenários em um projeto único.

BLOCO 4 — Serviços relacionados

Para ambientes Windows, combinamos quase sempre com [Pentest Active Directory](#). Para validar resposta defensiva, evolui para [Red Team](#) ou [Purple Team](#).

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest Active Directory

URL completa: <https://firstsecurity.com.br/servicos/pentest-active-directory>

HERO

Pentest Active Directory (AD e Azure AD/Entra ID)

AD é o coração do ambiente corporativo Windows, e também o alvo preferido de atacante. A First Security mapeia kerberoasting, AS-REP roasting, delegação insegura, GPO abusivas, ACLs perigosas e caminhos de comprometimento via BloodHound. Cobertura também para Azure AD/Entra ID com seus próprios vetores de abuso.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Escopo

O que cobrimos em AD

- Enumeração de domínio: usuários, grupos, computadores, GPOs.
- Kerberoasting e AS-REP roasting.
- Constrained, unconstrained e resource-based delegation.
- Mapeamento de caminhos com BloodHound: shortest path para Domain Admin.
- ACL abuse: WriteDACL, GenericAll, GenericWrite, AddSelf.
- GPO abuse e exploração de objetos privilegiados.
- Pass-the-Hash, Pass-the-Ticket, Overpass-the-Hash, Golden Ticket, Silver Ticket.
- DCSync, DCShadow, ADCS misconfigurations (ESC1-ESC14).

BLOCO 3 — Azure AD / Entra ID

Cobertura Azure AD / Entra ID

A migração para Azure AD trouxe novos vetores: consentimento abusivo via OAuth, app registration com permissões excessivas, escalada via roles do Entra, abuso de Conditional Access mal configurado, dispositivos Intune comprometidos como ponto de pivô.

BLOCO 4 — Relevância

Por que AD costuma ser prioridade

Em uma empresa Windows-centric, 80% do impacto de um ransomware vem da capacidade do atacante de circular pelo AD com privilégio. Testar AD não é luxo, é fundação.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Pentest as a Service (PTaaS)

URL completa: <https://firstsecurity.com.br/servicos/pentest-as-a-service>

HERO

Pentest as a Service (PTaaS)

Modelo recorrente que substitui o pentest anual por uma cobertura contínua ao longo do ano. Plataforma com dashboard de vulnerabilidades em tempo real, retestes ilimitados, integração com seu pipeline de CI/CD, e horas de pentester sênior alocadas por mês. Ideal para SaaS, cloud, APIs em release contínuo.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Como funciona

Como o PTaaS funciona na prática

Em vez de um relatório PDF que envelhece em três meses, o PTaaS entrega cobertura contínua.

13. Onboarding: setup da plataforma, integração com o seu Jira/Slack/CI, definição de escopo recorrente.
14. Execução mensal: o pentester sênior trabalha um número fixo de horas no escopo a cada mês.
15. Achados em tempo real: cada vulnerabilidade entra na plataforma assim que validada, com severidade e plano de correção.
16. Retestes ilimitados: depois que você corrige, o pentester reteste e fecha o achado.
17. Relatórios sob demanda: a qualquer momento, você gera relatório executivo para auditor, cliente ou conselho.

BLOCO 3 — Diferenciais vs pentest tradicional

Quando PTaaS é melhor que pentest anual

- Você faz mais de uma release por mês.
- Seu produto cresce rápido em superfície de exposição.
- Seus clientes pedem evidência de segurança recorrentemente.
- Você quer integrar segurança ao ciclo de desenvolvimento (DevSecOps).

Comparação detalhada em [PTaaS vs Pentest Tradicional](#).

BLOCO 4 — Modelos disponíveis

Modelos de assinatura

- **PTaaS Essentials:** até 40 horas/mês de pentester sênior, escopo de uma aplicação ou ambiente.
- **PTaaS Pro:** até 80 horas/mês, escopo composto (web + API + cloud).
- **PTaaS Enterprise:** horas customizadas, múltiplos escopos, integração com programas globais de segurança.

NOTA EDITORIAL: Os modelos acima são placeholders comerciais. Definir com a área comercial os pacotes oficiais e seus preços.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Red Team (operação adversarial)

URL completa: <https://firstsecurity.com.br/servicos/red-team>

HERO

Red Team em cibersegurança

Simulação de adversário real com objetivo de medir não só o que está vulnerável, mas se o seu time defensivo é capaz de detectar e responder. Escopo amplo (tecnologia, processos, pessoas), prazo extenso (semanas), objetivos claros (acessar X, exfiltrar Y, comprometer Z) e relatório que mede maturidade defensiva por tática MITRE ATT&CK.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Diferença para pentest

Por que Red Team não é o mesmo que pentest

Pentest busca o máximo de vulnerabilidades em escopo bem delimitado. Red Team busca um objetivo específico e mede o caminho. Pentest é amplo e raso (em termos de táticas). Red Team é estreito e profundo (em termos de adversário).

A comparação detalhada está em [Pentest vs Red Team](#).

BLOCO 3 — Quando vale Red Team

Quando faz sentido contratar Red Team

- Você já tem SOC e EDR maduros, e quer testar de verdade.
- Você fez vários pentests e quer validar a postura defensiva como um todo.
- Sua diretoria quer saber: "se nos atacarem, conseguimos detectar?"
- Você está sob exigência regulatória pesada (BACEN, financeiro, governo).
- Houve incidente recente e você quer simular um cenário similar para validar correções.

BLOCO 4 — Como conduzimos

Fases de um exercício de Red Team

18. Planejamento: definição de objetivos (flags), regras de engajamento, white cell (executivos que sabem do exercício).
19. Reconhecimento ativo e passivo do alvo.
20. Acesso inicial: phishing, exploração de perímetro, abuso de fornecedor, presença física.
21. Estabelecimento de C2 com comando e controle resilientes.
22. Movimento lateral, escalada de privilégio, persistência.
23. Captura das flags definidas no planejamento.

24. Reunião de retro com time defensivo: o que detectaram, o que perderam, por quê.

BLOCO 5 — Cobertura MITRE ATT&CK

Mapeamento por MITRE ATT&CK

Toda atividade do nosso Red Team é mapeada para táticas e técnicas do MITRE ATT&CK. O relatório final mostra a matriz com tudo o que foi executado e o que foi detectado pelo seu time. É o documento mais útil que existe para evoluir a maturidade defensiva.

BLOCO 6 — Serviços relacionados

Após o Red Team, recomendamos ciclos de [Purple Team](#) para evoluir a detecção em conjunto com o seu time. Veja também a página pilar [Red Team em cibersegurança](#).

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Purple Team

URL completa: <https://firstsecurity.com.br/servicos/purple-team>

HERO

Purple Team: ataque e defesa lado a lado

Em vez de operar como adversário escondido (Red Team) ou apenas mapear falhas (pentest), o Purple Team trabalha lado a lado com o seu time defensivo. Executamos uma técnica de ataque, observamos juntos se foi detectada, ajustamos o controle e validamos. Cada ciclo evolui a postura defensiva de forma mensurável.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Diferenciais

Por que Purple Team é o ciclo mais produtivo

Pentest entrega uma lista de problemas. Red Team entrega uma narrativa de comprometimento. Purple Team entrega evolução real do time defensivo. O cliente sai do projeto com SOC mais maduro, com alertas mais bem calibrados, com playbooks revisados.

BLOCO 3 — Estrutura típica

Estrutura de um exercício Purple Team

25. Workshop inicial: alinhamento sobre maturidade atual do time defensivo, tecnologias em uso (EDR, SIEM, NDR), ameaças prioritárias.
26. Definição de matriz de testes: técnicas MITRE ATT&CK a serem executadas, por ordem de prioridade.
27. Execução em ciclos: para cada técnica, executar ataque, observar telemetria, calibrar detecção, repetir.
28. Documentação: cada técnica gera um registro com status (detectada, perdida, parcialmente detectada) e recomendação de melhoria.
29. Re-execução: depois das melhorias, validar que as detecções funcionam.
30. Relatório de evolução: mapa de antes e depois.

BLOCO 4 — Quando contratar

Quando o Purple Team faz mais sentido

- Você tem SOC interno ou MSSP que precisa amadurecer.
- Sua empresa investiu em EDR, SIEM, NDR e quer extrair o máximo do que comprou.
- Você quer transformar o achado de Red Team em melhoria operacional sustentável.

- Você precisa de evidência de evolução em ciclos contínuos (board, auditor).

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

AI Red Teaming

URL completa: <https://firstsecurity.com.br/servicos/ai-red-teaming>

HERO

AI Red Teaming para LLMs e agentes

Aplicações que usam IA generativa expõem classes inéditas de risco: prompt injection direta e indireta, jailbreaks, vazamento de dados de treinamento ou contexto, abuso de ferramentas via agentes, alucinação como vetor de manipulação. A First Security testa LLMs e agentes em produção com cobertura OWASP Top 10 for LLM e técnicas próprias.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Escopo

O que cobrimos em AI Red Teaming

- Prompt injection: direta (no input do usuário) e indireta (via documento, página, email processado pelo LLM).
- Jailbreaks: técnicas que burlam guardrails do modelo.
- Vazamento de informação: exfiltração de dados do contexto, do system prompt ou de embeddings.
- Abuso de tooling: agentes com acesso a APIs internas, bancos de dados, browsers.
- Manipulação de output: forçar o LLM a executar ação maliciosa via instrução escondida.
- Treinamento adversarial: poisoning de fine-tuning ou de RAG.
- Cobertura OWASP Top 10 for LLM (LLM01 a LLM10).

BLOCO 3 — Cobertura específica para agentes

Particularidades de agentes (LLM + tools)

Agentes que usam ferramentas (function calling, MCP, browsers) ampliam radicalmente a superfície de ataque. Um prompt injection que antes era curiosidade acadêmica se transforma em comando real para enviar emails, modificar dados, executar código. A First Security tem método específico para agentes com cobertura de cadeia completa.

BLOCO 4 — Diferenciais

Por que escolher a First Security para AI Red Teaming

- Equipe que pesquisa ativamente em IA, não consultoria que descobriu o tema ontem.
- Cobertura para múltiplos provedores: OpenAI, Anthropic, Google, Mistral, modelos open source.

- Foco em risco real de negócio, não apenas em "fui capaz de fazer o LLM xingar".
- Recomendações implementáveis pelo seu time de produto.

BLOCO 5 — Serviços relacionados

Quando o produto envolve LLM em pipeline maior, combinamos com [Pentest API](#) e [Pentest Cloud](#). Para aplicações que só usam IA como feature, veja também [Pentest com IA](#).

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Pentest com IA

URL completa: <https://firstsecurity.com.br/servicos/pentest-ai>

HERO

Pentest em aplicações com IA

Para aplicações tradicionais (web, API, mobile) que incorporaram IA como funcionalidade, a First Security executa pentest com cobertura ampliada que inclui os vetores de risco específicos de LLM e ML. Diferente do AI Red Teaming dedicado, este é o pentest de aplicação que reconhece que IA hoje faz parte do produto.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Diferença para AI Red Teaming

Pentest com IA vs AI Red Teaming dedicado

Use [AI Red Teaming](#) quando o foco é exclusivamente o componente de IA (LLM, agentes, ML em produção). Use Pentest com IA quando você quer um pentest completo da aplicação que inclui também a camada de IA. Os dois se complementam, raramente competem.

BLOCO 3 — Cobertura

Cobertura típica

- Tudo que está em pentest web/mobile/API tradicional.
- Vetores OWASP Top 10 for LLM aplicáveis ao caso.
- Integrações entre o LLM e o backend (function calling, RAG, busca em base interna).
- Camada de moderação e guardrails (testar bypass).

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest IoT

URL completa: <https://firstsecurity.com.br/servicos/pentest-iot>

HERO

Pentest IoT (Internet of Things)

Dispositivos conectados, sensores, equipamentos inteligentes, wearables e gateways IoT testados em todas as camadas: hardware (UART, JTAG, SPI), firmware (análise estática e dinâmica), comunicação (BLE, ZigBee, LoRa, Wi-Fi, celular), backend e app companion. Ideal para fabricantes que precisam garantir segurança de produto antes do go-to-market.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Escopo

Camadas que cobrimos

- **Hardware:** extração de firmware via UART/JTAG, análise de chips, secrets em hardware.
- **Firmware:** engenharia reversa, busca por backdoors, secrets, vulnerabilidades de implementação.
- **Comunicação radio:** BLE, ZigBee, Z-Wave, LoRa, sub-1GHz, 2.4GHz proprietário.
- **Backend:** APIs e cloud que recebem dados do dispositivo.
- **App companion:** aplicativo mobile que controla o dispositivo.

BLOCO 3 — Quem contrata

Setores típicos

- Fabricantes de dispositivos médicos.
- Casas inteligentes e domótica.
- Indústria 4.0 com IIoT.
- Tracking de frota e logística.
- Wearables e healthtech.
- Smart cities e iluminação pública.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest OT/SCADA (ambientes industriais)

URL completa: <https://firstsecurity.com.br/servicos/pentest-ot-scada>

HERO

Pentest OT/SCADA (Operational Technology)

Ambientes industriais (energia, água, saneamento, manufatura, óleo e gás) exigem abordagem específica. Pentest em OT/SCADA tem regra primária inviolável: não impactar produção. A First Security adota IEC 62443, Purdue Model e técnicas passivas para ambientes que não toleram interrupção, com etapa ativa em ambientes segregados.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Particularidades de OT

Por que OT exige cuidado diferente

Em IT, um servidor que cai pode ser reiniciado. Em OT, uma centrífuga que para no momento errado pode causar acidente físico, perda de produção, dano ambiental. Por isso o pentest em OT trabalha em três camadas distintas: análise passiva em produção, análise ativa em testbed segregado e análise de arquitetura/segmentação.

BLOCO 3 — Escopo

Escopo típico

- Segmentação entre IT, OT e DMZ industrial.
- Protocolos OT: Modbus, DNP3, IEC 61850, OPC, EtherNet/IP.
- PLCs, RTUs, HMIs, históricos de processo.
- Engenharia de protocolos: análise de tráfego em tempo real.
- Servidores SCADA, MES, soluções de visualização.
- Aderência a IEC 62443.

BLOCO 4 — Frameworks

Frameworks de referência

- IEC 62443 (segurança em sistemas de controle industrial).
- NIST SP 800-82 (Guide to Industrial Control Systems Security).
- Purdue Enterprise Reference Architecture.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Engenharia Social

URL completa: <https://firstsecurity.com.br/servicos/engenharia-social>

HERO

Engenharia Social (campanhas autorizadas)

O vetor humano continua sendo o ponto de entrada mais comum em ataques reais. A First Security executa campanhas autorizadas de phishing, vishing, smishing e ataques físicos (intrusão presencial, USB drop), todas com escopo, regras e métricas claras, sem expor pessoas a constrangimento. Resultado mensurável, com plano de awareness derivado.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Modalidades

Modalidades de engenharia social

- **Phishing por email:** campanhas direcionadas com landing pages clonadas e captura de credenciais (sem armazenar senha).
- **Spear phishing:** ataque direcionado a alvos específicos (executivos, financeiro).
- **Vishing:** engenharia social por telefone com cenários elaborados.
- **Smishing:** SMS com link malicioso.
- **USB drop:** pendrives plantados em áreas comuns com payload de telemetria.
- **Intrusão física:** tentativa de acesso a áreas restritas (tailgating, social engineering presencial).

BLOCO 3 — Cuidados éticos

Cuidados éticos obrigatórios

A First Security trabalha engenharia social com regras rígidas. Não usamos pretextos que envolvam familiares, doenças, demissões ou outros temas sensíveis. Não exponhamos nominalmente quem caiu no teste no relatório. O objetivo é melhorar a postura organizacional, não punir indivíduos.

BLOCO 4 — Entregáveis

O que você recebe

- Métricas de campanha (taxa de clique, taxa de submissão de credencial, taxa de reporte).
- Análise de funções e áreas com maior taxa de vulnerabilidade humana.
- Plano de awareness customizado.
- Sugestão de campanhas educativas para os meses seguintes.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Pentest para Empresas (pacote enterprise)

URL completa: <https://firstsecurity.com.br/servicos/pentest-para-empresas>

HERO

Pentest para Empresas: oferta enterprise

Para empresas de médio e grande porte que precisam programa anual de testes ofensivos, a First Security oferece pacotes enterprise. Combinam múltiplos escopos (web, API, cloud, AD, mobile), cobertura recorrente, relatórios consolidados para diretoria e atendimento prioritário.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — O que inclui

Estrutura do programa enterprise

- Reunião trimestral com o CISO ou diretor de TI para revisão de risco e calibragem de escopo.
- Múltiplos escopos contratados em pacote único.
- Relatório consolidado anual para diretoria e conselho.
- Atendimento prioritário em até 4 horas úteis para qualquer demanda.
- Atendimento emergencial 24/7 em caso de incidente.
- Possibilidade de embed de especialistas em projetos críticos.

BLOCO 3 — Diferenciais

Por que empresas escolhem o pacote enterprise

- Custo total inferior ao somatório de projetos isolados.
- Visão consolidada de risco em todo o ambiente.
- Liderança técnica única conhecendo todo o ambiente, sem perder contexto entre projetos.
- Cobertura adequada à exigência de auditores e clientes corporativos.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Consultoria em Cibersegurança

URL completa: <https://firstsecurity.com.br/servicos/consultoria-ciberseguranca>

HERO

Consultoria em cibersegurança ofensiva

Para empresas que precisam de orientação contínua em segurança ofensiva (programa de pentest, estruturação de Red Team interno, governança de bug bounty, evolução de SOC via Purple Team), a First Security oferece consultoria especializada. Não vendemos ferramenta, vendemos clareza estratégica.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Áreas de atuação

Áreas em que apoiamos

- Estruturação ou amadurecimento de programa interno de pentest.
- Construção de Red Team interno (recrutamento, ferramentas, métricas).
- Governança de bug bounty: políticas, processos, integração com triage.
- Roadmap de evolução de SOC com base em exercícios Purple Team.
- Diagnóstico de maturidade ofensiva e plano de evolução.

BLOCO 3 — Modelos

Modelos comerciais

- **Projeto pontual:** diagnóstico ou estruturação com prazo definido.
- **Retainer:** horas mensais de consultoria sênior para apoio contínuo.
- **Fractional CISO ofensivo:** liderança técnica part-time para empresas em fase de estruturação.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Teste de Intrusão (sinônimo de pentest)

URL completa: <https://firstsecurity.com.br/servicos/teste-de-intrusao>

HERO

Teste de Intrusão: o pentest em bom português

Teste de intrusão é o termo em português brasileiro equivalente a "pentest" ou "penetration testing". Usado especialmente em contratos formais, documentação técnica corporativa e referências jurídicas no Brasil. A First Security usa os dois termos de forma intercambiável e entrega exatamente o mesmo serviço.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Esclarecimento

Esta página existe para esclarecer

Se você chegou aqui buscando "teste de intrusão", está no lugar certo. Convidamos a continuar a leitura no hub principal: [Pentest](#). Ou veja a definição completa em [o que é pentest](#).

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest no Brasil (foco internacional)

URL completa: <https://firstsecurity.com.br/servicos/pentest-no-brasil>

HERO

Pentest no Brasil: contrate uma consultoria local

Para empresas internacionais com operação no Brasil ou que vendem para o mercado brasileiro, contratar uma consultoria local resolve mais que problema de fuso horário. Você ganha entendimento de LGPD, BACEN, fluxo PIX, particularidades de open finance e contratação em moeda local. A First Security é consultoria brasileira com equipe que fala inglês fluente.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — English version

English summary

First Security is a Brazilian cybersecurity consultancy specialized in offensive security: penetration testing, Red Team, Purple Team and AI Red Teaming. We work with international companies operating in Brazil and with Brazilian companies serving global customers. Deliverables in English available upon request at no extra cost. Compliance coverage: LGPD, BACEN, PCI DSS, ISO 27001, SOC 2.

BLOCO 3 — Diferenciais para empresas internacionais

Why hire a Brazilian consultancy / Por que contratar uma consultoria brasileira

- Native understanding of LGPD, BACEN regulation and Brazilian banking ecosystem.
- PIX, Open Finance and Brazilian-specific fraud scenarios covered out of the box.
- Local contracting in BRL, no FX exposure.
- Compliance reports accepted by Brazilian auditors (QSA-PCI, ISO 27001 BR, BACEN).
- Deliverables in English or bilingual when needed.

BLOCO FINAL — CTA de fechamento

Pronto para começar?

A conversa de descoberta é gratuita e sem compromisso. Em 30 minutos definimos o que faz sentido para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Parte 6. Pilar Red Team em cibersegurança

Esta parte trata da página pilar /red-team, central para autoridade tópica da First Security no termo. Em SEO brasileiro, "Red Team" é palavra ambígua (Pokémon, Halo, suplementos, Team Fortress), e por isso a página adota desambiguação explícita no topo e usa o qualificador "em cibersegurança" sempre que o contexto pede.

PÁGINA • /red-team

Red Team em cibersegurança

URL completa: <https://firstsecurity.com.br/red-team>

HERO

Red Team em cibersegurança: definição, propósito e quando contratar

Red Team em cibersegurança é a equipe ou exercício adversarial autorizado que simula um atacante real para medir a capacidade de uma organização de detectar e responder a ameaças. Diferente de pentest (que mapeia vulnerabilidades em escopo fechado), o Red Team trabalha com objetivos definidos, escopo amplo (tecnologia, processos, pessoas) e foco em testar maturidade defensiva, não só pontos de falha.

Esta é a página de referência da First Security sobre Red Team em cibersegurança. Cobrimos a definição precisa, a diferença para pentest, como funciona um exercício profissional, quando faz sentido contratar e quem deve estar envolvido pela parte do cliente.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de Red Team → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Desambiguação editorial

"Red Team" em outros contextos

O termo "Red Team" existe em vários domínios. Em videogame, é o nome de equipe (Pokémon, Halo, Team Fortress). Em fitness, há linha de suplementos. Em estratégia militar e empresarial, "red teaming" é prática de adversarial thinking aplicada a planejamento estratégico, sem componente cibernético.

Esta página, e o conteúdo da First Security em geral, trata exclusivamente de Red Team em cibersegurança: a prática técnica de simular adversário cibernético contra a infraestrutura, aplicações, pessoas e processos de uma organização-alvo. Sempre que o termo aparece no nosso conteúdo sem contexto explícito, é nesse sentido que ele deve ser entendido.

[SEM CTA / SEM FORMULÁRIO] Bloco de desambiguação. Crucial para SEO neste termo.

BLOCO 3 — Origem do conceito

De onde vem o conceito de Red Team

A origem está na Guerra Fria. As forças armadas americanas começaram, nos anos 1960, a constituir equipes internas que tinham a missão de pensar e agir como o adversário soviético, para identificar falhas no próprio planejamento. Essas equipes foram chamadas de "red teams", em oposição às "blue teams" (defensivas).

A prática migrou para o setor privado nas décadas seguintes, primeiro em consultorias estratégicas (red teaming de planejamento) e depois, com o crescimento da cibersegurança, em equipes técnicas dedicadas a simular ataques cibernéticos. Na década de 2010, Red Team se consolidou como prática diferenciada de pentest, com metodologia e expectativa próprias.

BLOCO 4 — Red Team vs outras práticas (tabela)

Red Team comparado a outras práticas ofensivas

Para quem está decidindo qual serviço contratar, a tabela abaixo resume as diferenças.

Prática	Foco	Escopo	Quem é avisado
Red Team	Testar capacidade defensiva via adversário	Amplo (tech + pessoas + processos)	Apenas a "white cell" (poucos executivos)
Pentest	Mapear vulnerabilidades em escopo fechado	Restrito ao ativo definido	Time defensivo é avisado
Purple Team	Evoluir detecção em conjunto com defesa	Definido por matriz ATT&CK	Time defensivo trabalha junto
Análise de vulnerabilidade	Listar falhas conhecidas (scan)	Definido por inventário	Operacional do time

Aprofunde em [Pentest vs Red Team](#) e [Red Team vs Blue Team](#).

BLOCO 5 — Anatomia de uma operação

Anatomia de uma operação de Red Team

Toda operação séria de Red Team em cibersegurança passa por sete fases canônicas.

Planejamento e ROE

Definição dos objetivos do exercício (as "flags"), estabelecimento da white cell de executivos que sabem do exercício, regras de engajamento por escrito, canais de emergência caso algo dê errado, janela de execução.

Reconhecimento

Coleta passiva de informações sobre o alvo: DNS, certificados, vazamentos públicos, presença em redes sociais, fornecedores, parceiros, presença física. Mapeamento da superfície de ataque visível.

Acesso inicial

Tentativa de obter o primeiro pé dentro da organização. Vetores comuns: phishing, exploração de perímetro, abuso de fornecedor, presença física com social engineering, USB drop.

Estabelecimento de C2

Após acesso inicial, instalação de comando e controle resiliente, com técnicas que dificultem detecção. Comunicação por canais legítimos (HTTPS, DNS, serviços cloud).

Movimento lateral e escalada

A partir do ponto inicial, exploração para outros sistemas, escalada de privilégio em domínio Windows ou em ambiente cloud, busca por credenciais úteis para a missão.

Captura das flags

Demonstração de comprometimento real dos objetivos definidos: acesso ao sistema X, exfiltração simulada do dado Y, persistência durável no ambiente Z.

Reunião de retro

Sessão de fechamento com o time defensivo (e a white cell). Apresentação completa do que foi feito, do que foi detectado, do que passou despercebido, e do mapa MITRE ATT&CK consolidado.

BLOCO 6 — Quando contratar

Quando faz sentido contratar Red Team

Red Team não é primeiro investimento em segurança ofensiva. Faz sentido quando alguns pré-requisitos estão presentes.

- Você já tem SOC interno ou MSSP com capacidade de detecção.
- Você já fez pentests e quer subir o nível do que está sendo testado.
- Sua diretoria pergunta "se nos atacarem, conseguimos perceber a tempo?".
- Você está sob exigência regulatória pesada (BACEN para grandes bancos, governo, defesa).
- Você sofreu incidente recente e quer simular cenário similar para validar correções.
- Você está em diligência avançada (M&A, IPO, parceria estratégica).

Se o seu cenário ainda não comporta Red Team, o caminho é começar por [pentest](#) e evoluir gradualmente.

BLOCO 7 — Quem deve estar envolvido

Quem deve estar na "white cell"

A white cell é o grupo restrito de executivos do cliente que sabe que o exercício está em andamento. O time defensivo não deve saber, porque o objetivo é justamente medir a reação real do time. Quem fica na white cell:

- CEO ou COO (representação executiva).
- CISO ou diretor de segurança da informação.
- CIO ou diretor de TI (em alguns casos).
- Jurídico (para casos que envolvem terceiros ou regulação).
- Comunicação (para o caso de o exercício causar burburinho interno).

BLOCO 8 — Cobertura MITRE ATT&CK

Por que MITRE ATT&CK é o esqueleto do relatório

O MITRE ATT&CK é a matriz pública de táticas, técnicas e procedimentos usados por adversários reais. Hoje é o padrão de fato para mapear ataques. Toda atividade do Red Team da First Security é mapeada para uma técnica ATT&CK. O relatório final mostra a matriz com:

- Tudo o que foi executado pelo Red Team.
- O que foi detectado pelo time defensivo.
- O tempo médio de detecção (MTTD) e de resposta (MTTR).
- Lacunas claras de cobertura.

Esse mapeamento é o que torna o exercício acionável. O CISO sai do projeto sabendo exatamente onde investir para evoluir.

BLOCO 9 — Modalidades

Modalidades de Red Team

Red Team tradicional

Exercício único, com duração de seis a dez semanas em média, com objetivos definidos e relatório consolidado ao final. Modelo mais comum.

Red Team contínuo

Programa anual com vários exercícios menores ao longo do ano, cada um com objetivos distintos. Usado por empresas com alta maturidade que querem cobertura permanente de threat hunting adversarial.

Red Team específico

Exercício focado em um cenário (ransomware, insider threat, supply chain attack). Útil para validar resposta a um tipo específico de ameaça.

BLOCO 10 — FAQ

Perguntas frequentes sobre Red Team

Red Team é o mesmo que pentest?

Não. Pentest busca o máximo de vulnerabilidades em escopo definido; Red Team busca um objetivo específico medindo capacidade defensiva. Detalhe em [Pentest vs Red Team](#).

Quanto dura uma operação de Red Team?

Tipicamente seis a dez semanas, do planejamento à reunião de retro. Operações enterprise complexas podem chegar a três meses.

Quanto custa um Red Team?

Operações sérias começam na faixa de seis dígitos em reais (R\$). O custo reflete o número de pentesters seniores envolvidos, a duração e a complexidade do alvo. Para empresas em fase inicial, recomendamos começar por pentests focados e evoluir gradualmente.

Vocês usam ferramentas comerciais (Cobalt Strike, Brute Ratel)?

Sim, dentro dos termos de licença e com infraestrutura própria. Também desenvolvemos tooling interno e usamos open source (Sliver, Mythic, custom implants) quando o cenário pede.

Como vocês evitam impacto operacional durante o Red Team?

Regras de engajamento por escrito que detalham o que pode e o que não pode. Canal de emergência sempre aberto. Decisões de ação com impacto potencial passam por aprovação da white cell. Histórico de zero incidentes operacionais em projetos passados.

O que diferencia o Red Team da First Security de outros fornecedores?

Equipe que combina certificação reconhecida (CRTO, CRTL, OSEP) com pesquisa publicada, foco real em mensurar maturidade defensiva (não apenas em "comprovar que conseguimos invadir") e ciclo natural de evolução para Purple Team após o exercício.

BLOCO 11 — Serviços relacionados

Serviços relacionados

A página de serviço dedicada está em </servicos/red-team>. Para evolução pós Red Team, recomendamos [Purple Team](#). Para começar, [pentests focados](#) são o primeiro passo lógico.

BLOCO 12 — CTA final

Pronto para uma operação séria?

Red Team é decisão estratégica. Conversamos com o seu CISO ou diretor de segurança em uma reunião de 60 minutos para entender o cenário e propor um exercício que faça sentido.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa com a liderança técnica → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Parte 7. Páginas comparativas

Páginas comparativas ranqueiam excepcionalmente bem em SEO porque atendem a um momento decisivo da jornada: a comparação entre alternativas. Cada texto abaixo segue um padrão: definição rápida + diferença sintética + tabela comparativa + análise por critério + recomendação por cenário + FAQ.

PÁGINA • /comparativos/red-team-vs-blue-team

Red Team vs Blue Team

URL completa: <https://firstsecurity.com.br/comparativos/red-team-vs-blue-team>

HERO

Red Team vs Blue Team em cibersegurança: papéis e diferenças

Em cibersegurança, Red Team é a equipe ofensiva (simula adversário) e Blue Team é a equipe defensiva (protege, detecta e responde). A combinação dos dois (com integração via Purple Team) é o padrão maduro de uma operação de segurança. Em outros contextos (videogame, esportes, militar), os termos têm significados diferentes; esta página trata exclusivamente do uso em cibersegurança.

BLOCO 2 — Tabela comparativa

Tabela comparativa rápida

Aspecto	Red Team	Blue Team
Postura	Ofensiva, adversarial	Defensiva, protetora
Objetivo	Encontrar caminhos de comprometimento	Impedir, detectar e responder a ameaças
Mentalidade	Pensa como atacante	Pensa como defensor
Atividades típicas	Pentest, simulação adversarial, exploits	Monitoramento, hardening, resposta a incidentes
Ferramentas	Cobalt Strike, Burp, Metasploit, custom implants	SIEM, EDR, NDR, SOAR
Certificações típicas	OSCP, OSEP, CRT0, CRTL	GCIH, GCFA, GMON, BTL1

BLOCO 3 — O que faz cada um

O que faz o Red Team

O Red Team simula adversários reais para medir a capacidade defensiva da organização. As atividades incluem pentests, simulações adversariais de longa duração, desenvolvimento de implants customizados, OSINT e operações de engenharia social autorizadas. Trabalha em ciclos de exercícios com objetivos definidos.

O que faz o Blue Team

O Blue Team protege a organização. Mantém EDR e SIEM, escreve regras de detecção, faz threat hunting, responde a incidentes, aplica hardening em servidores e endpoints, mantém atualizações, ajusta políticas de identidade e acesso. Trabalha em modo de operação contínua.

BLOCO 4 — Por que ambos são necessários

Por que toda empresa madura tem (ou contrata) ambos

Blue Team sozinho não tem como saber se as suas detecções funcionam contra um adversário sério. Red Team sozinho não evolui a defesa, só aponta falhas. Junto, eles formam o ciclo de aprendizado que torna a organização realmente resiliente. Por isso o

BLOCO 5 — Comum: empresa só tem um lado

O cenário mais comum: empresa só tem Blue Team

A maioria das empresas brasileiras tem alguma estrutura de Blue Team (SOC interno ou terceirizado, EDR, SIEM) mas não tem Red Team interno. A solução prática nesse cenário é contratar Red Team como serviço, com frequência anual ou semestral, da First Security ou de outra consultoria séria.

BLOCO 6 — Links relacionados

Aprofunde em [Pentest vs Red Team](#), [Red Team vs Purple Team](#) e na página pilar [Red Team em cibersegurança](#).

CTA FINAL

Ainda em dúvida sobre qual escolher?

Conversamos com você em 30 minutos e indicamos o caminho mais adequado ao seu cenário, sem empurrar serviço desnecessário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest vs Análise de Vulnerabilidade

URL completa: <https://firstsecurity.com.br/comparativos/pentest-vs-analise-de-vulnerabilidade>

HERO

Pentest vs Análise de Vulnerabilidade: como escolher

Pentest e análise de vulnerabilidade resolvem problemas diferentes. A análise de vulnerabilidade lista falhas conhecidas via scan automatizado. O pentest valida quais dessas falhas são realmente exploráveis, encadeia múltiplas falhas e mede impacto real com julgamento humano. Os dois se complementam, mas não se substituem, e contratar um pelo outro costuma sair caro.

BLOCO 2 — Tabela

Tabela comparativa

Aspecto	Análise de vulnerabilidade	Pentest
Execução	Automatizada (scanner)	Manual + ferramentas auxiliares
Resultado	Lista de vulnerabilidades conhecidas	Validação de exploração + impacto medido
Falsos positivos	Altos	Praticamente zero (validação manual)
Falsos negativos	Vulnerabilidades novas e lógica de negócio	Cobertura ampla por julgamento humano
Custo	Baixo (assinatura de ferramenta)	Alto (horas de especialista)
Frequência ideal	Contínua/semanal	Trimestral ou anual (ou contínua via PTaaS)
Compliance	Atende quando exigência é "vulnerability assessment"	Atende quando exigência é "penetration test"

BLOCO 3 — Análise detalhada

Quando análise de vulnerabilidade resolve

Quando o objetivo é manter visibilidade contínua sobre falhas conhecidas em um inventário grande de ativos. Scan semanal de mil servidores, monitoramento de CVEs em containers em produção, varredura de configurações em ambientes cloud. Para esse propósito, scanner automatizado é o caminho certo.

Quando só pentest resolve

Quando o objetivo é validar segurança real de aplicação ou ambiente crítico. Identificar IDOR em API de fintech, validar lógica de negócio de checkout em e-commerce, comprovar que uma aplicação resiste a atacante motivado. Aqui scanner não substitui pentest, e a tentativa de fazer isso costuma terminar em incidente.

A combinação certa

Para a maioria das empresas, a combinação ideal é análise de vulnerabilidade contínua (scanner em CI/CD e em produção) + pentest periódico em ativos críticos. Os dois cobrem ângulos diferentes do problema.

Para entender quando contratar pentest, veja [o que é pentest](#). Para conhecer o serviço, [pentest web](#) ou [pentest API](#).

CTA FINAL

Ainda em dúvida sobre qual escolher?

Conversamos com você em 30 minutos e indicamos o caminho mais adequado ao seu cenário, sem empurrar serviço desnecessário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest vs Red Team

URL completa: <https://firstsecurity.com.br/comparativos/pentest-vs-red-team>

HERO

Pentest vs Red Team: qual é a diferença real

Pentest é exercício de identificação de vulnerabilidades em escopo fechado, com cobertura ampla de falhas. Red Team é exercício adversarial com objetivo definido, escopo aberto (tecnologia + pessoas + processos) e foco em medir capacidade defensiva. Pentest entrega lista de problemas; Red Team entrega narrativa de comprometimento e maturidade defensiva mensurada.

BLOCO 2 — Tabela

Tabela comparativa

Aspecto	Pentest	Red Team
Objetivo	Encontrar máximo de vulnerabilidades	Atingir objetivos definidos como adversário
Escopo	Ativo bem delimitado (app, API, AD)	Amplo (tech + pessoas + processos)
Duração típica	1-4 semanas	6-10 semanas
Time defensivo é avisado?	Sim	Não (apenas a white cell sabe)
Ênfase	Cobertura de falhas	Profundidade de cenário e detecção
Métrica principal	Número e criticidade de achados	Objetivos atingidos + MTTR/MTTD defensivo
Custo relativo	Médio	Alto

BLOCO 3 — Quando contratar cada um

Quando pentest é a escolha certa

- Você quer validar segurança de uma aplicação específica antes do lançamento.
- Você está em ciclo de auditoria que exige pentest formal.
- Você quer cobertura ampla de vulnerabilidades em escopo claro.
- Sua empresa ainda não tem Blue Team maduro o suficiente para se beneficiar de Red Team.

Quando Red Team é a escolha certa

- Você já tem Blue Team funcional e quer testar de verdade.
- Você quer simular um cenário específico (ransomware, insider threat).
- Sua diretoria precisa de evidência de maturidade defensiva.
- Você está em exigência regulatória pesada ou alta exposição.

A regra prática que usamos com clientes

Se a sua empresa nunca contratou nenhum dos dois, comece por pentest. Se a sua empresa já fez vários pentests e tem Blue Team maduro, evolua para Red Team. Se quer combinar os dois com aprendizado contínuo, contrate Purple Team.

Veja também [Red Team em cibersegurança](#) (página pilar), [serviço de Red Team](#) e [Purple Team](#).

CTA FINAL

Ainda em dúvida sobre qual escolher?

Conversamos com você em 30 minutos e indicamos o caminho mais adequado ao seu cenário, sem empurrar serviço desnecessário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

PTaaS vs Pentest Tradicional

URL completa: <https://firstsecurity.com.br/comparativos/ptaas-vs-pentest-tradicional>

HERO

PTaaS vs Pentest Tradicional: qual modelo serve para sua empresa

Pentest tradicional é modelo de projeto fechado: escopo definido, prazo curto, relatório PDF. PTaaS (Pentest as a Service) é modelo recorrente: plataforma, retestes ilimitados, integração com CI/CD, achados em tempo real. PTaaS é melhor para SaaS e ambientes em release contínuo; pentest tradicional segue insubstituível para auditorias formais e escopos fechados.

BLOCO 2 — Tabela

Tabela comparativa

Aspecto	Pentest Tradicional	PTaaS
Modelo comercial	Projeto fechado	Assinatura recorrente
Entrega	Relatório PDF ao final	Achados em tempo real na plataforma
Retestes	Incluídos uma vez	Ilimitados durante o contrato
Integração CI/CD	Não	Sim
Cobertura temporal	Snapshot do momento do teste	Contínua ao longo do contrato
Ideal para	Auditoria, escopo fechado, anual	SaaS, release contínuo, DevSecOps

BLOCO 3 — Quando faz sentido cada um

Quando contratar pentest tradicional

- Empresa com ciclo de release lento.
- Necessidade de relatório formal para auditor uma vez por ano.
- Ativo crítico bem delimitado.
- Orçamento concentrado em uma janela.

Quando contratar PTaaS

- SaaS B2B com release semanal ou mensal.
- Equipe de produto que quer integrar segurança no pipeline.
- Clientes corporativos que pedem evidência recorrente de segurança.
- Programa de segurança maduro.

Conheça o [serviço PTaaS da First Security](#).

Ainda em dúvida sobre qual escolher?

Conversamos com você em 30 minutos e indicamos o caminho mais adequado ao seu cenário, sem empurrar serviço desnecessário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Pentest vs Bug Bounty

URL completa: <https://firstsecurity.com.br/comparativos/pentest-vs-bug-bounty>

HERO

Pentest vs Bug Bounty: complemento ou alternativa

Pentest é exercício contratado, com escopo, prazo, equipe definida e cobertura garantida. Bug Bounty é programa público em que pesquisadores externos reportam vulnerabilidades em troca de recompensa, sem garantia de cobertura. São práticas complementares: bug bounty cobre o tempo entre pentests, mas não substitui pentest formal para compliance ou para garantir cobertura sistemática.

BLOCO 2 — Tabela

Tabela comparativa

Aspecto	Pentest	Bug Bounty
Modelo	Serviço contratado	Programa público de recompensa
Garantia de cobertura	Sim (escopo definido)	Não
Prazo	Fixo	Indeterminado
Custo	Previsível por escopo	Variável (depende de achados)
Aceito em compliance	Sim (PCI DSS, ISO, SOC 2, BACEN)	Geralmente não substitui pentest formal
Profundidade	Alta (especialista dedicado)	Depende dos pesquisadores ativos

BLOCO 3 — A relação ideal

Como pentest e bug bounty se complementam

Pentest dá cobertura sistemática em momentos específicos. Bug Bounty mantém pressão contínua entre pentests. A empresa madura usa os dois: pentest formal para auditoria e cobertura garantida; bug bounty para captar achados que escapam ao escopo do pentest e para manter a pressão adversarial constante.

CTA FINAL

Ainda em dúvida sobre qual escolher?

Conversamos com você em 30 minutos e indicamos o caminho mais adequado ao seu cenário, sem empurrar serviço desnecessário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Red Team vs Purple Team

URL completa: <https://firstsecurity.com.br/comparativos/red-team-vs-purple-team>

HERO

Red Team vs Purple Team: adversário escondido ou exercício colaborativo

Red Team em cibersegurança opera como adversário escondido, sem avisar o time defensivo, para medir reação real. Purple Team opera lado a lado com o time defensivo, em ciclos colaborativos, para evoluir a detecção de forma mensurável. Red Team responde "o que aconteceu se nos atacarem?"; Purple Team responde "como ficamos melhores?".

BLOCO 2 — Tabela

Tabela comparativa

Aspecto	Red Team	Purple Team
Modo	Adversarial escondido	Colaborativo aberto
Time defensivo sabe?	Não	Sim
Foco	Medir capacidade real	Evoluir detecção
Métrica	Objetivos atingidos + MTTD	Cobertura por técnica MITRE evoluída
Frequência	Anual ou semestral	Contínuo (ciclos curtos)
Quando contratar	Validar maturidade	Quando há SOC para evoluir

BLOCO 3 — A sequência ideal

A sequência saudável: Red Team primeiro, Purple Team depois

A sequência mais produtiva costuma ser: faça um Red Team para medir maturidade defensiva real, depois entre em ciclos contínuos de Purple Team para evoluir o que ficou aquém. Em alguns cenários (Blue Team em estágio inicial), começar direto por Purple Team é mais útil.

CTA FINAL

Ainda em dúvida sobre qual escolher?

Conversamos com você em 30 minutos e indicamos o caminho mais adequado ao seu cenário, sem empurrar serviço desnecessário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Pentest vs Auditoria de Segurança

URL completa: <https://firstsecurity.com.br/comparativos/pentest-vs-auditoria>

HERO

Pentest vs Auditoria de Segurança: o que cada um responde

Auditoria de segurança verifica conformidade: a empresa tem os controles que deveria? Eles estão documentados e operam como planejado? Pentest valida eficácia técnica: os controles realmente resistem a ataque? Auditor olha papel, pentester olha sistema. Os dois compõem o conjunto mínimo para uma certificação séria (ISO 27001, SOC 2, PCI DSS).

BLOCO 2 — Tabela

Tabela comparativa

Aspecto	Auditoria	Pentest
Pergunta	Os controles existem e são documentados?	Os controles funcionam contra ataque?
Evidência principal	Documentos, processos, amostras	Exploração técnica reproduzível
Quem faz	Auditor certificado (ISO, QSA, CPA)	Pentester profissional (OSCP, OSWE)
Entregável	Relatório de não-conformidades	Relatório de vulnerabilidades exploráveis
Cobertura	Ampla (todo o programa)	Profunda em ativos definidos

BLOCO 3 — A combinação obrigatória

Por que você precisa dos dois para a maioria das normas

PCI DSS, ISO 27001, SOC 2 e BACEN exigem auditoria E pentest. São verificações complementares. Auditoria responde se a empresa tem programa de segurança; pentest responde se o programa funciona contra atacante real.

Veja como nosso [relatório se integra à auditoria](#).

CTA FINAL

Ainda em dúvida sobre qual escolher?

Conversamos com você em 30 minutos e indicamos o caminho mais adequado ao seu cenário, sem empurrar serviço desnecessário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Black Box vs White Box vs Grey Box

URL completa: <https://firstsecurity.com.br/comparativos/black-box-vs-white-box-vs-grey-box>

HERO

Black Box vs White Box vs Grey Box: qual modalidade contratar

A modalidade de pentest define quanto conhecimento prévio o testador recebe. Black box simula atacante externo sem informação. White box dá ao testador credenciais, documentação e código. Grey box é o meio termo: informação parcial, como usuário comum ou parceiro. Cada modalidade entrega resultados diferentes para o mesmo orçamento.

BLOCO 2 — Tabela

Tabela comparativa

Aspecto	Black Box	White Box	Grey Box
Informação prévia	Nenhuma	Completa (creds, docs, código)	Parcial
Realismo	Alto (atacante externo)	Baixo (insider técnico)	Médio
Profundidade no mesmo tempo	Baixa (reconhecimento gasta tempo)	Alta	Média
Tempo necessário	Maior	Menor	Intermediário
Custo relativo	Alto	Baixo	Médio
Quando faz sentido	Simular adversário externo, validar perímetro	Janela curta, ativo crítico	Maioria dos casos

BLOCO 3 — Análise por cenário

Recomendação por cenário

- **Pentest anual de aplicação web pública:** grey box (testador como usuário comum).
- **Pentest pré-lançamento de API crítica:** white box (cobertura máxima em prazo curto).
- **Pentest externo de perímetro:** black box (simula atacante real).
- **Validação de Active Directory:** grey box (assumed breach, acesso de usuário comum).
- **Pentest mobile:** white box (cobertura completa do app).

BLOCO 4 — Falsa dicotomia

Por que "qual é melhor" é a pergunta errada

Não existe modalidade superior em absoluto. A escolha certa depende do objetivo do teste. White box dá mais cobertura no mesmo tempo, mas perde o realismo. Black box é realista, mas consome

boa parte do prazo em reconhecimento. Grey box equilibra os dois. Definir a modalidade certa é parte do trabalho do orçamento, não decisão isolada do cliente.

CTA FINAL

Ainda em dúvida sobre qual escolher?

Conversamos com você em 30 minutos e indicamos o caminho mais adequado ao seu cenário, sem empurrar serviço desnecessário.

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Parte 8. Páginas de Compliance Regulatório

Pentest é exigido ou pressuposto por inúmeras normas. Cada página abaixo trata de uma norma específica, com o que ela exige, como o pentest se encaixa e como o relatório da First Security responde à demanda do auditor. Padrão: definição da norma + exigência específica sobre pentest + como atendemos + FAQ + CTA.

PÁGINA • /compliance

Hub de Compliance

URL completa: <https://firstsecurity.com.br/compliance>

HERO

Pentest e compliance regulatório

Sete normas concentram a maioria das exigências de pentest em empresas brasileiras: LGPD, PCI DSS, ISO 27001, BACEN 4.893, SOC 2, NIST CSF e HIPAA. A First Security entrega relatórios estruturados para responder o que cada auditor pede, sem retrabalho.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de pentest para compliance → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Normas atendidas (cards)

Normas que atendemos com profundidade

- [LGPD](#) • Lei Geral de Proteção de Dados (Brasil)
- [PCI DSS](#) • Payment Card Industry Data Security Standard
- [ISO 27001](#) • Sistema de Gestão de Segurança da Informação
- [BACEN](#) • Resolução BACEN 4.893 (instituições financeiras)
- [SOC 2](#) • Service Organization Control 2
- [NIST CSF](#) • NIST Cybersecurity Framework
- [HIPAA](#) • Saúde nos EUA, referência para healthtechs brasileiras

CTA FINAL

Quer pentest para compliance?

A First Security entrega relatório aceito por auditores e por reguladores. Conheça o escopo ideal para compliance em uma reunião de descoberta.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para LGPD

URL completa: <https://firstsecurity.com.br/compliance/pentest-lgpd>

HERO

Pentest para conformidade com a LGPD

A Lei Geral de Proteção de Dados (Lei 13.709/2018) exige que controladores e operadores adotem medidas de segurança "aptas a proteger dados pessoais de acessos não autorizados". Pentest é o instrumento técnico mais reconhecido para demonstrar essa adoção diante da ANPD. A First Security entrega pentest com relatório executivo escrito para encarregados de proteção de dados (DPOs) e diretoria.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de pentest para compliance → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — O que a LGPD pede

O que a LGPD exige em segurança técnica

O artigo 46 da LGPD determina que agentes de tratamento devem adotar "medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito".

A ANPD, em guias publicados, sinaliza pentest como evidência razoável de cumprimento. Em fiscalizações, ter relatório recente de pentest reduz substancialmente o risco de sanção.

BLOCO 3 — Como atendemos

Como o pentest da First Security atende LGPD

- Foco em fluxos que envolvem dado pessoal (cadastro, autenticação, gestão de conta, exportação de dados).
- Análise específica de dados sensíveis (saúde, financeiro, biométrico) e fluxos de criança/adolescente.
- Validação de cumprimento de direitos do titular (anonimização, eliminação, portabilidade).
- Avaliação de criptografia em trânsito e em repouso.
- Relatório com seção específica para o DPO.
- Documentação adequada para uso em DPIA (Data Protection Impact Assessment) e em comunicação com a ANPD em caso de incidente.

BLOCO 4 — FAQ

Perguntas frequentes

A LGPD exige pentest explicitamente?

Não usa a palavra "pentest", mas exige medidas técnicas adequadas. Pentest é o caminho mais direto para demonstrar essa adequação diante da ANPD.

Com que frequência fazer?

No mínimo anualmente e sempre após mudança significativa de arquitetura. Empresas com tratamento de dado sensível em escala devem considerar pentest semestral ou PTaaS contínuo.

O relatório serve para a ANPD em caso de incidente?

Sim. Relatório recente é evidência forte de boa-fé e de cumprimento do dever de cuidado.

CTA FINAL

Quer pentest para LGPD?

A First Security entrega relatório aceito por auditores e por reguladores. Conheça o escopo ideal para LGPD em uma reunião de descoberta.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para PCI DSS

URL completa: <https://firstsecurity.com.br/compliance/pentest-pci-dss>

HERO

Pentest para conformidade com PCI DSS

PCI DSS é a norma que rege segurança de dados de cartão de pagamento. O Requisito 11.4 (versão 4.0) exige pentest anual e após mudança significativa em sistemas no escopo. A First Security entrega pentest com relatório aceito por QSAs e validado em programas de empresas brasileiras de e-commerce, adquirência e fintechs.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de pentest para compliance → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — O que pede

O que o PCI DSS exige em pentest

- Requisito 11.4.1: política de pentest documentada.
- Requisito 11.4.2: pentest externo anualmente e após mudança significativa.
- Requisito 11.4.3: pentest interno anualmente e após mudança significativa.
- Requisito 11.4.4: correção de vulnerabilidades exploráveis e retest.
- Requisito 11.4.5: pentest de segmentação para empresas que segmentam o ambiente CDE (Cardholder Data Environment).

BLOCO 3 — Como atendemos

Como a First Security cobre o requisito

Nosso pentest para PCI DSS é estruturado em cinco frentes: externo, interno, web/API, segmentação e wireless quando aplicável. O relatório vem com a numeração dos requisitos atendidos para facilitar o trabalho do QSA.

CTA FINAL

Quer pentest para PCI DSS?

A First Security entrega relatório aceito por auditores e por reguladores. Conheça o escopo ideal para PCI DSS em uma reunião de descoberta.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para ISO 27001

URL completa: <https://firstsecurity.com.br/compliance/pentest-iso-27001>

HERO

Pentest para conformidade com ISO/IEC 27001

A ISO 27001 estabelece o Sistema de Gestão de Segurança da Informação. O Anexo A inclui controle específico (A.12.6.1 na 2013, equivalente na 2022) sobre gestão de vulnerabilidades técnicas, do qual pentest é evidência central. A First Security entrega pentest com relatório que se integra ao seu SoA (Statement of Applicability) e ao programa de melhoria contínua.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de pentest para compliance → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Cobertura

Quais controles do Anexo A o pentest evidencia

- A.5.7 (Threat Intelligence) parcial.
- A.5.30 (ICT Readiness for Business Continuity) parcial.
- A.8.7 (Protection against malware).
- A.8.8 (Management of technical vulnerabilities), central.
- A.8.9 (Configuration management).
- A.8.20 (Network security).
- A.8.23 (Web filtering).
- A.8.25 (Secure development life cycle).
- A.8.29 (Security testing in development and acceptance), central.

NOTA EDITORIAL: Numeração baseada na ISO 27001:2022. Ajustar para 2013 quando aplicável.

CTA FINAL

Quer pentest para ISO 27001?

A First Security entrega relatório aceito por auditores e por reguladores. Conheça o escopo ideal para ISO 27001 em uma reunião de descoberta.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para BACEN

URL completa: <https://firstsecurity.com.br/compliance/pentest-bacen>

HERO

Pentest para conformidade com a Resolução BACEN 4.893

A Resolução BACEN 4.893/2021 dispõe sobre política de segurança cibernética em instituições financeiras autorizadas pelo Banco Central. O artigo 3º exige programa de gestão de riscos cibernéticos, com testes de intrusão como componente. A First Security entrega pentest com relatório aderente ao que a área de risco da instituição precisa para reportar ao BACEN.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de pentest para compliance → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — O que pede

Pontos da Resolução 4.893 que pentest atende

- Artigo 3º, IX: testes regulares dos controles de segurança cibernética.
- Artigo 4º: tratamento de incidentes (pentest reduz exposição e melhora playbook).
- Artigo 6º: prevenção e detecção de incidentes.
- Artigo 14: arranjos contratuais com prestadores relevantes (pentest valida segurança de integração).

BLOCO 3 — Cobertura típica em fintech BACEN

Cobertura típica em fintech ou banco

- Aplicação web e mobile do banco/fintech (cliente final).
- API que sustenta open finance, PIX e operações em geral.
- Active Directory e identidade interna.
- Ambiente cloud (AWS/Azure/GCP).
- Perímetro externo e segmentação interna.

CTA FINAL

Quer pentest para BACEN?

A First Security entrega relatório aceito por auditores e por reguladores. Conheça o escopo ideal para BACEN em uma reunião de descoberta.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para SOC 2

URL completa: <https://firstsecurity.com.br/compliance/pentest-soc-2>

HERO

Pentest para conformidade com SOC 2

SOC 2 é o relatório de controles para empresas de tecnologia que processam dados de clientes corporativos, especialmente SaaS. Os Trust Services Criteria CC4.1 e CC7.1 pressupõem pentest como evidência. A First Security entrega pentest aceito por auditores SOC 2 (CPAs licenciados) nos Estados Unidos e no Brasil, com relatório em inglês quando o ciclo de auditoria pede.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de pentest para compliance → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Tipos de SOC 2

SOC 2 Type 1 e Type 2

SOC 2 Type 1 avalia o design dos controles em um ponto no tempo. Type 2 avalia o desenho e a operação dos controles ao longo de um período (tipicamente seis a doze meses). Pentest é evidência para os dois, mas é especialmente relevante em Type 2, onde o auditor verifica se o programa funciona ao longo do tempo.

BLOCO 3 — Diferencial First Security

Por que startups SaaS brasileiras escolhem a First Security

- Relatório bilíngue (PT-BR e EN) sem custo extra.
- Equipe acostumada a trabalhar com firmas de auditoria americanas (Big4 e mid-tier).
- Cobertura completa de Trust Services Criteria.
- Atendimento ao calendário rígido do SOC 2 (janelas de evidência).

CTA FINAL

Quer pentest para SOC 2?

A First Security entrega relatório aceito por auditores e por reguladores. Conheça o escopo ideal para SOC 2 em uma reunião de descoberta.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para NIST CSF

URL completa: <https://firstsecurity.com.br/compliance/pentest-nist-csf>

HERO

Pentest para alinhamento com NIST CSF

O NIST Cybersecurity Framework não é regulação, é estrutura de referência adotada por empresas de todo o mundo para organizar programa de segurança em cinco funções (Identify, Protect, Detect, Respond, Recover). Pentest contribui especialmente para Identify e Detect. A First Security entrega pentest com mapeamento direto para as subcategorias relevantes do CSF, facilitando uso em programas internos.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de pentest para compliance → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Cobertura por função

Como pentest se mapeia ao NIST CSF

Identify (ID)

- ID.RA-1: vulnerabilidades de ativos identificadas.
- ID.RA-3: ameaças, internas e externas, identificadas.
- ID.SC-4: avaliação de fornecedores.

Protect (PR)

- PR.AC-1, PR.AC-3, PR.AC-4: validação de controles de acesso.
- PR.DS-1, PR.DS-2: validação de proteção de dados em repouso e em trânsito.

Detect (DE)

- DE.CM-1, DE.CM-8: validação de capacidade de detecção (especialmente em Purple Team).

CTA FINAL

Quer pentest para NIST CSF?

A First Security entrega relatório aceito por auditores e por reguladores. Conheça o escopo ideal para NIST CSF em uma reunião de descoberta.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para HIPAA

URL completa: <https://firstsecurity.com.br/compliance/pentest-hipaa>

HERO

Pentest para conformidade com HIPAA

HIPAA é a lei norte-americana de privacidade de dados de saúde. Healthtechs brasileiras que vendem para os Estados Unidos, processam dados de pacientes americanos ou se integram a EHR/PHR de provedores nos EUA precisam estar em conformidade. O HIPAA Security Rule exige avaliação de risco e medidas técnicas, do qual pentest é evidência reconhecida. A First Security entrega pentest com relatório aceito por auditores HIPAA.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento de pentest para compliance → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Cobertura

O que o pentest cobre para HIPAA

- Proteção de ePHI (electronic Protected Health Information) em aplicações, APIs e backend.
- Autenticação e autorização em sistemas que tratam ePHI.
- Criptografia em trânsito e em repouso.
- Audit logging suficiente para investigação.
- Validação de integração com provedores de saúde via HL7/FHIR.

BLOCO 3 — Combinação ideal

Combinação com outras normas

Healthtechs brasileiras quase sempre precisam combinar HIPAA com [LGPD](#). A First Security entrega cobertura combinada, com relatório que atende as duas em um único projeto.

CTA FINAL

Quer pentest para HIPAA?

A First Security entrega relatório aceito por auditores e por reguladores. Conheça o escopo ideal para HIPAA em uma reunião de descoberta.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Parte 9. Páginas Verticais (segmentos B2B)

Cada vertical reúne riscos típicos, regulação aplicável e ofertas comerciais alinhadas. Padrão: hero contextualizado + riscos do setor + regulação relevante + escopo recomendado + cases + CTA. As 6 verticais principais (fintech, bancos, SaaS, e-commerce, healthtech, governo) trazem texto completo; as demais são listadas via tabela na página hub /segmentos.

PÁGINA • /segmentos

Hub de Segmentos B2B

URL completa: <https://firstsecurity.com.br/segmentos>

HERO

Cibersegurança ofensiva por setor

Cada setor tem riscos próprios, regulação própria e expectativas próprias de cliente final. A First Security desenha o pentest considerando essas particularidades. Encontre seu setor abaixo.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — Setores em destaque

Setores em destaque

- [Pentest para Fintechs](#) • BACEN, PCI DSS, LGPD, PIX, open finance
- [Pentest para Bancos](#) • Core banking, AD enterprise, internet banking
- [Pentest para SaaS B2B](#) • SOC 2, ISO 27001, multi-tenant, APIs
- [Pentest para E-commerce](#) • PCI DSS, checkout, sazonalidade, fraude
- [Pentest para Healthtech](#) • LGPD, HIPAA, prontuário, telemedicina
- [Pentest para Governo](#) • Lei 14.133, TCU, CGU, ANPD

BLOCO 3 — Demais setores atendidos

Demais setores que atendemos

A First Security trabalha com qualquer setor que tenha dado sensível ou alta exposição. Confira abaixo os principais setores adicionais.

Setor	Riscos típicos	Foco do pentest
Indústria 4.0	OT/IT convergente, IIoT	Pentest OT + segmentação + infraestrutura
Marketplace	Fraude, abuso de seller, APIs	Pentest web + API + antifraude
EdTech	Dado de menor de idade, LGPD	Pentest web + LGPD

	agravada	
LegalTech	Confidencialidade processual	Pentest web + cloud
AgTech	IoT em campo, integração com cooperativas	Pentest IoT + API
LogTech	Tracking, integração com transportadoras	Pentest mobile + API
Energia	OT crítica, regulação ANEEL	Pentest OT/SCADA + infraestrutura
Telecom	Redes complexas, exposição massiva	Pentest infraestrutura + cloud
Seguros	Dado sensível, fraude	Pentest web + API + LGPD
Educação superior	Dado de aluno, pesquisa	Pentest web + LGPD
Mineração e óleo/gás	OT crítica, ambiente remoto	Pentest OT + infraestrutura

[SEM CTA / SEM FORMULÁRIO] Setores adicionais com tabela. Se a empresa estiver em um deles, conversamos no orçamento e adaptamos o escopo.

CTA FINAL

Pentest pensado para seu setor

A First Security entende as particularidades do setor de seu setor. Em uma conversa de descoberta, mapeamos o escopo ideal para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para Fintechs

URL completa: <https://firstsecurity.com.br/segmentos/pentest-fintech>

HERO

Pentest para Fintechs (BACEN, PIX, open finance)

Fintechs operam sob regulação BACEN, frequentemente sob PCI DSS, integradas a PIX, open finance e arranjos de pagamento. A superfície de ataque combina aplicação cliente, APIs críticas, ambiente cloud em grande escala e integrações com SPB. A First Security tem método dedicado para fintechs, com cobertura combinada de Web + API + Cloud + Active Directory e relatórios aceitos por BACEN e QSAs.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Riscos típicos

Riscos típicos em fintechs

- IDOR e BOLA em APIs que servem múltiplos clientes (tenant isolation).
- Abuso de fluxo PIX (devolução, cobrança, agendamento).
- Exposição em integração com Bacen Jud e outros sistemas governamentais.
- Vazamento de dados de cartão em logs ou cache mal configurado.
- Bypass de antifraude em onboarding e em transação.
- Permissão excessiva em IAM da cloud que sustenta a infraestrutura.

BLOCO 3 — Regulação aplicável

Regulação que se aplica

- [BACEN 4.893](#)
- [PCI DSS](#) para fluxo de cartão
- [LGPD](#)
- Circulares específicas BACEN sobre PIX, open finance, lavagem de dinheiro
- [SOC 2](#) para fintechs SaaS B2B

BLOCO 4 — Escopo recomendado

Escopo recomendado para fintechs

- [Pentest Web](#) do internet banking ou app de gestão
- [Pentest Mobile](#) do app cliente
- [Pentest API](#) para o core da fintech

- [Pentest Cloud](#) do ambiente AWS/GCP/Azure
- [Pentest Active Directory](#) se houver AD corporativo
- [PTaaS](#) para release contínuo

CTA FINAL

Pentest pensado para fintechs

A First Security entende as particularidades do setor de fintechs. Em uma conversa de descoberta, mapeamos o escopo ideal para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para Bancos

URL completa: <https://firstsecurity.com.br/segmentos/pentest-bancos>

HERO

Pentest para bancos (digitais e tradicionais)

Bancos são alvos premium em cibersegurança. Combinam superfície enorme (internet banking, mobile, ATM, núcleo bancário, redes de agências), regulação pesada (BACEN, Banco Central, CMN) e adversários sofisticados. A First Security atende bancos digitais e tradicionais com programa dedicado, equipe sênior alocada e cobertura combinada de aplicação, infraestrutura, AD enterprise e Red Team.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Particularidades

Particularidades de bancos

- Active Directory corporativo extenso, foco preferido de ransomware.
- Integração com SPB, SELIC, CIP e demais sistemas centrais.
- Ambiente de agências físicas com endpoints e impressoras em rede.
- Mainframe e sistemas legados ainda presentes em bancos tradicionais.
- Adversários organizados e persistentes.

BLOCO 3 — Programa recomendado

Programa de pentest recomendado para banco

Bancos se beneficiam de programa anual com múltiplos exercícios.

- Pentest contínuo de canais cliente (internet banking, mobile, API).
- [Pentest AD](#) anual.
- [Red Team](#) anual.
- [Purple Team](#) em ciclos trimestrais para evolução do SOC.
- [Engenharia social](#) semestral.

CTA FINAL

Pentest pensado para bancos

A First Security entende as particularidades do setor de bancos. Em uma conversa de descoberta, mapeamos o escopo ideal para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para SaaS B2B

URL completa: <https://firstsecurity.com.br/segmentos/pentest-saas>

HERO

Pentest para SaaS B2B (SOC 2, ISO 27001, multi-tenant)

Vender SaaS B2B é vender confiança. Cada cliente corporativo passa o seu SaaS por questionários de segurança que exigem evidência de pentest recente. SOC 2 e ISO 27001 viraram régua de mercado. A First Security entende essa dinâmica e entrega pentest pensado para SaaS, com cobertura de isolamento entre tenants, IAM granular e relatório aceito por compradores em diligência.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — Riscos típicos

Riscos típicos em SaaS B2B

- Quebra de isolamento entre tenants (cross-tenant access).
- IDOR em recursos compartilhados ou em endpoints administrativos.
- Escalada de privilégio dentro do tenant (de viewer para admin).
- Abuso de integração SSO/SAML.
- Exposição de webhook ou de eventos para tenant errado.
- SSRF em integração com APIs externas configuradas pelo cliente.

BLOCO 3 — Compliance prioritária

Compliance prioritária para SaaS B2B

- [SOC 2](#)
- [ISO 27001](#)
- [LGPD](#)
- [NIST CSF](#) (referência para clientes corporativos)

BLOCO 4 — PTaaS é o caminho

Por que SaaS combina mais com PTaaS

SaaS que faz release semanal ou mensal não consegue suportar pentest anual e ficar 11 meses sem cobertura. O modelo certo é [PTaaS](#), com cobertura contínua, retestes ilimitados e integração com CI/CD.

CTA FINAL

Pentest pensado para SaaS B2B

A First Security entende as particularidades do setor de SaaS B2B. Em uma conversa de descoberta, mapeamos o escopo ideal para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para E-commerce

URL completa: <https://firstsecurity.com.br/segmentos/pentest-e-commerce>

HERO

Pentest para E-commerce (PCI DSS, checkout, sazonalidade)

E-commerce processa cartão (PCI DSS obrigatório), atrai fraude organizada e enfrenta picos sazonais (Black Friday, Cyber Monday, Natal). A First Security entrega pentest com cobertura completa do funil (catálogo, carrinho, checkout, pós-venda), integração com gateways e antifraude. Modelo PTaaS recomendado para grandes operações com release contínua.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — Riscos típicos

Riscos típicos em e-commerce

- Compra com cartão alheio (BIN scraping, testagem em ambiente vulnerável).
- Bypass de cupom ou de promoção (price manipulation).
- IDOR em pedido, em endereço, em meio de pagamento salvo.
- Exposição de PAN em logs ou em integração mal configurada.
- Bypass de antifraude em checkout.
- SQL injection em busca interna do catálogo.

BLOCO 3 — Janela

Janela ideal para o pentest

E-commerces brasileiros típicos contratam pentest dois a três meses antes da Black Friday. Isso dá folga para correção e reteste sem disputar com a operação no pico.

CTA FINAL

Pentest pensado para e-commerce

A First Security entende as particularidades do setor de e-commerce. Em uma conversa de descoberta, mapeamos o escopo ideal para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Agendar conversa → </agendar-conversa>

Pentest para Healthtech

URL completa: <https://firstsecurity.com.br/segmentos/pentest-healthtech>

HERO

Pentest para Healthtech (LGPD, HIPAA, telemedicina)

Healthtech trata dado sensível por definição (saúde). Sob LGPD, dado sensível tem proteção agravada. Quando a empresa vende para os Estados Unidos, HIPAA entra. Telemedicina, prontuário eletrônico, integração com operadoras e laboratórios complicam a equação. A First Security tem método dedicado para o setor, com cobertura combinada de LGPD + HIPAA + integrações HL7/FHIR.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Riscos típicos

Riscos típicos em healthtech

- Vazamento de prontuário em IDOR ou em endpoint mal protegido.
- Acesso indevido a videochamada de telemedicina (URL adivinhável).
- Exposição em integração com operadoras (planos de saúde).
- Vazamento de exame em integração com laboratório.
- Captura de áudio de teleconsulta por falha em WebRTC.

BLOCO 3 — Compliance prioritária

Compliance prioritária

- [LGPD](#) com tratamento de dado sensível
- [HIPAA](#) para empresas com cliente americano
- Regulação CFM e ANS quando aplicável

CTA FINAL

Pentest pensado para healthtech

A First Security entende as particularidades do setor de healthtech. Em uma conversa de descoberta, mapeamos o escopo ideal para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest para Governo

URL completa: <https://firstsecurity.com.br/segmentos/pentest-governo>

HERO

Pentest para órgãos públicos e governo

Órgãos públicos federais, estaduais e municipais, autarquias, fundações e empresas estatais têm exigência crescente de cibersegurança. A First Security atende contratação pública via Lei 14.133, com proposta técnica formal e aderência aos requisitos de TCU, CGU e ANPD. Equipe brasileira, contratação em real, dados em território nacional.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Particularidades

Particularidades de contratação pública

- Lei 14.133/2021 como marco regulatório.
- Possibilidade de contratação por inexigibilidade quando justificável tecnicamente.
- Exigências de TCU sobre segurança da informação em órgãos federais.
- Atendimento à LGPD com regime especial para órgãos públicos.
- Requisitos de soberania de dados em determinados contextos.

BLOCO 3 — Cobertura típica

Cobertura típica em órgão público

- Portais e sistemas externos expostos ao cidadão.
- Sistemas administrativos internos.
- Integração com gov.br e barramentos federais.
- Ambiente de datacenter próprio ou nuvem soberana.

CTA FINAL

Pentest pensado para governo

A First Security entende as particularidades do setor de governo. Em uma conversa de descoberta, mapeamos o escopo ideal para o seu cenário.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Parte 10. Páginas Geográficas (Onde Atendemos)

Páginas geográficas atendem a busca local ("pentest em [cidade]") e ajudam a empresa a fechar presença regional. Padrão: hero contextualizado para a praça + ecossistema local + setores predominantes + atendimento (presencial/remoto) + cases regionais + CTA. As 4 praças prioritárias (SP, RJ, MG, DF) trazem texto completo; Goiânia tem texto especial por ser sede; as demais são listadas via tabela.

PÁGINA • /onde-atendemos

Onde atendemos no Brasil

URL completa: <https://firstsecurity.com.br/onde-atendemos>

HERO

Atendimento em todo o Brasil, presencial nas praças principais

A First Security trabalha remotamente em qualquer cidade do Brasil. Nas praças principais (SP, RJ, MG, DF, RS, PR, SC, PE, CE, BA, GO), atendemos também presencialmente. O atendimento presencial faz diferença em reuniões com diretoria, em validação de controles físicos e em projetos de Red Team com componente in-situ.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → </orcamento>

Secundário: Falar com especialista → </agendar-conversa>

BLOCO 2 — Mapa interativo

Praças com atendimento presencial

- [Pentest em São Paulo](#)
- [Pentest no Rio de Janeiro](#)
- [Pentest em Belo Horizonte e Minas Gerais](#)
- [Pentest em Brasília e Distrito Federal](#)
- [Pentest em Porto Alegre e Rio Grande do Sul](#)
- [Pentest em Curitiba e Paraná](#)
- [Pentest em Florianópolis e Santa Catarina](#)
- [Pentest em Recife e Pernambuco](#)
- [Pentest em Fortaleza e Ceará](#)
- [Pentest em Salvador e Bahia](#)
- [Pentest em Goiânia e Goiás \(sede\)](#)

BLOCO 3 — Demais estados

Demais estados atendidos remotamente

Em qualquer estado do Brasil, atendemos remotamente com a mesma qualidade. Eventualmente, deslocamos especialistas para reuniões críticas ou validações presenciais.

Estado	Atendimento	Quando faz sentido presencial
Espírito Santo	Remoto	Reunião de fechamento ou validação física
Mato Grosso	Remoto	Projetos OT em agronegócio
Mato Grosso do Sul	Remoto	Idem
Pará	Remoto	OT em mineração e energia
Amazonas	Remoto	Polo industrial de Manaus
Demais estados	Remoto	Sob demanda

CTA FINAL

Pentest profissional para empresas em todo o Brasil

A First Security atende presencial e remotamente em todo o Brasil. Em uma conversa de descoberta, conhecemos seu cenário e propomos o escopo certo.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest em São Paulo

URL completa: <https://firstsecurity.com.br/onde-atendemos/sao-paulo>

HERO

Pentest profissional em São Paulo

São Paulo concentra a maior densidade de fintechs, bancos, SaaS B2B, healthtechs e grandes empresas do país. A First Security atende presencial em SP capital e região metropolitana com regularidade semanal. Equipe pronta para reuniões com diretorias na Faria Lima, na Berrini e na Paulista, com a mesma qualidade técnica do atendimento remoto.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Ecossistema

O que torna SP particular

São Paulo combina concentração de capital, regulação financeira intensa e ecossistema de tecnologia maduro. Empresas paulistanas costumam ser as primeiras a adotar SOC 2, ISO 27001, PCI DSS 4.0 e PTaaS. A First Security trabalha com esse perfil de cliente cotidianamente.

BLOCO 3 — Setores predominantes

Setores que mais atendemos em SP

- [Fintechs](#) • Faria Lima e região
- [SaaS B2B](#) • Itaim, Pinheiros, Berrini
- [Bancos](#) • Centro, Itaim, Vila Olímpia
- [Healthtechs](#) • Jardins, Pinheiros
- [E-commerce](#)

BLOCO 4 — Atendimento

Como funciona o atendimento em SP

Para projetos em São Paulo, mantemos disponibilidade semanal de reunião presencial nos eixos comerciais (Faria Lima, Itaim, Berrini, Vila Olímpia, Paulista, Brigadeiro, Centro). Sala segura para projetos de Red Team com necessidade de presença física pode ser providenciada em parceria com escritórios coworking premium.

CTA FINAL

Pentest profissional para empresas em São Paulo

A First Security atende presencial e remotamente em São Paulo. Em uma conversa de descoberta, conhecemos seu cenário e propomos o escopo certo.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest no Rio de Janeiro

URL completa: <https://firstsecurity.com.br/onde-atendemos/rio-de-janeiro>

HERO

Pentest profissional no Rio de Janeiro

Rio de Janeiro concentra setor de óleo e gás (Petrobras e cadeia), forte presença bancária histórica, telecom e empresas do governo federal. A First Security atende presencial no Rio com regularidade, com equipe disponível para reuniões na Cinelândia, Centro, Botafogo, Barra da Tijuca e Niterói.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Particularidades

O que torna o Rio particular em segurança

A presença de empresas estatais e do setor de energia adiciona camadas de OT/SCADA, regulação específica (ANP, ANEEL) e exigência de cibersegurança alinhada a programas federais. A First Security tem método dedicado para esse contexto.

BLOCO 3 — Setores predominantes

Setores em destaque no Rio

- Energia e óleo/gás (com Pentest OT/SCADA).
- Bancos tradicionais com matriz histórica.
- Telecom (sede de grandes operadoras).
- Empresas estatais e do setor público federal.

CTA FINAL

Pentest profissional para empresas em Rio de Janeiro

A First Security atende presencial e remotamente em Rio de Janeiro. Em uma conversa de descoberta, conhecemos seu cenário e propomos o escopo certo.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest em Minas Gerais

URL completa: <https://firstsecurity.com.br/onde-atendemos/minas-gerais>

HERO

Pentest profissional em Belo Horizonte e Minas Gerais

Minas Gerais combina ecossistema tech robusto em BH (com forte presença de fintechs e SaaS surgindo da Universidade Federal de Minas Gerais), mineração de classe mundial no interior (com forte componente OT) e indústria diversificada. A First Security atende presencial em Belo Horizonte e desloca equipe para projetos no interior.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Setores predominantes

Setores que atendemos em Minas

- Fintechs e SaaS B2B em BH.
- Mineração (com pentest OT em ambiente industrial).
- Siderurgia.
- Healthtechs.
- Cooperativas e empresas do agronegócio do Triângulo Mineiro.

CTA FINAL

Pentest profissional para empresas em Belo Horizonte e Minas Gerais

A First Security atende presencial e remotamente em Belo Horizonte e Minas Gerais. Em uma conversa de descoberta, conhecemos seu cenário e propomos o escopo certo.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest em Brasília e Distrito Federal

URL completa: <https://firstsecurity.com.br/onde-atendemos/distrito-federal>

HERO

Pentest profissional em Brasília

Brasília concentra órgãos federais, agências reguladoras, autarquias e estatais. A First Security tem equipe dedicada a atendimento ao setor público, com proposta técnica em formato compatível com Lei 14.133 e experiência de contratação por inexigibilidade quando aplicável.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Contratação pública

Contratação por órgãos públicos

A First Security está habilitada a ser fornecedora de órgãos públicos federais, estaduais e municipais. Atendemos a Lei 14.133/2021 e suas modalidades (dispensa, pregão, inexigibilidade). Proposta técnica detalhada disponível em até 5 dias úteis para processos formais.

BLOCO 3 — Setores

Quem atendemos em Brasília

- [Órgãos públicos federais](#)
- Agências reguladoras.
- Empresas estatais.
- Fintechs e SaaS B2B do ecossistema DF.
- Cooperativas de crédito.

CTA FINAL

Pentest profissional para empresas em Brasília

A First Security atende presencial e remotamente em Brasília. Em uma conversa de descoberta, conhecemos seu cenário e propomos o escopo certo.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Pentest em Goiânia e Goiás

URL completa: <https://firstsecurity.com.br/onde-atendemos/goias>

HERO

Pentest profissional em Goiânia (sede operacional First Security)

A First Security tem sede operacional em Goiânia, Goiás. A capital concentra ecossistema crescente de fintechs, SaaS B2B, healthtechs e startups apoiadas pela UFG e por programas estaduais. O interior do estado tem forte agronegócio com AgTechs em rápido crescimento. Como sede, atendemos com disponibilidade máxima na praça.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Falar com especialista → [/agendar-conversa](#)

BLOCO 2 — Por que estamos em Goiânia

Por que a First Security tem sede em Goiânia

Goiânia combina três fatores que fazem sentido para uma consultoria de cibersegurança: ecossistema técnico em crescimento (com talento formado em UFG, IFG e ecossistema startup), custo operacional mais competitivo que SP-RJ permitindo investimento maior em equipe e pesquisa, e posição central no Brasil que facilita atendimento em todas as regiões.

BLOCO 3 — Setores predominantes

Setores que atendemos em Goiás

- Fintechs do ecossistema Goiânia.
- AgTechs do agronegócio goiano (especialmente em Rio Verde e região).
- Healthtechs.
- Cooperativas (de crédito e agropecuárias).
- Indústrias instaladas em Anápolis e DAIA.
- Governo estadual e municipal.

BLOCO 4 — Atendimento

Atendimento em Goiânia

Por sermos sede, atendemos Goiânia com agilidade extra. Reuniões presenciais com 24 horas de antecedência, visita técnica para validação de controles físicos no mesmo dia em casos urgentes, equipe disponível para emergências em horário não comercial sob contrato.

CTA FINAL

Pentest profissional para empresas em Goiânia e Goiás

A First Security atende presencial e remotamente em Goiânia e Goiás. Em uma conversa de descoberta, conhecemos seu cenário e propomos o escopo certo.

[DOIS BOTÕES CTA lado a lado]

Primário: Solicitar orçamento → [/orcamento](#)

Secundário: Agendar conversa → [/agendar-conversa](#)

Parte 11. Blog: textos prontos e estrutura editorial

O blog é onde a First Security demonstra autoridade técnica fora das páginas comerciais. Posts não vendem diretamente, ensinam, esclarecem e dão ao leitor uma razão para confiar no fornecedor. Esta parte traz a estrutura editorial recomendada e três posts pilares completos, prontos para publicação.

PÁGINA • /blog

Hub do Blog

URL completa: <https://firstsecurity.com.br/blog>

HERO

Blog da First Security

Conteúdo técnico sobre pentest, Red Team, AI Red Teaming, compliance regulatório e gestão de risco em cibersegurança ofensiva. Escrito por quem está em campo, revisado pela liderança técnica, atualizado sempre que o cenário muda.

[SEM CTA / SEM FORMULÁRIO] Hero do hub. Os CTAs vêm a partir da listagem.

BLOCO 2 — Categorias

Categorias do blog

Organizamos o blog em sete categorias temáticas.

- [Fundamentos](#) • Conceitos básicos: o que é hacker ético, o que é pentest, glossário de termos.
- [Tipos de pentest](#) • Aprofundamentos por modalidade e escopo.
- [Carreira](#) • Como se tornar pentester, certificações, mercado.
- [Vulnerabilidades](#) • Aprofundamentos técnicos em classes de vulnerabilidade.
- [Compliance](#) • LGPD, PCI DSS, ISO 27001, BACEN, SOC 2, NIST.
- [Cloud Security](#) • AWS, Azure, GCP, particularidades por provedor.
- [IA e Segurança](#) • AI Red Teaming, OWASP Top 10 for LLM, segurança em agentes.

BLOCO 3 — Linha editorial

Linha editorial do blog

Cada post da First Security segue critérios firmes.

- Autor identificável com nome real e link para perfil.
- Revisor técnico nomeado.
- Data de publicação e data de última revisão visíveis.
- Conteúdo factualmente correto, com referência a fontes confiáveis.

- Sem rewriting de IA generalista; cada texto traz contribuição original.
- Mínimo de 1.500 palavras em posts pilares, mínimo de 800 em posts de profundidade média.
- Linkagem interna obrigatória para serviços, compliance e páginas pilares relevantes.

BLOCO 4 — Posts em destaque (listagem dinâmica)

Posts em destaque

Componente: listagem dinâmica via Content Collections do Astro, com filtro por categoria. Cada card mostra: categoria, título, resumo de duas linhas, autor e data.

[SEM CTA / SEM FORMULÁRIO] Bloco dinâmico. CTA final do hub do blog vem no próximo bloco.

BLOCO 5 — Newsletter (opcional)

Receba nosso conteúdo por email

Para quem quer receber os posts diretamente, mantemos uma newsletter quinzenal de cibersegurança ofensiva. Cobertura prática: o que aconteceu de relevante na quinzena, com leitura crítica da equipe da First Security.

[FORMULÁRIO] Inscrição na newsletter

Campos:

- Nome (texto, obrigatório)
- Email corporativo (email, obrigatório)
- Aceite LGPD (checkbox obrigatório com link para /legal/politica-de-privacidade)

Botão de envio: "Inscrever na newsletter"

NOTA EDITORIAL: Inscrição vai para CRM com tag "newsletter". Possibilidade de descadastro em todo email enviado, conforme exigência LGPD.

Hacker ético: o que faz, como atua, como se torna um

URL completa: <https://firstsecurity.com.br/blog/fundamentos/hacker-etico-o-que-faz>

HERO DO POST

Hacker ético: o que faz, como atua e como se torna um

Categoria: Fundamentos · **Tempo de leitura:** cerca de 9 minutos · **Publicado em:** [data] · **Última revisão:** [data]

Hacker ético é o profissional autorizado por contrato a usar as mesmas técnicas de um atacante mal-intencionado para identificar vulnerabilidades em sistemas e ajudar a corrigi-las antes que sejam exploradas. Atua em pentest, Red Team, bug bounty, pesquisa de vulnerabilidades e desenvolvimento seguro, com ética profissional rigorosa e regras claras de engajamento.

INTRODUÇÃO

Por que o termo "hacker ético" causa confusão

A palavra "hacker" carrega décadas de associação negativa na imprensa generalista. "Hacker ético" surgiu como um termo conciliador, para diferenciar o profissional autorizado do criminoso cibernético. Na prática, o trabalho é o mesmo em técnica, mas radicalmente diferente em intenção, autorização e consequência. Este post explica o que faz um hacker ético, em que tipos de projeto atua, como se forma um, quanto ganha no Brasil e o que diferencia o profissional sério do amador perigoso.

H2 1

O que é um hacker ético

Hacker ético, também chamado de pentester, ethical hacker, white hat ou simplesmente especialista em segurança ofensiva, é o profissional cuja função é identificar vulnerabilidades em sistemas, redes, aplicações e processos antes que um adversário mal-intencionado as encontre. A atuação acontece sempre com autorização formal por escrito do responsável legal pelos sistemas, com escopo definido, prazo acordado e regras explícitas sobre o que pode e o que não pode ser feito.

Sem essa autorização, qualquer tentativa de acesso não autorizado a sistemas alheios é crime previsto na Lei Carolina Dieckmann (Lei 12.737/2012) e no Código Penal brasileiro. A "ética" em hacker ético, portanto, não é meramente filosófica: é o que separa um profissional de um criminoso.

H2 2

O que um hacker ético faz no dia a dia

A rotina de um hacker ético depende do tipo de projeto. Em pentest, o profissional passa boa parte do dia em três frentes principais.

- **Reconhecimento:** mapeia a superfície de ataque do alvo. Levanta subdomínios, certificados, tecnologias em uso, exposição em vazamentos públicos.
- **Análise e exploração:** identifica vulnerabilidades em aplicações, APIs, infraestrutura ou Active Directory. Testa cada hipótese com exploração manual, encadeando falhas para demonstrar impacto real.
- **Documentação:** descreve cada achado em relatório técnico com evidência reproduzível, severidade CVSS, impacto de negócio e recomendação de remediação.

Em Red Team, o trabalho se estende para vetores não técnicos: phishing autorizado, vishing, intrusão física, abuso de fornecedor. O exercício dura semanas, é silencioso, e o pentester precisa pensar como um adversário motivado tentaria comprometer a organização.

Em bug bounty, o hacker ético trabalha de forma autônoma reportando vulnerabilidades em programas públicos. Em pesquisa de vulnerabilidades, dedica-se a explorar tecnologias em busca de falhas inéditas, frequentemente publicando CVEs. Em desenvolvimento seguro, atua junto ao time de produto para evitar que falhas cheguem em produção (veja [Purple Team](#)).

H2 3

Áreas de especialização

Cibersegurança ofensiva é ampla demais para uma pessoa cobrir tudo com profundidade. Hackers éticos seniores costumam se especializar.

Web e API: foco em [pentest web](#) e [pentest API](#), com profundidade em OWASP Top 10 e em vulnerabilidades de lógica de negócio.

Mobile: foco em [pentest mobile](#) iOS e Android, com domínio de Frida, decompilação e instrumentação.

Cloud: foco em [pentest cloud](#), com domínio de IAM e exploração de configurações.

Active Directory: [pentest AD](#), com BloodHound, Kerberoasting, abuso de delegação.

IA: [AI Red Teaming](#) em LLMs e agentes.

Exploitação binária e pesquisa: engenharia reversa, fuzzing, desenvolvimento de exploit, publicação de CVE.

- **Engenharia social:** phishing avançado, vishing, intrusão física.

H2 4

Certificações reconhecidas no Brasil e no mundo

Certificação não é o único critério para julgar competência (experiência prática e portfólio público pesam mais), mas é referência aceita em contratação e em propostas comerciais. As mais respeitadas em segurança ofensiva são:

- **OSCP (Offensive Security Certified Professional):** considerada o "porta de entrada" sério, exame prático de 24 horas com reporting.
- **OSWE (Offensive Security Web Expert):** foco em pentest web avançado e em desenvolvimento de exploit.

- **OSEP (Offensive Security Experienced Penetration Tester):** foco em técnicas de evasão e bypass de defesas modernas.
- **OSED (Offensive Security Exploit Developer):** desenvolvimento de exploit para Windows.
- **CERTO (Certified Red Team Operator):** operação ofensiva com Cobalt Strike.
- **CRTL (Certified Red Team Lead):** liderança de equipes Red Team.
- **BSCP (Burp Suite Certified Practitioner):** pentest web com foco em PortSwigger.
- **GPEN (GIAC Penetration Tester):** certificação SANS, valorizada em empresas americanas.
- **CISSP (Certified Information Systems Security Professional):** gerencial e abrangente, fora do escopo ofensivo puro mas valorizada em senioridade.

H2 5

Quanto ganha um hacker ético no Brasil

A faixa salarial varia bastante com senioridade, certificação, idioma e modelo de contratação (CLT, PJ, contratação remota internacional). Em 2026, faixas usuais ficam aproximadamente:

- **Junior (até 2 anos):** entre R\$ 5 mil e R\$ 8 mil por mês CLT.
- **Pleno (3 a 5 anos):** entre R\$ 10 mil e R\$ 18 mil CLT, ou faixas equivalentes em PJ.
- **Sênior (5+ anos com certificações):** a partir de R\$ 20 mil CLT, ou USD 5 mil a USD 12 mil/mês em contratos internacionais remotos.
- **Especialistas e líderes técnicos:** sem teto definido, com contratos internacionais frequentemente acima de USD 15 mil/mês.

NOTA EDITORIAL: Faixas indicativas, baseadas em observação de mercado. Variam conforme a cidade, o setor, o modelo contratual e a moeda de pagamento.

H2 6

Como se tornar um hacker ético

Não existe caminho único. A trajetória mais consistente combina fundamentos técnicos, prática supervisionada e portfólio público.

31. **Fundamentos sólidos:** redes (TCP/IP, HTTP), sistemas operacionais (Linux e Windows), programação básica (Python, Bash), bancos de dados.
32. **Estudo dirigido em segurança ofensiva:** OWASP Top 10, OWASP API Top 10, MITRE ATT&CK, NIST SP 800-115.
33. **Prática em laboratórios:** Hack The Box, TryHackMe, PortSwigger Web Security Academy, HackTheBox Academy.
34. **Primeira certificação prática:** OSCP é o melhor primeiro passo para a maioria dos casos.
35. **Portfólio público:** CTFs, bug bounty (HackerOne, YesWeHack), blog técnico, contribuição em ferramentas open source.
36. **Networking real:** eventos como H2HC, Roadsec, BSides, encontros locais, comunidades técnicas no Telegram/Discord.
37. **Primeira posição:** consultoria júnior, programa de bug bounty interno, time de AppSec em empresa grande.

O que diferencia o profissional sério

O mercado tem quantidade enorme de gente que se diz "hacker" sem credenciais reais. Para identificar profissional sério, alguns sinais ajudam:

- Certificação reconhecida (OSCP, OSWE, OSEP, CRTO).
- Portfólio público com CVEs, blog técnico, palestras em eventos.
- Histórico em consultoria ou em time de produto de empresa madura.
- Comunicação clara, especialmente em relatórios.
- Ética profissional explicitada: NDA, escopo formal, divulgação responsável.

Hacker ético e a First Security

A First Security é constituída por profissionais que se enquadram nesse perfil sério. Toda a nossa [equipe](#) carrega certificação reconhecida, tem nome e perfil público e atua de acordo com a [Política de Divulgação Responsável](#).

Quem busca consultoria de hacking ético pode partir do nosso hub principal de [Pentest](#), conhecer a [Metodologia](#) que adotamos e a [lista de certificações](#) do time.

Perguntas frequentes sobre hacker ético

Qual a diferença entre hacker ético e cracker?

"Cracker" é termo informal para hacker mal-intencionado (também chamado de black hat). Hacker ético tem autorização e propósito legítimo; cracker age sem autorização e com objetivo de dano ou ganho ilícito. Tecnicamente, as técnicas se sobrepõem; o que muda é a moldura legal e ética.

Preciso de diploma para ser hacker ético?

Não é obrigatório. Empresas costumam exigir formação técnica em TI ou áreas afins, mas portfólio público e certificações práticas têm peso muito maior na contratação técnica em consultoria.

Hacker ético no Brasil é crime?

Não. Quando autorizado por escrito pelo responsável legal pelos sistemas, é atividade profissional regular. Sem autorização, configura crime.

É possível ser hacker ético freelancer?

Sim. Muitos atuam como freelancers em consultorias, em bug bounty público (HackerOne, YesWeHack, Bugcrowd, BugHunt) e em contratação direta de empresas. Modelo PJ é comum.

Hacker ético precisa saber programar?

Conhecimento mínimo de programação (Python, Bash, capacidade de ler código em várias linguagens) é praticamente obrigatório. Para especialização em pentest web e em pesquisa de vulnerabilidades, programação aprofundada é diferencial decisivo.

CTA FINAL DO POST

Quer aprofundar com a equipe da First Security?

A First Security tem equipe certificada e atende empresas em todo o Brasil. Se este conteúdo levantou perguntas para o seu cenário, vamos conversar.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Ethical Hacking: guia prático para empresas

URL completa: <https://firstsecurity.com.br/blog/fundamentos/ethical-hacking-guia>

HERO DO POST

Ethical Hacking: guia prático para empresas que vão contratar pela primeira vez

Categoria: Fundamentos · **Tempo de leitura:** cerca de 11 minutos

Ethical hacking, ou hacking ético, é o uso autorizado e profissional de técnicas de ataque cibernético para identificar e corrigir vulnerabilidades em sistemas, aplicações e processos de uma organização. Este guia explica como uma empresa contrata, o que esperar, o que NÃO esperar, e como avaliar fornecedores.

H2 1

O que é ethical hacking, em uma frase

Ethical hacking é o exercício autorizado e profissional de invasão simulada de sistemas, aplicações ou processos de uma organização, com objetivo de identificar e corrigir vulnerabilidades antes que um atacante real as explore. É o nome em inglês para o que no Brasil se costuma chamar de pentest, teste de intrusão, hacker ético ou segurança ofensiva.

H2 2

Quando uma empresa precisa contratar

Cinco situações típicas levam empresas brasileiras a contratar ethical hacking pela primeira vez.

- Vai lançar uma aplicação nova e quer evitar exposição em produção.
- Entrou em ciclo de auditoria (LGPD, PCI DSS, ISO 27001, SOC 2, BACEN).
- Sofreu incidente ou identificou tentativa de ataque no SOC.
- Está em diligência avançada (investimento, M&A, parceria estratégica).
- Cliente corporativo solicitou evidência de segurança em questionário.

Em qualquer desses cenários, o ponto de partida é a página [o que é pentest](#).

H2 3

O que esperar de um projeto

Um projeto sério de ethical hacking segue fluxo previsível.

38. **Reunião comercial:** descoberta do cenário, definição preliminar de escopo.
39. **NDA:** assinatura de acordo de confidencialidade antes de detalhes técnicos.
40. **Proposta:** escopo formal, prazo, preço, termos contratuais.

41. **Contrato e termo de autorização:** autorização por escrito de todos os ativos a serem testados.
42. **Kickoff técnico:** definição de ponto focal, janela, regras de engajamento, canal de emergência.
43. **Execução:** pentest propriamente dito, com comunicação periódica.
44. **Entrega:** relatório técnico, executivo, reunião de fechamento.
45. **Remediação:** cliente corrige, fornecedor faz reteste.
46. **Encerramento:** certificado de execução, base para auditores.

H2 4

O que NÃO esperar

Cinco coisas que ethical hacking não é, apesar do que algumas consultorias prometem.

- Não é uma "varredura automatizada" disfarçada de pentest. Scanner é uma ferramenta auxiliar; o trabalho é manual.
- Não é uma garantia de "imunidade". O escopo é específico; outros vetores podem existir fora dele.
- Não é um substituto de auditoria ou de controle preventivo (WAF, EDR, SIEM).
- Não é teatro de segurança com slides bonitos e nenhuma evidência reproduzível.
- Não é uma confissão pública. Tudo é confidencial.

H2 5

Como avaliar fornecedores

A escolha de fornecedor é uma decisão de risco. Sete sinais separam fornecedor sério de oportunista.

- Equipe identificável com nome, perfil e certificação verificável.
- Metodologia documentada e publicada (PTES, OWASP, NIST, MITRE ATT&CK).
- Capacidade de mostrar relatório modelo anonimizado antes do contrato.
- Cases públicos com cliente identificado (com autorização) ou anonimizado de forma transparente.
- Cobertura de compliance que se aplica ao seu cenário.
- Política clara de confidencialidade e divulgação responsável.
- Reuniões com a liderança técnica, não só com vendedor.

A First Security atende todos esses critérios. Você pode [baixar nosso modelo de relatório](#), ver nossa [equipe](#) e nossa [metodologia](#).

H2 6

Quanto custa, na prática

Faixas usuais em projetos brasileiros, considerando equipe sênior e relatório aceito por auditores:

- Pentest web ou API de pequeno porte: faixa de poucas dezenas de milhares de reais.
- Pentest combinado (web + API + cloud): faixa intermediária.
- **PTaaS recorrente:** assinatura mensal ou anual com pacote de horas.
- **Red Team enterprise:** investimento na casa dos seis dígitos em reais.

NOTA EDITORIAL: Valores específicos requerem briefing. Solicite orçamento detalhado.

H2 7

Erros comuns a evitar

Cinco erros que a First Security observa com frequência em empresas iniciantes em ethical hacking.

- **Contratar fornecedor barato sem critério:** sai mais caro a longo prazo, relatório medíocre que não passa em auditoria.
- **Escopo amplo demais:** tentar testar tudo em um único projeto e acabar sem profundidade em nada.
- **Não preparar o ambiente:** pentestear sem documentação atualizada, sem ponto focal técnico, sem janela definida.
- **Tratar achados como ataque pessoal:** em vez de aprendizado, virar caça às bruxas com o time de desenvolvimento.
- **Ignorar reteste:** corrigir sem validar é não corrigir.

CTA FINAL DO POST

Quer aprofundar com a equipe da First Security?

A First Security tem equipe certificada e atende empresas em todo o Brasil. Se este conteúdo levantou perguntas para o seu cenário, vamos conversar.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Como se tornar pentester profissional

URL completa: <https://firstsecurity.com.br/blog/carreira/como-se-tornar-pentester>

HERO DO POST

Como se tornar pentester profissional no Brasil em 2026

Categoria: Carreira • **Tempo de leitura:** cerca de 14 minutos

Tornar-se pentester profissional combina fundamentos técnicos sólidos (redes, sistemas, programação), prática supervisionada em laboratórios reconhecidos, certificação prática (a OSCP costuma ser a primeira), portfólio público demonstrável (CTFs, bug bounty, blog técnico) e a primeira posição em consultoria ou em time interno. O caminho leva entre 1 e 3 anos em média, e demanda disciplina mais do que talento.

H2 1

Pré-requisitos: você precisa ter (ou aprender) isto

Antes de se candidatar à primeira vaga, alguns fundamentos não são negociáveis.

- **Redes:** TCP/IP, HTTP, DNS, TLS, protocolos comuns.
- **Sistemas operacionais:** Linux (administração, scripting, permissões) e Windows (Active Directory básico, registry, serviços).
- **Programação:** Python e Bash fluentes. Capacidade de ler código em Java, PHP, JavaScript, C.
- **Web fundamentos:** HTTP, HTML, JavaScript, headers, cookies, sessões, autenticação.
- **Bancos de dados:** SQL básico, conceitos NoSQL.
- **Cloud (cada vez mais relevante):** noções de AWS ou Azure ou GCP.

H2 2

Roteiro de estudo, fase 1: laboratórios e teoria

Os primeiros seis a doze meses costumam ser dedicados a estudo dirigido.

- PortSwigger Web Security Academy (gratuito, excelente).
- TryHackMe (didático, com trilhas estruturadas).
- HackTheBox e HTB Academy (mais avançado, foco em práticas reais).
- OWASP Top 10 e OWASP API Top 10 estudados a fundo.
- MITRE ATT&CK explorado em detalhes.
- Leitura de relatórios públicos de pentest e de cases de bug bounty.

H2 3

Fase 2: primeira certificação prática

A OSCP (Offensive Security Certified Professional) é, em 2026, a melhor primeira certificação para a maioria dos casos. Exame prático de 24 horas com relatório técnico, simulando um pentest real. Aprovação reconhecida internacionalmente, com peso em qualquer processo seletivo de consultoria séria.

Alternativas válidas dependem do foco: OSWE para quem quer especialização em web, BSCP para entrada via PortSwigger, GPEN para quem mira mercado americano (SANS é reconhecida lá). Para iniciantes absolutos, CEH é nome conhecido mas com prestígio técnico inferior a OSCP.

H2 4

Fase 3: construir portfólio público

Empresas sérias contratam por evidência, não por currículo. Quatro tipos de portfólio têm peso real:

- **CTFs (Capture The Flag):** participação documentada em competições, com writeups publicados.
- **Bug bounty:** achados em programas públicos (HackerOne, YesWeHack, Bugcrowd, BugHunt brasileiro). Mesmo achados de severidade baixa contam.
- **Blog técnico próprio:** posts sobre vulnerabilidades exploradas em ambientes próprios, técnicas estudadas, ferramentas desenvolvidas.
- **Contribuição open source:** ferramentas de segurança próprias ou contribuições em projetos existentes.

H2 5

Fase 4: primeira posição

Três caminhos comuns para a primeira posição.

- **Consultoria júnior:** a porta de entrada mais frequente. Você entra como pentester júnior em consultoria especializada (como a First Security), executa projetos com supervisão de sênior, evolui em ciclo de mentoria. Caminho mais sólido tecnicamente.
- **Time interno de AppSec:** em empresas de tecnologia maduras, há vagas para AppSec engineer com componente de pentest interno. Salário em geral maior, mas profundidade técnica varia.
- **Bug bounty profissional:** caminho mais arriscado financeiramente, mas que algumas pessoas conseguem fazer dar certo. Recomendado apenas após acúmulo significativo de portfólio.

H2 6

Evolução: do júnior ao sênior

O pulo de júnior para pleno costuma exigir dois a três anos de execução supervisionada, uma a duas certificações avançadas e capacidade de conduzir projetos sozinho. O pulo para sênior leva mais três

a cinco anos e exige especialização clara (cloud, AD, mobile, AI, etc.), publicações próprias e capacidade de liderar projetos complexos com clientes.

H2 7

Onde estudar: recursos práticos

Lista curada de recursos respeitados pela equipe da First Security.

- PortSwigger Web Security Academy (gratuito).
- TryHackMe.
- Hack The Box e HTB Academy.
- OffSec Labs (PWK, AWE, AWAE).
- SANS Reading Room.
- OWASP guides: WSTG, MASTG, API Top 10.
- Livros: "The Web Application Hacker's Handbook", "Real-World Bug Hunting", "Hacking APIs", "RTFM".
- Eventos: H2HC, Roadsec, BSides em várias capitais brasileiras, DEF CON.
- Comunidades: H2HC, Hackers do Bem, comunidades regionais.

H2 8

Erros a evitar na carreira

Erros comuns que atrasam ou descarrilham carreiras promissoras.

- **Pular fundamentos:** tentar atalhar redes, programação e Linux. Sempre cobra depois.
- **Coleção de certificações sem prática:** CV cheio de siglas, mas sem capacidade de executar.
- **Trabalhar sem autorização:** testar sistemas alheios sem permissão. Crime e fim de carreira.
- **Falta de comunicação:** profissional excelente tecnicamente que não consegue escrever relatório claro tem teto de carreira.
- **Falta de ética:** cair em tentação de vazar achado, vender para terceiros, abusar de acesso. Carreira encerrada.

H2 9

Quer começar como pentester na First Security?

A First Security mantém programa de formação para juniores e plenos. Quando temos vaga aberta, divulgamos em [nossa equipe](#) e em nossas redes profissionais.

CTA FINAL DO POST

Quer aprofundar com a equipe da First Security?

A First Security tem equipe certificada e atende empresas em todo o Brasil. Se este conteúdo levantou perguntas para o seu cenário, vamos conversar.

[DOIS BOTÕES CTA lado a lado]

Primário: Agendar conversa → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Parte 12. Páginas de autoridade e E.E.A.T.

E.E.A.T. (Experience, Expertise, Authoritativeness, Trustworthiness) é fator decisivo no ranqueamento de páginas comerciais e ainda mais em consultorias de cibersegurança. As páginas abaixo (Metodologia, Equipe, Certificações, Diferenciais, Casos de Uso, Modelo de Relatório, Glossário) constroem essa autoridade em camadas.

PÁGINA • /quem-somos/metodologia

Metodologia da First Security

URL completa: <https://firstsecurity.com.br/quem-somos/metodologia>

HERO

Como conduzimos cada projeto, fase a fase

A metodologia da First Security é pública e documentada. Cada projeto segue as mesmas fases canônicas, com adaptações por tipo de teste. Frameworks de referência: PTES, OWASP WSTG e MASTG, OWASP API Top 10, NIST SP 800-115, MITRE ATT&CK e OSSTMM.

BLOCO 2 — Fases canônicas

Sete fases canônicas de um pentest

1. Pré-engajement

Reunião de descoberta, NDA, definição formal de escopo, autorização por escrito, janela, ponto focal, regras de engajamento, canal de emergência. Sem essa fase concluída, nada começa.

2. Reconhecimento

Coleta passiva e ativa de informações sobre o alvo. Mapeamento de superfície de exposição. Identificação de tecnologias, versões, integrações.

3. Modelagem de ameaça

Análise das ameaças relevantes para o alvo. Em pentest web de fintech, a modelagem inclui adversário motivado financeiramente; em pentest de prontuário eletrônico, ameaça inclui acesso a dado sensível por colaborador interno.

4. Análise e exploração

Identificação de vulnerabilidades, com testes manuais e ferramentas auxiliares. Cada vulnerabilidade é validada com prova de impacto reproduzível.

5. Pós-exploração

Avaliação do impacto real de cada falha encontrada. Movimento lateral controlado quando autorizado. Sempre com registro detalhado.

6. Relato

Entrega do relatório técnico e executivo, com priorização por criticidade real e plano de remediação por esforço.

7. Reteste

Após o cliente concluir a remediação, validamos correções e encerramos o ciclo.

BLOCO 3 — Frameworks

Frameworks de referência

- **PTES (Penetration Testing Execution Standard):** esqueleto metodológico geral.
- **OWASP WSTG (Web Security Testing Guide):** checklist técnico para web.
- **OWASP MASTG (Mobile Application Security Testing Guide):** checklist para mobile.
- **OWASP API Security Top 10:** referência para API.
- **NIST SP 800-115:** diretrizes técnicas para testes de segurança.
- **MITRE ATT&CK:** matriz de táticas e técnicas de adversário.
- **OSSTMM:** metodologia formal de segurança operacional.
- **IEC 62443:** para ambientes OT/SCADA.
- **OWASP Top 10 for LLM:** para AI Red Teaming.

BLOCO 4 — Tooling

Ferramentas que usamos

A First Security usa combinação de ferramentas comerciais, open source e tooling interno desenvolvido pela equipe.

- Burp Suite Pro com extensões customizadas (Web/API).
- Postman, Insomnia, mitmproxy (API).
- Frida, Objection, MobSF (Mobile).
- BloodHound, Rubeus, Mimikatz, Impacket (Active Directory).
- Prowler, ScoutSuite, Pacu, CloudFox (Cloud).
- Cobalt Strike, Mythic, Sliver (Red Team).
- Metasploit, nmap, Nuclei (uso seletivo).
- Tooling interno desenvolvido pela equipe (não publicizado).

BLOCO 5 — Garantias

Garantias contratuais sobre execução

- Equipe que assina o relatório é a mesma que executou.
- Comunicação periódica via canal acordado (Slack, Teams, email).

- Disponibilidade da liderança técnica em até 4 horas úteis em qualquer fase.
- Canal de emergência 24/7 durante execução.
- Confidencialidade absoluta sobre informações trocadas.
- Reteste incluído no escopo.

CTA

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Equipe da First Security

URL completa: <https://firstsecurity.com.br/quem-somos/equipe>

HERO

Quem assina o trabalho da First Security

Cibersegurança ofensiva é feita por pessoas. Esta página apresenta a equipe da First Security, com perfis públicos, certificações verificáveis e contribuições em pesquisa e comunidade. Não há subcontratação opaca: quem assina o relatório é quem você conhece nesta página.

BLOCO 2 — Liderança técnica

Liderança técnica

NOTA EDITORIAL: Esta seção precisa ser preenchida com os perfis reais da equipe. Os perfis abaixo são placeholders estruturais.

Nome do Diretor Técnico

Diretor Técnico e co-fundador. Mais de [X] anos em segurança ofensiva, especialização em Red Team e Active Directory. Certificações principais: OSCP, OSEP, OSCE3, CRT0, CRTL. Publicações em [referenciar]. Palestras em [eventos].

Nome do Head de Pentest Web

Head de pentest Web e API. Especialização em testes profundos de aplicações modernas, GraphQL e arquiteturas multi-tenant. Certificações: OSWE, BSCP, OSCP, CARTP.

Nome do Head de Cloud

Head de Cloud Security. Especialização em AWS, Azure e GCP. Certificações: AWS Security Specialty, Azure Security Engineer, OSCP.

Nome do Head de AI Red Teaming

Head de AI Red Teaming. Pesquisa publicada em prompt injection e abuso de agentes. Trajetória combinando engenharia de ML e segurança ofensiva.

Nome do Head de Pesquisa

Head de Pesquisa. CVEs publicadas, palestras internacionais. Especialização em engenharia reversa e desenvolvimento de exploit. Certificações: OSED, OSCE3.

BLOCO 3 — Time de execução

Pentesters do time de execução

A First Security mantém time enxuto e sênior. Cada pentester de execução tem em média [X] anos de experiência, pelo menos uma certificação prática (OSCP, OSWE, BSCP, GPEN) e portfólio público em CTF, bug bounty ou pesquisa.

NOTA EDITORIAL: *Listar nominalmente o time completo, com foto, certificações e link individual quando aplicável.*

BLOCO 4 — Como contratamos

Critérios para entrar na equipe

- Certificação prática reconhecida (OSCP no mínimo, ou equivalente).
- Portfólio público demonstrável (CTF, bug bounty, blog, contribuição open source).
- Capacidade de comunicação escrita (relatórios são metade do trabalho).
- Aderência ética estrita.
- Curiosidade técnica genuína (a First Security investe em pesquisa e em laboratório próprio).

CTA

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Certificações da equipe

URL completa: <https://firstsecurity.com.br/quem-somos/certificacoes>

HERO

Certificações que a equipe da First Security carrega

Certificação não substitui experiência prática, mas atesta padrão de competência e ética. A equipe da First Security é construída em torno de certificações reconhecidas internacionalmente em segurança ofensiva.

BLOCO 2 — Certificações por categoria

Certificações em segurança ofensiva

Offensive Security (OffSec)

- OSCP (Offensive Security Certified Professional).
- OSWE (Offensive Security Web Expert).
- OSEP (Offensive Security Experienced Penetration Tester).
- OSED (Offensive Security Exploit Developer).
- OSCE3 (Offensive Security Certified Expert 3).

Red Team

- CRTO (Certified Red Team Operator).
- CRTL (Certified Red Team Lead).
- CRTP (Certified Red Team Professional).

Cloud Security

- AWS Certified Security Specialty.
- Azure Security Engineer Associate.
- Google Professional Cloud Security Engineer.

Outras relevantes

- BSCP (Burp Suite Certified Practitioner).
- GPEN (GIAC Penetration Tester).
- GWAPT (GIAC Web Application Penetration Tester).
- CISSP (Certified Information Systems Security Professional).
- CISM (Certified Information Security Manager).
- CEH (Certified Ethical Hacker) [referência de mercado].

BLOCO 3 — Verificação

Como verificar as certificações

Toda certificação da nossa equipe é verificável publicamente nos registros do emissor. Em propostas formais, listamos nome do profissional alocado e ID de certificação para que o cliente verifique diretamente com OffSec, GIAC, AWS, Microsoft ou Google.

CTA

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Diferenciais da First Security

URL completa: <https://firstsecurity.com.br/quem-somos/diferenciais>

HERO

O que diferencia a First Security das outras opções

O mercado brasileiro de pentest tem opções de todo tipo: consultorias gigantes, integradores que adicionaram pentest ao portfólio, freelancers e fornecedores genuinamente especializados. A First Security é da última categoria. Esta página explicita por quê.

BLOCO 2 — Diferenciais

Sete diferenciais que importam

1. Especialização verdadeira

A First Security faz apenas cibersegurança ofensiva. Não vendemos ferramenta, não fazemos venda casada com infraestrutura, não competimos com integradores. Pentest é o que fazemos o tempo todo, todos os dias.

2. Equipe identificável

Quem assina o relatório é a mesma pessoa que executou o projeto. Nada de "consultor parceiro" ou subcontratação opaca. Veja a [nossa equipe](#) e [certificações](#).

3. Metodologia transparente

Nossa [metodologia é pública](#) e baseada em frameworks reconhecidos. Você pode consultá-la antes do contrato e exigir aderência durante a execução.

4. Relatório que passa em auditoria

Nossos relatórios são lidos e aceitos por auditores QSA (PCI DSS), BACEN, ISO 27001 e SOC 2. Pode [baixar modelo anonimizado](#) antes de pedir orçamento.

5. Ciclo completo

Trabalhamos ataque ([pentest](#), [Red Team](#)), integração ([Purple Team](#)) e modelos contínuos ([PTaaS](#)). Não é só "pentest anual".

6. Atendimento humano

Quem responde ao seu email é pentester sênior, não SDR. Reunião de descoberta sem custo, sem qualificação automática frustrante.

7. Atualização contínua

A First Security investe em pesquisa, em laboratório próprio e em formação contínua da equipe. Profissionais com tempo dedicado a estudo e a desenvolvimento de tooling interno.

CTA

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → </agendar-conversa>

Secundário: Solicitar orçamento → </orcamento>

Casos de uso (cases anonimizados)

URL completa: <https://firstsecurity.com.br/casos-de-uso>

HERO

Cases reais e anonimizados

Esta página reúne casos anonimizados de projetos reais executados pela First Security. Todos foram aprovados por escrito pelos clientes antes da publicação. As empresas envolvidas têm seus nomes preservados conforme a Política de Confidencialidade.

BLOCO 2 — Case 1

Case 1: fintech de crédito, PTaaS + PCI DSS

Setor: fintech de crédito ao consumidor.

Cenário: lançamento de produto novo de crédito digital, com integração PIX e armazenamento de dado de cartão. Auditoria PCI DSS marcada para 90 dias após o go-live.

Serviço contratado: PTaaS Pro com escopo combinado de web + API + cloud.

Resultado: sete vulnerabilidades críticas identificadas antes do go-live (incluindo dois BOLAs em endpoints de pagamento e um SSRF em integração com bureau de crédito). Auditoria PCI DSS aprovada no primeiro ciclo.

BLOCO 3 — Case 2

Case 2: SaaS B2B internacional, Red Team + AI Red Teaming

Setor: SaaS B2B com base instalada nos EUA e na Europa.

Cenário: lançamento de feature baseada em IA generativa, com integração ao ambiente AWS via agente com permissões amplas.

Serviço contratado: Red Team + AI Red Teaming combinados.

Resultado: comprometimento completo do ambiente AWS em 11 dias por meio de prompt injection indireta em documento processado pelo agente. Plano de remediação fechado em três semanas com mudança de arquitetura.

BLOCO 4 — Case 3

Case 3: healthtech, pentest mobile + cloud + LGPD

Setor: healthtech com aplicativo de telemedicina e prontuário eletrônico.

Cenário: adequação à LGPD com pressão de fiscalização da ANPD após denúncia anônima.

Serviço contratado: pentest mobile + cloud com cobertura LGPD ampliada.

Resultado: mapeamento completo do tratamento de dado pessoal sensível em três semanas. Relatório técnico apresentado ao encarregado da empresa, com plano de mitigação aceito pela ANPD.

BLOCO 5 — Mais cases

Quer ver um case específico para seu setor?

Os cases acima são apenas três entre muitos. Para casos do seu setor (banco, governo, indústria, e-commerce), entre em contato e compartilhamos exemplos relevantes sob NDA.

CTA

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Modelo de relatório de pentest

URL completa: <https://firstsecurity.com.br/relatorios/modelo-de-relatorio>

HERO

Baixe um modelo anonimizado do relatório que entregamos

Antes de assinar contrato, conheça o entregável. A First Security disponibiliza um modelo anonimizado do relatório de pentest exatamente como ele chega na mão do nosso cliente. Sumário executivo para diretoria, achados ordenados por criticidade, evidências reproduzíveis e plano de remediação por esforço.

BLOCO 2 — O que tem no relatório

O que você encontra no relatório

- **Sumário executivo:** 4 a 8 páginas em linguagem de risco, escrito para diretoria e conselho.
- **Metodologia aplicada:** frameworks usados, ferramentas, fases.
- **Resumo de achados:** tabela de vulnerabilidades por criticidade, com mapeamento MITRE ATT&CK e CWE.
- **Detalhe técnico de cada achado:** descrição, evidência reproduzível (screenshot, request, payload), CVSS, impacto de negócio, recomendação.
- **Plano de remediação:** priorização por criticidade e estimativa de esforço.
- **Apêndices:** logs relevantes, referências, mapeamento de compliance.

BLOCO 3 — Formulário

Baixe o modelo

Preencha os dados abaixo e receba o modelo por email. Sem qualificação automática frustrante, sem ligação de SDR no dia seguinte.

[FORMULÁRIO] Download de modelo de relatório

Campos:

- Nome completo (obrigatório)
- Email corporativo (obrigatório, validação de domínio livre)
- Empresa (obrigatório)
- Cargo (obrigatório)
- Telefone (opcional)
- Aceite LGPD (checkbox obrigatório com link para /legal/politica-de-privacidade)

Botão de envio: "Baixar modelo gratuito"

NOTA EDITORIAL: Após envio: redirecionamento para página de obrigado com link direto para o PDF. Email automático com cópia do relatório. Sequência de quatro emails ao longo de duas semanas com conteúdo complementar.

Glossário de cibersegurança ofensiva

URL completa: <https://firstsecurity.com.br/glossario>

HERO

Glossário de termos em cibersegurança ofensiva

Lista alfabética de termos usados ao longo do conteúdo da First Security. Definições curtas e citáveis, com link para a página principal quando o termo tem uma. Este glossário é vivo e atualizado conforme o vocabulário do setor evolui.

[SEM CTA / SEM FORMULÁRIO] Hero do glossário. Apenas introdução.

BLOCO 2 — Termos

A

Active Directory (AD)

Serviço de diretório da Microsoft para gerenciamento centralizado de identidades e recursos em redes Windows. Alvo prioritário em pentests internos. Veja [pentest Active Directory](#).

AI Red Teaming

Disciplina que testa modelos de IA, especialmente LLMs e agentes, contra ataques específicos: prompt injection, jailbreaks, vazamento de dados, abuso de tooling. Página dedicada: [AI Red Teaming](#).

API

Application Programming Interface. Conjunto de endpoints expostos por uma aplicação para integração com outras aplicações. Alvo central em pentest moderno.

ATT&CK (MITRE)

Matriz pública mantida pela MITRE que cataloga táticas, técnicas e procedimentos usados por adversários reais. Padrão de fato para mapeamento de ataque em Red Team e em Purple Team.

B

Black Box

Modalidade de pentest em que o testador não recebe informação prévia sobre o alvo. Veja [Black Box vs White Box vs Grey Box](#).

Blue Team

Equipe defensiva em cibersegurança. Opera SOC, SIEM, EDR, NDR, responde a incidentes. Oposto operacional do Red Team. Veja [Red Team vs Blue Team](#).

BOLA (Broken Object Level Authorization)

Classe de vulnerabilidade em API caracterizada por falha de autorização ao acessar objeto específico. Equivalente moderno do IDOR.

Bug Bounty

Programa público em que empresas pagam recompensa a pesquisadores que reportam vulnerabilidades. Complementar a pentest. Veja [Pentest vs Bug Bounty](#).

C

CISO (Chief Information Security Officer)

Líder executivo responsável pela segurança da informação de uma organização.

Cloud Security

Disciplina que cuida da segurança em ambientes cloud (AWS, Azure, GCP). Inclui IAM, configuração, exposição e exploração ativa. Veja [pentest cloud](#).

CVE (Common Vulnerabilities and Exposures)

Identificador público padronizado para vulnerabilidades específicas em softwares. Atribuído por autoridades de numeração (CNAs).

CVSS (Common Vulnerability Scoring System)

Sistema padrão de pontuação de severidade de vulnerabilidades, de 0.0 a 10.0.

D

DPO (Data Protection Officer / Encarregado)

Em LGPD, o encarregado de proteção de dados é a pessoa responsável por mediar entre titulares, controlador e ANPD.

E

E.E.A.T. (Experience, Expertise, Authoritativeness, Trustworthiness)

Framework do Google para avaliar qualidade de páginas. Fator crítico em SEO de consultoria.

Engenharia Social

Ataque que explora a confiança humana em vez de falha técnica. Inclui phishing, vishing, smishing, ataques físicos. Veja [engenharia social](#).

G

Grey Box

Modalidade de pentest em que o testador recebe informação parcial sobre o alvo, simulando um usuário comum ou parceiro.

GraphQL

Linguagem de query para APIs criada pelo Facebook. Tem classes próprias de vulnerabilidade (introspection abuse, batch attacks, depth attacks).

I

IDOR (Insecure Direct Object Reference)

Classe de vulnerabilidade em que a aplicação permite acesso a objeto sem validar se o usuário tem autorização para ele.

ISO 27001

Norma internacional para Sistema de Gestão de Segurança da Informação. Veja [pentest para ISO 27001](#).

L

LGPD

Lei Geral de Proteção de Dados (Lei 13.709/2018). Regula o tratamento de dados pessoais no Brasil. Veja [pentest para LGPD](#).

LLM (Large Language Model)

Modelo de linguagem treinado em larga escala. Base de muitas aplicações de IA generativa modernas. Tem classes próprias de risco mapeadas pelo OWASP Top 10 for LLM.

O

OSCP (Offensive Security Certified Professional)

Certificação prática de 24 horas em pentest. Considerada a "porta de entrada" séria em segurança ofensiva.

OWASP (Open Worldwide Application Security Project)

Fundação que mantém referências open source em segurança de aplicações: OWASP Top 10, WSTG, MASTG, API Security Top 10, Top 10 for LLM.

P

Pentest

Abreviação de "penetration test", teste de intrusão. Veja [o que é pentest](#).

PCI DSS

Payment Card Industry Data Security Standard. Norma para empresas que processam, armazenam ou transmitem dados de cartão. Veja [pentest para PCI DSS](#).

Phishing

Ataque de engenharia social via email (ou variantes: SMS, telefone) que tenta induzir vítima a clicar em link malicioso, baixar arquivo ou fornecer credenciais.

Prompt Injection

Classe específica de vulnerabilidade em aplicações com LLM, em que entrada do usuário (ou de fonte externa processada pelo LLM) manipula o comportamento do modelo.

PTaaS (Pentest as a Service)

Modelo de pentest recorrente, com plataforma, retestes ilimitados e integração com CI/CD. Veja [PTaaS](#).

Purple Team

Exercício colaborativo entre Red Team (ataque) e Blue Team (defesa) para evoluir capacidade defensiva. Veja [Purple Team](#).

R

Red Team

Em cibersegurança, equipe ou exercício adversarial autorizado que simula adversário real. Veja a página pilar [Red Team em cibersegurança](#).

Reteste

Validação posterior à correção de uma vulnerabilidade reportada, para confirmar que ela foi efetivamente remediada.

S

SOC (Security Operations Center)

Centro operacional que monitora, detecta e responde a incidentes de segurança. Parte central do Blue Team.

SOC 2

Relatório de controles para empresas de tecnologia que processam dados de clientes corporativos. Veja [pentest para SOC 2](#).

SQL Injection

Classe clássica de vulnerabilidade em aplicações que constroem queries SQL dinamicamente sem sanitização adequada.

SSRF (Server-Side Request Forgery)

Classe de vulnerabilidade em que aplicação é induzida a fazer requisições para destino controlado pelo atacante.

W

White Box

Modalidade de pentest em que o testador recebe informação completa sobre o alvo (credenciais, documentação, código).

WSTG (Web Security Testing Guide)

Guia de teste de segurança em aplicações web mantido pela OWASP.

CTA

[DOIS BOTÕES CTA lado a lado]

Primário: Falar com especialista → [/agendar-conversa](#)

Secundário: Solicitar orçamento → [/orcamento](#)

Parte 13. Páginas Legais

As páginas legais sustentam a confiança jurídica do site. São páginas pouco visitadas em volume, mas essenciais para LGPD, para auditoria e para credibilidade institucional. Os textos abaixo são modelos prontos, escritos para a realidade brasileira, com referência explícita à LGPD.

RECOMENDAÇÃO: revisão final pelo jurídico da First Security antes da publicação.

NOTA EDITORIAL: Os textos a seguir são modelos prontos. Eles foram redigidos com base nas práticas mais comuns do mercado brasileiro de cibersegurança e em conformidade com a LGPD. Devem ser revisados e validados pelo advogado responsável pela First Security antes da publicação. Substituir [placeholders] por dados reais (CNPJ, endereço, nome de DPO, etc.).

PÁGINA • /legal/politica-de-privacidade

Política de Privacidade

URL completa: <https://firstsecurity.com.br/legal/politica-de-privacidade>

HEADER

Política de Privacidade da First Security

Última atualização: [data de revisão jurídica]

TEXTO

1. Quem é a First Security

A First Security é a marca operacional da [Razão Social], pessoa jurídica de direito privado inscrita no CNPJ [CNPJ], com sede em [endereço completo, cidade, estado, Brasil]. Atuamos no segmento de cibersegurança ofensiva (pentest, Red Team, Purple Team, AI Red Teaming e serviços relacionados).

2. O que esta Política cobre

Esta Política explica como tratamos dados pessoais coletados por meio do site firstsecurity.com.br e dos canais relacionados (formulários de contato, orçamento, agendamento, lead magnets, newsletter, conversas comerciais por email). Está em conformidade com a Lei Geral de Proteção de Dados (Lei 13.709/2018, LGPD).

3. Dados que coletamos

Coletamos dados pessoais de você apenas quando você nos fornece, e na medida estritamente necessária para a finalidade declarada.

- **Em formulários de contato, orçamento ou agendamento:** nome, email corporativo, empresa, cargo, telefone (opcional), e mensagem ou briefing.
- **Em download de lead magnet:** nome, email, empresa, cargo.
- **Em inscrição em newsletter:** nome e email.

- **Automaticamente, via navegação no site:** endereço IP, tipo de navegador, sistema operacional, páginas visitadas, tempo na página, fonte de tráfego e identificadores de cookies necessários ao funcionamento técnico.

4. Para que usamos os dados

Cada dado coletado é tratado com base em uma finalidade legítima e específica:

- Responder às solicitações de contato, orçamento ou agendamento (execução de contrato ou diligência pré-contratual).
- Entregar os materiais solicitados em lead magnets (execução de contrato ou interesse legítimo).
- Enviar a newsletter para quem assina (consentimento livre e específico, revogável a qualquer momento).
- Cumprir obrigações legais e regulatórias.
- Defender direitos em processos judiciais, administrativos ou arbitrais.
- Melhorar o funcionamento do site e a qualidade do nosso conteúdo (interesse legítimo, com base no balanceamento previsto na LGPD).

5. Bases legais (LGPD)

As bases legais aplicáveis ao tratamento de cada dado pessoal são:

- Consentimento (art. 7º, I), para newsletter e comunicações de marketing.
- Execução de contrato e procedimentos preliminares (art. 7º, V), para formulários comerciais.
- Cumprimento de obrigação legal (art. 7º, II), para dados fiscais e contábeis.
- Interesse legítimo (art. 7º, IX), para análise de navegação agregada e melhorias do site, sempre com balanceamento de direitos.

6. Compartilhamento de dados

Não vendemos dados pessoais. Compartilhamos apenas com operadores e parceiros estritamente necessários para a operação:

- CRM e plataformas de email marketing usadas pela First Security.
- Ferramentas de agendamento (Cal.com ou Calendly) usadas em /agendar-conversa.
- Provedores de hospedagem do site e de serviços técnicos.
- Autoridades públicas, mediante ordem legal ou judicial.

Mantemos contratos com cláusulas de proteção de dados com todos os operadores. Listagem detalhada de operadores disponível mediante solicitação ao DPO.

7. Transferência internacional

Em alguns casos (ex: provedor de hospedagem ou de email marketing sediado fora do Brasil), pode haver transferência internacional. Quando ocorre, garantimos que o destinatário tenha nível de proteção equivalente ao previsto pela LGPD, conforme art. 33 da Lei.

8. Retenção

Mantemos seus dados pelo tempo estritamente necessário para a finalidade declarada. Dados de leads que não viraram cliente são removidos do CRM após [12 meses] de inatividade, salvo manifestação contrária. Dados contratuais de clientes são retidos pelo prazo legal de obrigação fiscal e contábil (mínimo 5 anos).

9. Seus direitos como titular

Conforme a LGPD, você tem direito a:

- Confirmação da existência de tratamento de seus dados.
- Acesso aos dados que tratamos sobre você.
- Correção de dados incompletos, inexatos ou desatualizados.
- Anonimização, bloqueio ou eliminação de dados desnecessários ou tratados em desconformidade com a Lei.
- Portabilidade dos dados a outro fornecedor.
- Eliminação dos dados tratados com base em consentimento.
- Informação sobre as entidades públicas e privadas com as quais compartilhamos seus dados.
- Informação sobre a possibilidade de não consentir e suas consequências.
- Revogação do consentimento.
- Apresentar reclamação à ANPD.

10. Como exercer seus direitos

Para exercer qualquer direito previsto na LGPD, entre em contato com nosso encarregado de proteção de dados:

- **Email do DPO:** dpo@firstsecurity.com.br
- **Endereço postal:** [endereço completo da First Security]

Respondemos toda solicitação válida em até 15 dias corridos.

11. Cookies

Usamos cookies estritamente necessários ao funcionamento do site. Detalhes na [Política de Cookies](#).

12. Segurança

Adotamos medidas técnicas e administrativas para proteger os dados pessoais que tratamos: criptografia em trânsito (HTTPS obrigatório), acesso restrito por necessidade de conhecimento, monitoramento contínuo, backups regulares e testes periódicos de segurança. Caso ocorra incidente de segurança que possa acarretar risco ou dano relevante aos titulares, comunicaremos a ANPD e os titulares afetados conforme art. 48 da LGPD.

13. Alterações nesta Política

Esta Política pode ser atualizada periodicamente. A data da última atualização aparece no início do documento. Mudanças relevantes são comunicadas via email ou aviso no site.

14. Lei aplicável e foro

Esta Política é regida pela legislação brasileira. Foro eleito: comarca de [cidade-sede da First Security].

[SEM CTA / SEM FORMULÁRIO] *Página legal informativa, sem CTA comercial. Apenas contato com DPO.*

Conformidade com a LGPD

URL completa: <https://firstsecurity.com.br/legal/lgpd>

HEADER

Conformidade da First Security com a LGPD

TEXTO

1. Compromisso com a LGPD

A First Security trata dados pessoais em conformidade com a Lei 13.709/2018, a Lei Geral de Proteção de Dados (LGPD). Atuamos como controlador no tratamento dos dados coletados por meio do nosso site, formulários e relacionamento comercial, e como operador nos dados que processamos a serviço dos nossos clientes (durante a execução de pentest, Red Team e outros projetos).

2. Encarregado de Proteção de Dados (DPO)

Mantemos encarregado de proteção de dados conforme exigido pela LGPD para empresas do nosso porte e tipo de tratamento.

- **Nome:** [nome do encarregado]
- **Email:** dpo@firstsecurity.com.br
- **Endereço postal:** [endereço da First Security]

3. Princípios que orientam o tratamento

- **Finalidade:** tratamos dados somente para os fins declarados na coleta.
- **Adequação:** os dados tratados são compatíveis com as finalidades declaradas.
- **Necessidade:** limitamos o tratamento ao mínimo necessário.
- **Livre acesso:** garantimos consulta facilitada ao titular sobre seus dados.
- **Qualidade dos dados:** mantemos os dados exatos e atualizados.
- **Transparência:** damos informação clara sobre o tratamento.
- **Segurança:** adotamos medidas técnicas e administrativas adequadas.
- **Prevenção:** agimos para evitar danos.
- **Não-discriminação:** não tratamos dados com fins discriminatórios.
- **Responsabilização e prestação de contas:** comprovamos a adoção de medidas eficazes.

4. Tratamento de dados como operador (em projetos com clientes)

Durante a execução de pentest, Red Team e demais projetos, podemos eventualmente acessar dados pessoais armazenados nos sistemas do cliente. Este tratamento é regido pelo contrato de

prestação de serviços, com cláusula específica de proteção de dados, e segue as instruções do cliente (controlador).

Nesse contexto, a First Security:

- Acessa apenas os dados estritamente necessários para a execução do projeto.
- Não retém cópias de dados pessoais após a conclusão.
- Adota controles técnicos e organizacionais reforçados para o ambiente de trabalho.
- Comunica imediatamente o cliente em caso de incidente.

5. Direitos dos titulares

Detalhamos os direitos dos titulares e como exercê-los na [Política de Privacidade](#).

[SEM CTA / SEM FORMULÁRIO] *Página informativa. Apenas contato com DPO.*

Termos de Uso

URL completa: <https://firstsecurity.com.br/legal/termos-de-uso>

HEADER

Termos de Uso do site First Security

Última atualização: [data]

TEXTO

1. Aceitação dos Termos

Ao acessar e utilizar o site firstsecurity.com.br, você concorda com estes Termos de Uso e com a Política de Privacidade vinculada. Se não concorda, deve interromper o uso do site.

2. Conteúdo do site

Todo o conteúdo publicado no site (textos, imagens, gráficos, vídeos, logos, marca e código) é de propriedade da First Security ou licenciado para uso pela First Security, e está protegido pelas leis brasileiras de propriedade intelectual e direitos autorais.

Você pode acessar e consultar o conteúdo para fins informativos pessoais ou profissionais. É vedado: reprodução comercial não autorizada; uso em produtos derivados; remoção de avisos de propriedade; engenharia reversa de qualquer componente técnico.

3. Conduta esperada

Ao utilizar o site, você se compromete a:

- Fornecer informações verdadeiras nos formulários.
- Não interferir no funcionamento do site (não realizar pentest não autorizado, não tentar acesso não autorizado a áreas restritas).
- Não usar o site para finalidade ilícita ou contrária a estes Termos.

Pesquisadores que identificarem vulnerabilidades no site são incentivados a reportar conforme a [Política de Divulgação Responsável](#).

4. Sem garantia de resultados

O conteúdo do site (incluindo blog, glossário, guias) é informativo e geral. Ele não substitui orientação técnica ou jurídica específica para o seu caso. A contratação dos serviços da First Security se dá por contrato próprio, com escopo, prazo e termos definidos em proposta comercial.

5. Limitação de responsabilidade

Na máxima extensão permitida em lei, a First Security não se responsabiliza por danos indiretos, incidentais ou consequenciais decorrentes do acesso ou uso do site. Esta limitação não se aplica em hipóteses em que a legislação brasileira a vede.

6. Links externos

O site pode conter links para terceiros (frameworks, ferramentas, eventos, parceiros). Não controlamos esses sites e não nos responsabilizamos pelo conteúdo ou pelas práticas de privacidade deles.

7. Alterações nos Termos

Estes Termos podem ser atualizados periodicamente. A data da última atualização aparece no início do documento. O uso continuado do site após a alteração indica aceitação dos novos termos.

8. Lei aplicável e foro

Estes Termos são regidos pela legislação brasileira. Foro eleito: comarca de [cidade-sede da First Security].

Política de Cookies

URL completa: <https://firstsecurity.com.br/legal/politica-de-cookies>

HEADER

Política de Cookies

TEXTO

1. O que são cookies

Cookies são pequenos arquivos de texto armazenados no seu navegador quando você visita um site. Eles permitem que o site lembre informações sobre sua visita (preferências, sessão, identificadores técnicos).

2. Como a First Security usa cookies

O site firstsecurity.com.br usa cookies para finalidades específicas e estritamente necessárias.

- **Cookies essenciais:** necessários ao funcionamento técnico do site (sessão, preferências básicas). Não podem ser desativados.
- **Cookies analíticos:** permitem analisar uso agregado do site para melhoria do conteúdo. Anonimizados na medida do possível.
- **Cookies de marketing:** apenas se você consentir explicitamente, usados para medir efetividade de campanhas pagas.

3. Controle de cookies

Ao acessar o site pela primeira vez, você verá um banner de consentimento que permite aceitar ou rejeitar cookies não essenciais. Sua escolha é registrada e respeitada nas próximas visitas. Você pode revogá-la a qualquer momento via configuração do navegador ou banner persistente acessível no rodapé.

4. Cookies de terceiros

Alguns serviços que usamos (calendário de agendamento, plataforma de email, hospedagem) podem instalar cookies próprios. Esses cookies são regidos pelas políticas dos respectivos terceiros.

5. Mais informações

Para entender melhor o tratamento de dados pessoais associado, consulte nossa [Política de Privacidade](#).

Política de Divulgação Responsável

URL completa: <https://firstsecurity.com.br/legal/politica-de-divulgacao-responsavel>

HEADER

Política de Divulgação Responsável (Responsible Disclosure)

TEXTO

1. Compromisso da First Security

A First Security valoriza o trabalho de pesquisadores de segurança que identificam vulnerabilidades em sistemas. Esta política descreve como você pode reportar vulnerabilidades encontradas no site firstsecurity.com.br ou em sistemas operados pela First Security, e como vamos responder.

2. Escopo

Esta política cobre o site firstsecurity.com.br, seus subdomínios e qualquer aplicação ou serviço explicitamente identificado como operado pela First Security. Não cobre serviços de terceiros (mesmo que listados como parceiros).

3. O que pedimos

- Reporte vulnerabilidades exclusivamente pelo canal indicado abaixo.
- Dê tempo razoável para correção antes de qualquer divulgação pública.
- Não acesse, modifique ou destrua dados que não sejam estritamente necessários para demonstrar a vulnerabilidade.
- Não execute ataques de negação de serviço (DoS, DDoS).
- Não execute engenharia social contra funcionários da First Security.
- Não use tooling automatizado que cause volume excessivo de requisições.

4. O que oferecemos

- Resposta dentro de 5 dias úteis confirmando recebimento.
- Avaliação técnica detalhada do reporte em até 15 dias úteis.
- Comunicação contínua durante o processo de remediação.
- Reconhecimento público (Hall of Fame) ao pesquisador, mediante consentimento.
- Compromisso de não tomar medidas legais contra quem agir dentro desta política.

5. Canal de reporte

- **Email:** security@firstsecurity.com.br
- Chave PGP disponível mediante solicitação inicial.

6. Hall of Fame

Mantemos lista pública de pesquisadores que contribuíram para a segurança da First Security. Inclusão sempre mediante consentimento expresso.

[SEM CTA / SEM FORMULÁRIO] *Página técnica e jurídica. Sem CTA comercial.*

Política de Confidencialidade

URL completa: <https://firstsecurity.com.br/legal/politica-de-confidencialidade>

HEADER

Política de Confidencialidade da First Security

TEXTO

1. Princípio

Confidencialidade é fundação do nosso negócio. Toda informação compartilhada por cliente ou prospect com a First Security é tratada como ultra confidencial, do primeiro contato à conclusão e arquivamento do projeto.

2. Quando se aplica

A confidencialidade aplica-se a:

- Informações compartilhadas durante a fase comercial (briefing, escopo, cenário técnico).
- Dados, credenciais, documentação e código compartilhados durante execução de projeto.
- Resultados de pentest, Red Team e outros exercícios (vulnerabilidades, achados, evidências).
- Comunicações entre cliente e First Security (email, chat, reuniões).
- Documentos contratuais e financeiros.

3. NDA

A First Security assina NDA antes de qualquer troca de detalhes técnicos com prospect. Aceitamos NDA padrão do cliente ou usamos o nosso modelo. A confidencialidade é mútua: nós também esperamos que o cliente trate como confidencial nosso material proprietário (metodologia, ferramentas internas, propostas comerciais).

4. Controles internos

- Acesso a informação de projeto restrito ao time alocado, por princípio de necessidade.
- Ambientes de trabalho segregados por projeto.
- Criptografia obrigatória em trânsito e em repouso.
- Política de descarte seguro de dados após conclusão.
- Treinamento contínuo da equipe em manejo de informação sensível.

5. Casos públicos

Todo case publicado em /casos-de-uso ou em material de marketing passa por aprovação prévia, por escrito, do cliente envolvido. Mesmo anonimizado, nenhum case é divulgado sem essa aprovação.

6. Vazamento ou incidente

Em caso de qualquer incidente que possa ter exposto informação do cliente, comunicamos o cliente em até 24 horas, com descrição do ocorrido, escopo do impacto e plano de mitigação imediato.

7. Duração

As obrigações de confidencialidade permanecem em vigor mesmo após a conclusão do projeto e o encerramento de qualquer relação comercial, pelo prazo previsto no NDA aplicável (em regra, 5 anos a partir do término), ou por prazo maior quando exigido por lei ou por contrato.

[SEM CTA / SEM FORMULÁRIO] *Página institucional jurídica.*

Parte 14. Encerramento, governança e próximos passos

Esta parte fecha o documento com governança editorial, calendário de manutenção e checklist para a equipe de implementação. Texto pronto e atalhos para os pontos críticos.

14.1 Governança editorial

O conteúdo redigido neste documento é vivo. Páginas, textos e linkagens internas precisam evoluir conforme o mercado, a regulação e a marca evoluem. A First Security adota governança editorial com três níveis.

Responsável editorial

Uma pessoa nomeada (placeholder: head de marketing ou head de conteúdo) tem responsabilidade final sobre tudo que vai ao ar no site. Sem aval dessa pessoa, nada novo é publicado e nada existente é alterado.

Revisores técnicos

Cada categoria temática tem um revisor técnico de plantão: pentest web, mobile, cloud, AD, Red Team, AI Red Teaming, compliance, etc. Textos da categoria passam pelo revisor antes do aval editorial.

Revisão jurídica

Documentos legais (Política de Privacidade, Termos, Cookies, Divulgação Responsável, Confidencialidade) só vão ao ar com aval do advogado responsável pela First Security. Mudanças posteriores também passam por esse aval.

14.2 Calendário de manutenção

Sugestão de calendário mínimo de revisão para manter o site atualizado.

Frequência	O que revisar	Responsável
Mensal	Blog: publicar pelo menos 2 posts novos por mês	Revisores técnicos + responsável editorial
Mensal	Verificar links quebrados em todo o site	Time de implementação
Trimestral	Revisar páginas de serviço (escopo, entregáveis, preço médio)	Revisores técnicos
Trimestral	Atualizar números da página /quem-somos (projetos, vulnerabilidades, CVEs)	Comercial + responsável editorial
Semestral	Revisar páginas pilares (/pentest,	Responsável editorial

	/red-team, /pentest/o-que-e)	
Semestral	Revisar páginas de compliance (mudanças regulatórias)	Revisor técnico de compliance
Anual	Revisar políticas legais	Advogado responsável
Sob demanda	Atualizar cases ao receber autorização de novo cliente	Comercial + responsável editorial

14.3 Checklist para a equipe de implementação

Antes de publicar cada página, verificar os pontos a seguir.

47. Texto importado do documento sem corrupção (acentos, cedilhas, til preservados).
48. Todos os hyperlinks internos apontam para a URL correta (testar cada um na pré-produção).
49. Todos os CTAs estão configurados com texto exato e URL correta.
50. Formulários têm os campos exatos listados, com validação adequada.
51. Integração com CRM configurada e testada.
52. Sequência de email pós-formulário configurada (lead magnets, newsletter, contato).
53. Schema JSON-LD aplicado (Organization, FAQPage, Article, Service conforme a página).
54. Meta tags (title, description) revisadas para SEO.
55. Open Graph e Twitter Cards configurados para compartilhamento.
56. Imagens otimizadas com alt text preenchido.
57. Page Speed Insights superior a 90 em mobile.
58. Acessibilidade básica: contraste, navegação por teclado, screen reader.
59. Cookie banner LGPD funcionando e respeitando a escolha do usuário.
60. Sitemap.xml atualizado.
61. Robots.txt revisado.

14.4 Próximos passos imediatos

Para a equipe que recebe este documento.

62. Revisar o documento integralmente com o head de marketing e a liderança técnica para alinhar tom, terminologia e prioridades.
63. Apontar páginas com placeholders ([nome], [data], [CNPJ]) e providenciar os dados reais.
64. Enviar a Parte 13 (legais) para revisão do advogado responsável.
65. Iniciar a implementação pela Home, hub /pentest, página /pentest/o-que-e e principais serviços (web, API, cloud). Essas páginas concentram a maior parcela do tráfego potencial.
66. Configurar a Política de Privacidade, Política de Cookies e cookie banner antes de qualquer publicação. Não há publicação sem essa fundação LGPD.
67. Implementar as 6 páginas verticais detalhadas e as 5 geográficas detalhadas em ondas posteriores, conforme prioridade comercial.
68. Publicar os 3 posts pilares do blog (Parte 11) no mesmo lançamento, para que o blog não inicie vazio.

69. Definir cronograma editorial dos próximos 6 meses, com pelo menos 2 posts/mês.
70. Definir governança de cases: como capturar autorização do cliente, como anonimizar, como publicar.
71. Marcar revisão completa do documento daqui a 6 meses para validar o que precisa ser atualizado.

14.5 Como atualizar este documento

Este documento deve ser tratado como artefato vivo. Toda alteração de página no site deve ter origem aqui antes de subir ao ar, garantindo coerência entre o que está documentado e o que está publicado. Para alterações pontuais (corrigir um erro, atualizar uma frase), basta editar a parte correspondente e republicar. Para alterações estruturais (adicionar uma página nova, mudar a arquitetura de um silo), pedimos que a equipe de implementação registre a alteração também na Documentação de Implementação do Site.

14.6 Encerramento

Este documento concentra o trabalho de redação completa do conteúdo do site First Security: cerca de [contar] páginas, todas com textos prontos para implementação, CTAs configurados, formulários especificados, linkagens internas mapeadas e marcações claras de onde existe ação e onde existe apenas informação.

A construção desse conteúdo segue o método já praticado pela First Security: profundidade técnica, comunicação direta, ética profissional e respeito pelo tempo de quem lê. Que o site, ao subir ao ar, transmita o mesmo padrão.

Cibersegurança ofensiva séria começa em quem fala, em como fala e no que entrega. Este documento é parte do que entregamos.